c. Summary Of Observation

S.No.	Control No.	Reference(s)	Non-compliance observed	Action taken by CA, if any	Compliance
1	3.1.1.1	WebTrust 3.7.3	Change control procedures exist and are followed for the hardware, network component, and system configuration changes.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Yes
2	3.1.2.2	WebTrust 3.7.6	Application systems are reviewed and tested when operating system changes occur	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Yes

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3	3.1.3.3	WebTrust 3.7.7	The implementation of changes is strictly controlled by the use of formal change control procedures to minimize the risk of corruption of information systems.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	No
4	3.1.4.4	IT CA Rules SCHEDULE II 21.1	Organizational responsibilities for the change management process shall be defined and assigned	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Yes
5	3.1.5.5	IT CA Rules SCHEDULE II 21.1	A risk and impact analysis, classification and prioritisation process shall be	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including	Yes

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

			established	scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	
6	3.1.6.6	IT CA Rules SCHEDULE II 21.1	No changes to a production system shall be implemented until such changes have been formally authorised. Authorisation procedures for change control shall be defined and documented	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	
7	3.1.7.7	IT CA Rules SCHEDULE II 21.1	Owners/Users shall be notified of all changes made to production system which may affect the processing of information on the said production system	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes	Yes

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

				c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	
8	3.1.8.8	IT CA Rules SCHEDULE II 21.1	Fall-back procedures in the event of a failure in the implementation of the change process shall be established and documented.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	
9	3.1.9.9	IT CA Rules SCHEDULE II 21.1	Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation shall be documented and implemented	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures	Yes

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

				e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	
10	3.1.10.10	IT CA Rules SCHEDULE II 21.1	Version changes of application software and all system software installed on the computer systems and all communication devices shall be documented. Different versions of application software and system software must be kept in safe custody	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	
11	3.1.11.1	IT CA Rules SCHEDULE II 21.3	Procedures shall be established for an independent review of programme changes before they are moved into a production environment to detect unauthorized or malicious codes	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented	Yes

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

				6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	
12	3.1.12.2	IT CA Rules SCHEDULE II 21.3	Procedures shall be established to schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	Yes
13	3.1.13.3	IT CA Rules SCHEDULE II 21.3	All emergency changes/fixes in computer resource in the production system shall be reviewed and approved	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	Yes
14	3.1.14.4	IT CA Rules SCHEDULE II 21.3	Periodic management reports on the status of the changes implemented in the computer resourced in the production system shall be submitted for management review	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	Yes

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

15	3.1.15.5	IT CA Rules SCHEDULE III 7	Software updates and patches shall be reviewed for security implications before being implemented on Certifying Authority's system	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	
16	3.1.16.6	IT CA Rules SCHEDULE III 7	Software updates and patches to rectify security vulnerability in critical systems used for Certifying Authority's operation shall be promptly reviewed and implemented	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	
17	3.1.17.7	IT CA Rules SCHEDULE III 7	Information on the software updates and patches and their implementation on Certifying Authority's system shall be clearly and properly documented	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	
18	3.1.18.1	IT CA Rules SCHEDULE II 21.2	All changes in computer resource proposed in the production system	1. On a sample basis verify all changes in computer resource proposed in the production system are tested and the test results are reviewed and accepted by all concerned parties prior to implementation.	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

			shall be tested and the test results shall be reviewed and accepted by all concerned parties prior to implementation.	2. Validate user acceptance tests are performed in a controlled environment which includes requirements mentioned in control 3.2.2.13	
19	3.1.19.2	IT CA Rules SCHEDULE II 21.2	All user acceptance tests in respect of changes in computer resource in production system shall be performed in a controlled environment which includes: (i) Test objectives, (ii) A documented test plan, and (iii) acceptance criteria.	1. On a sample basis verify all changes in computer resource proposed in the production system are tested and the test results are reviewed and accepted by all concerned parties prior to implementation. 2. Validate user acceptance tests are performed in a controlled environment which includes requirements mentioned in control 3.2.2.13	

S.No.	Control No.	Reference(s)	Non-compliance observed	Action taken by CA, if any	Compliance
1	3.2.1.1	WebTrust 1.2	The CA discloses its business practices including but not limited to the topics listed in RFC 3647 or RFC 2527 in its Certificate Policy (CP)	1. Verify the CA has disclosed its business practices including but not limited to the topics listed in RFC 3647 7 in its CPS and CP	Yes

3. Detailed Audit Controls

3.1. Security Guidelines for Certifying Authorities

3.1.1. CA Business Practices Disclosure

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
CA Business Practices Disclosure							
3.1.1.1	The CA discloses its business practices including but not limited to the topics listed in RFC 3647 in its Certification Practice Statement (CPS)	1. Verify the CA has disclosed its business practices including but not limited to the topics listed in RFC 3647 7 in its CPS and CP	Mandatory	WebTrust 1.1	Yes	3.1.1.1-279	
3.1.1.2	The CA discloses its business practices including but not limited to the topics listed in RFC 3647	1. Verify the CA has disclosed its business practices including but not limited to the topics listed in RFC 3647 7 in its CPS and CP	Mandatory	WebTrust 1.2	No	3.1.1.2-280	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	or RFC 2527 in its Certificate Policy (CP)						

3.1.2. Business Practices Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Certification Practice Statement (CPS) Management							
3.1.2.1	The Certification Practice Statement of the Certifying Authority shall comply with, and be governed by, the laws of the country	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	IT CA Rules 18	Yes	3.1.2.1-281	
3.1.2.2	The Policy Authority (PA) has final authority and responsibility for approving the CA's Certification Practice Statement (CPS).	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.1	Yes	3.1.2.2-282	
3.1.2.3	Responsibilities for maintaining the CPS have been formally assigned.	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.2	Yes	3.1.2.3-283	
3.1.2.4	The CA's CPS is modified and approved in accordance with a defined review process.	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the	Mandatory	WebTrust 2.1.3	Yes	3.1.2.4-284	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required					
3.1.2.5	The CA makes available its Certification Practice Statement (CPS) to all appropriate parties	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.4	Yes	3.1.2.5-285	
3.1.2.6	Revisions to the CA's CPS are made available to appropriate parties.	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.5	Yes	3.1.2.6-286	
3.1.2.7	The CA updates its CPS to reflect changes in the environment as they occur	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.6	Yes	3.1.2.7-287	
Certificate Policy (CP) Management							
3.1.2.8	The Policy Authority (PA) has the responsibility of defining the business requirements and policies for using digital certificates and	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.1	Yes	3.1.2.8-288	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	specifying them in a Certificate Policy (CP) and supporting agreements						
3.1.2.9	The PA has final authority and responsibility for specifying and approving Certificate Policy(s).	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.2	Yes	3.1.2.9-289	
3.1.2.10	Certificate Policy(s) are approved by the Policy Authority in accordance with a defined annual review process, including responsibilities for maintaining and tracking changes to the Certificate Policy(s).	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.3	Yes	3.1.2.10-290	
3.1.2.11	A defined review process exists to assess that the Certificate Policy(s) are capable of support by the controls specified in the CPS.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.4	Yes	3.1.2.11-291	
3.1.2.12	The PA makes available the Certificate Policies supported by the CA to Subscribers and Relying Parties	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.5	Yes	3.1.2.12-292	
CP and CPS Consistency							
3.1.2.13	The PA is responsible for ensuring that the CA's control processes, as stated in a Certification Practice Statement (CPS) or equivalent, fully comply with the requirements of the CP.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.1	Yes	3.1.2.13-293	
3.1.2.14	The CA addresses the requirements of the CP when developing its CPS	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.2	Yes	3.1.2.14-294	
3.1.2.15	The CA assesses the impact of proposed CPS changes to ensure that they are consistent with the CP.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.3	Yes	3.1.2.15-295	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.1.2.16	A defined review process exists to ensure that Certificate Policy(s) are supported by the CA's CPS.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.4	Yes	3.1.2.16-296	
3.1.2.17	All changes in Certificate Policy and certification practice statement shall be published on the web site of the Certifying Authority and brought to the notice of the Controller well in advance of such publication. However any change shall not contravene any provision of the Act, rule or regulation or made there under.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	IT Regulations 3	Yes	3.1.2.17-297	

3.1.3. Change Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Change Management							
3.1.3.1	Software testing and change control procedures exist and are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data,	Mandatory	WebTrust 3.7.2	Yes	3.1.3.1-298	

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
3.1.3.2	Change control procedures exist and are followed for the hardware, network component, and system configuration changes.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Mandatory	WebTrust 3.7.3	No	3.1.3.2-299	
3.1.3.3	Application systems are reviewed and tested when operating system changes occur	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the	Mandatory	WebTrust 3.7.6	No	3.1.3.3-300	

COPY NOT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
3.1.3.4	The implementation of changes is strictly controlled by the use of formal change control procedures to minimize the risk of corruption of information systems.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application	Mandatory	WebTrust 3.7.7	No	3.1.3.4-301	

COPY NOT REPORT

		software, system software and communication devices is documented					
3.1.3.5	Organizational responsibilities for the change management process shall be defined and assigned	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Mandatory	IT CA Rules SCHEDULE II 21.1	No	3.1.3.5-302	
3.1.3.6	A risk and impact analysis, classification and prioritisation process shall be established	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change	Mandatory	IT CA Rules SCHEDULE II 21.1	No	3.1.3.6-303	

COMPOSITE REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
3.1.3.7	No changes to a production system shall be implemented until such changes have been formally authorised. Authorisation procedures for change control shall be defined and documented	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Mandatory	IT CA Rules SCHEDULE II 21.1	No	3.1.3.7-304	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.1.3.8	Owners/Users shall be notified of all changes made to production system which may affect the processing of information on the said production system	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Mandatory	IT CA Rules SCHEDULE II 21.1	No	3.1.3.8-305	
3.1.3.9	Fall-back procedures in the event of a failure in the implementation of the change process shall be established and documented.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are	Mandatory	IT CA Rules SCHEDULE II 21.1	No	3.1.3.9-306	

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
3.1.3.10	Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation shall be documented and implemented	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented	Mandatory	IT CA Rules SCHEDULE II 21.1	No	3.1.3.10-307	
3.1.3.11	Version changes of application software and all system software	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the	Mandatory	IT CA Rules SCHEDULE II 21.1	No	3.1.3.11-308	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	installed on the computer systems and all communication devices shall be documented. Different versions of application software and system software must be kept in safe custody	implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
Testing Of Changes To Production System							
3.1.3.12	All changes in computer resource proposed in the production system shall be tested and the test results shall be reviewed and accepted by all concerned parties prior to implementation.	1. On a sample basis verify all changes in computer resource proposed in the production system are tested and the test results are reviewed and accepted by all concerned parties prior to implementation. 2. Validate user acceptance tests are performed in a controlled environment which includes requirements mentioned in control 3.2.2.13	Mandatory	IT CA Rules SCHEDULE II 21.2	No	3.1.3.12-309	
3.1.3.13	All user acceptance tests in respect of changes in computer resource in production system shall be performed in a controlled environment which includes: (i) Test objectives, (ii) A documented test plan, and (iii)	1. On a sample basis verify all changes in computer resource proposed in the production system are tested and the test results are reviewed and accepted by all concerned parties prior to implementation. 2. Validate user acceptance tests are performed in a controlled environment which includes requirements mentioned in control 3.2.2.13	Mandatory	IT CA Rules SCHEDULE II 21.2	No	3.1.3.13-310	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	acceptance criteria.						
Review Of Changes							
3.1.3.14	Procedures shall be established for an independent review of programme changes before they are moved into a production environment to detect unauthorized or malicious codes	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	Mandatory	IT CA Rules SCHEDULE II 21.3	No	3.1.3.14-311	
3.1.3.15	Procedures shall be established to schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	Mandatory	IT CA Rules SCHEDULE II 21.3	No	3.1.3.15-312	
3.1.3.16	All emergency changes/fixes in	1. Verify the change management procedure mentions the following:	Mandatory	IT CA Rules SCHEDULE II 21.3	No	3.1.3.16-313	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	computer resource in the production system shall be reviewed and approved	a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented					
3.1.3.17	Periodic management reports on the status of the changes implemented in the computer resourced in the production system shall be submitted for management review	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	Mandatory	IT CA Rules SCHEDULE II 21.3	No	3.1.3.17-314	
3.1.3.18	Software updates and patches shall be reviewed for security implications before being implemented on Certifying Authority's system	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest	Mandatory	IT CA Rules SCHEDULE III 7	No	3.1.3.18-315	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented					
3.1.3.19	Software updates and patches to rectify security vulnerability in critical systems used for Certifying Authority's operation shall be promptly reviewed and implemented	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented	Mandatory	IT CA Rules SCHEDULE III 7	No	3.1.3.19-316	
3.1.3.20	Information on the software updates and patches and their implementation on Certifying Authority's system shall be clearly and properly documented	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches	Mandatory	IT CA Rules SCHEDULE III 7	No	3.1.3.20-317	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall are clearly and properly documented					

3.1.4. Operations Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Operations Management							
3.1.4.1	CA operating procedures are documented and maintained for each functional area.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.1	Yes	3.1.4.1-318	
3.1.4.2	Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.2	Yes	3.1.4.2-319	

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.1.4.3	Duties and areas of responsibility are segregated in order to reduce opportunities for unauthorized modification or misuse of information or services	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.3	Yes	3.1.4.3-320	
3.1.4.4	Development and testing facilities are separated from operational facilities	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.4	Yes	3.1.4.4-321	
3.1.4.5	Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable	Mandatory	WebTrust 3.5.5	Yes	3.1.4.5-322	

COA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		tests of the system carried out prior to acceptance					
3.1.4.6	Capacity demands are monitored and projections of future capacity requirements made to ensure that adequate processing power and storage are available.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.6	Yes	3.1.4.6-323	
3.1.4.7	Acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.7	Yes	3.1.4.7-324	

3.1.5. Measures to handle computer virus

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Measures to handle computer virus							
3.1.5.1	Detection and prevention controls to protect against viruses and malicious software, including on offline or air	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for	Mandatory	WebTrust 3.5.8	Yes	3.1.5.1-325	

CCA AUDIT REPORT

	gapped systems are implemented. Employee awareness programs are in place.	ensuring all file servers and personal computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are screened and verified by virus detection software before being loaded onto the computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on thedata, file, PKI or computer server or personal computer on Intranet and Internet only after proper screening and verification byvirus detection software					
3.1.5.2	Responsibilities and duties shall be assigned to ensure that allfile servers and personal computers are equipped with up-to- date virus protection and detection software.	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for ensuring all file servers and personal computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are screened and verified by virus detection software before being loaded onto the computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on thedata, file, PKI or computer server or personal computer on Intranet and Internet only after proper screening and verification byvirus detection software	Mandatory	IT CA Rules SCHEDULE II 11	Yes	3.1.5.2-326	
3.1.5.3	Virus detection software must be used to check storage drives both internal and external to the system on a periodic basis	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for ensuring all file servers and personal computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are screened and verified by virus detection software before being loaded onto the computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on thedata, file, PKI or computer server or personal computer on Intranet and Internet	Mandatory	IT CA Rules SCHEDULE II 11	Yes	3.1.5.3-327	

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		only after proper screening and verification byvirus detection software					
3.1.5.4	All diskettes and software shall be screened and verified by virus detection software before being loaded onto the computer system. No magnetic media like tape cartridge, floppies etc. brought from outside shall be used on the data, file, PKI or computer server or personal computer on Intranet and Internet without proper screening and verification by virus detection software	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for ensuring all file servers and personal computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are screened and verified by virus detection software before being loaded onto the computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on thedata, file, PKI or computer server or personal computer on Intranet and Internet only after proper screening and verification byvirus detection software	Mandatory	IT CA Rules SCHEDULE II 11	Yes	3.1.5.4-328	
3.1.5.5	A team shall be designated to deal with reported or suspected incidents of computer virus. The designated team shall ensure that latest version of antivirus software is loaded on all data, file, PKI servers and personal computers.	1. Verify a team is established for incidents management of computer virus 2. Validate the team ensures latest version of antivirus software is loaded on all data, file, PKI servers and personal computers.	Mandatory	IT CA Rules SCHEDULE II 11	Yes	3.1.5.5-329	
3.1.5.6	Procedures shall be established to limit the spread of viruses to other organization information assets. Such procedures inter alia shall include: • Communication to other business partners and users who may be at risk from an infected resource • Eradication and recovery procedures	1. Verify by checking procedures are established to limit the spread of viruses to other organization information assets 2. Check awareness and training programs are in place to communicate virus protection practices, available controls, areas of high risk to virus infection and responsibilities	Mandatory	IT CA Rules SCHEDULE II 11	Yes	3.1.5.6-330	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	• Incident report must be documented and communicated per established procedures						
3.1.5.7	An awareness and training programme shall be established to communicate virus protection practices, available controls, areas of high risk to virus infection and responsibilities	1. Verify by checking procedures are established to limit the spread of viruses to other organization information assets 2. Check awareness and training programs are in place to communicate virus protection practices, available controls, areas of high risk to virus infection and responsibilities	Mandatory	IT CA Rules SCHEDULE II 11	Yes	3.1.5.7-331	

3.1.6. Relocation of hardware and software

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Relocation of hardware and software							
3.1.6.1	Whenever computers or computer peripherals are relocated (e.g. for maintenance, installation at different sites or storage), the following guidelines shall apply: • All removable media will be removed from the computer system and kept at secure location. • Internal drives will be overwritten, reformatted or removed as the situation may be. • If applicable, ribbons will be removed from printers. • All paper will be removed from printers.	1. Perform walkthrough and verify Relocation of hardware and software is performed as per requirements mentioned in the control description	Mandatory	IT CA Rules SCHEDULE II 12	Yes	3.1.6.1-332	

3.1.7. Hardware and software maintenance

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Hardware and software maintenance							

CA - AUDIT REPORT

3.1.7.1	Proper placement and installation of Information Technology equipment to reduce the effects of interference due to electromagnetic emanations.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13	Yes	3.1.7.1-333	
3.1.7.2	Maintenance of an inventory and configuration chart of hardware	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13	Yes	3.1.7.2-334	
3.1.7.3	Identification and use of security features implemented within hardware.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is	Mandatory	IT CA Rules SCHEDULE II 13	Yes	3.1.7.3-335	

COA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements					
3.1.7.4	Authorization, documentation, and control of change made to the hardware	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13	Yes	3.1.7.4-336	
3.1.7.5	Identification of support facilities including power and air conditioning	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance	Mandatory	IT CA Rules SCHEDULE II 13	Yes	3.1.7.5-337	

COA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		personnel have signed non-disclosure agreements					
3.1.7.6	Provision of an uninterruptible power supply.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13	Yes	3.1.7.6-338	
3.1.7.7	Organization must make proper arrangements for maintenance of computer hardware, software (both system and application) and firmware installed and used by them	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13	Yes	3.1.7.7-339	
3.1.7.8	It shall be the responsibility of the officer in charge of the operational site to ensure that contract for annual maintenance of	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of	Mandatory	IT CA Rules SCHEDULE II 13	Yes	3.1.7.8-340	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	hardware is always in place.	hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements					
3.1.7.9	Organization must enter into maintenance agreements, if necessary, with the supplier of computer and communication hardware, software (both system and application) and firmware.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13	Yes	3.1.7.9-341	
3.1.7.10	Maintenance personnel will sign non-disclosure agreements	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place	Mandatory	IT CA Rules SCHEDULE II 13	Yes	3.1.7.10-342	

COA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements					

3.1.8. Purchase and Licensing of Hardware and Software

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Purchase and Licensing of Hardware and Software							
3.1.8.1	Hardware and software products that contain or are to be used to enforce security, and intended for use or interface into any organization system or network, must be verified to comply with these Information Technology Security Guidelines prior to the signing of any contract, purchase or lease.	Validate the hardware and software products comply with the Information Technology Security Guidelines	Mandatory	IT CA Rules SCHEDULE II 14	Yes	3.1.8.1-343	
3.1.8.2	Software, which is capable of bypassing or modifying the security system or operating system, integrity features, must be verified to determine that they conform to these Information Technology Security Guidelines. Where such compliance is not possible, then procedures shall be in place to ensure that the implementation and operation of that software does not compromise the security of the system.	1. Verify procedures have been implemented to ensure that the implementation and operation of that software does not compromise the security of the system	Mandatory	IT CA Rules SCHEDULE II 14	Yes	3.1.8.2-344	
3.1.8.3	There shall be procedures to identify, select, implement and	1. Validate procedures have been implemented to identify, select, implement and control software (system and application software) acquisition and	Mandatory	IT CA Rules SCHEDULE II 14	Yes	3.1.8.3-345	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	control software (system and application software) acquisition and installation to ensure compliance with the Indian Copyright Act and Information Technology Security Guidelines.	installation 2. Check that it is in compliance with the Indian Copyright Act and Information Technology Security Guidelines					
3.1.8.4	It is prohibited to knowingly install on any system whether test or production, any software which is not licensed for use on the specific systems or networks.	1. For software installed on the CA systems verify the following: a. only licensed software are installed on systems used for CA operations b. licensing agreements exists for software installed and used on CA systems c. Illegally acquired or unauthorized software are not used on any computer, computer network or data communication equipment d. System Administrator or Network Administrator are responsible for removing any illegal software if detected	Mandatory	IT CA Rules SCHEDULE II 14	Yes	3.1.8.4-346	
3.1.8.5	No software will be installed and used on the system when appropriate licensing agreements do not exist, except during evaluation periods for which the user has documented permission to install and test the software under evaluation.	1. For software installed on the CA systems verify the following: a. only licensed software are installed on systems used for CA operations b. licensing agreements exists for software installed and used on CA systems c. Illegally acquired or unauthorized software are not used on any computer, computer network or data communication equipment d. System Administrator or Network Administrator are responsible for removing any illegal software if detected	Mandatory	IT CA Rules SCHEDULE II 14	Yes	3.1.8.5-347	
3.1.8.6	Illegally acquired or unauthorized software must not be used on any computer, computer network or data communication equipment. In the event that any illegally acquired or unauthorized software is detected by the System Administrator or Network Administrator, the same must be removed	1. For software installed on the CA systems verify the following: a. only licensed software are installed on systems used for CA operations b. licensing agreements exists for software installed and used on CA systems c. Illegally acquired or unauthorized software are not used on any computer, computer network or data communication equipment d. System Administrator or Network Administrator are responsible for removing any illegal software if detected	Mandatory	IT CA Rules SCHEDULE II 14	Yes	3.1.8.6-348	

3.1.9. System Software

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
System Software							
3.1.9.1	All system software options and parameters shall be reviewed and approved by the management.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15	Yes	3.1.9.1-349	
3.1.9.2	System software shall be comprehensively tested and its security functionality validated prior to implementation.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15	Yes	3.1.9.2-350	

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.1.9.3	All vendor supplied default user IDs shall be deleted or password changed before allowing users to access the computer system	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15	Yes	3.1.9.3-351	
3.1.9.4	Versions of system software installed on the computer system and communication devices shall be regularly updated	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15	Yes	3.1.9.4-352	

COMPANY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.1.9.5	All changes proposed in the system software must be appropriately justified and approved by an authorized party	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15	Yes	3.1.9.5-353	
3.1.9.6	A log of all changes to system software shall be maintained, completely documented and tested to ensure the desired results.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15	Yes	3.1.9.6-354	

COMPTROLLER AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.1.9.7	There shall be no standing "Write" access to the system libraries. All "Write" access shall be logged and reviewed by the System Administrator for dubious activities.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15	Yes	3.1.9.7-355	
3.1.9.8	System Programmers shall not be allowed to have access to the application system's data and programme files in the production environment	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementationc. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All “Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15	Yes	3.1.9.8-356	

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.1.9.9	Procedures to control the use of sensitive system utilities and system programmes that could bypass intended security controls shall be in place and documented. All usage shall be logged and reviewed by the System Administrator and anotherperson independent of System Administrator for dubious activities.	1. Verify documented procedure is present to control the use of sensitive system utilities and system programmes 2. Validate all usage is logged and reviewed by the System Administrator and another person independent of System Administrator for dubious activities	Mandatory	IT CA Rules SCHEDULE II 15	Yes	3.1.9.9-357	

3.1.10. Documentation Security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Documentation Security							
3.1.10.1	All documentation pertaining to application software and sensitive system software and changes made therein shall be updated to the current time, accurately and stored securely. An up-to-date inventory list of all documentation shall be maintained to ensure control and accountability.	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented	Mandatory	IT CA Rules SCHEDULE II 16	Yes	3.1.10.1-358	
3.1.10.2	All documentation and subsequent changes shall be	1. Conduct a walkthrough of the documentation security process and verify the following:	Mandatory	IT CA Rules SCHEDULE II 16	Yes	3.1.10.2-359	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	reviewed and approved by an independent authorized party prior to issue	a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented					
3.1.10.3	Access to application software documentation and sensitive system software documentation shall be restricted to authorized personnel on a "need-to-use" basis only	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented	Mandatory	IT CA Rules SCHEDULE II 16	Yes	3.1.10.3-360	
3.1.10.4	Adequate backups of all documentation shall be maintained and a copy of all critical documentation and manuals shall be stored off-site.	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software	Mandatory	IT CA Rules SCHEDULE II 16	Yes	3.1.10.4-361	

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented					
3.1.10.5	Documentation shall be classified according to the sensitivity of its contents/ implications	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented	Mandatory	T CA Rules SCHEDULE II 16	Yes	3.1.10.5-362	
3.1.10.6	Organizations shall adopt a clean desk policy for papers, diskettes and other documentation in order to reduce the risks of unauthorized access, loss of and damage to information outside normal working hours.	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity	Mandatory	IT CA Rules SCHEDULE II 16	Yes	3.1.10.6-363	

COPY NOT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		h. Clear Desks policy has been implemented					

3.1.11. Firewalls

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Firewalls							
3.1.11.1	All web servers for access by Internet users shall be isolated from other data and host servers.	1. Obtain the network architecture of the CAs system and check the following: a. Networks that operate at varying security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet and any other external connection by a firewall c. Vulnerability assessment is performed on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.	Mandatory	IT CA Rules SCHEDULE II 18	Yes	3.1.11.1-367	
3.1.11.2	Intelligent devices generally known as "Firewalls" shall be used to isolate organization's data network with the external network. Firewall device should also be used to limit network connectivity for unauthorized use.	1. Verify firewalls have been installed to protect the data network and to prevent unauthorized use	Mandatory	IT CA Rules SCHEDULE II 18	Yes	3.1.11.2-364	
3.1.11.3	Networks that operate at varying security levels shall be isolated from each other by appropriate firewalls. The internal network of the organization shall be physically and logically isolated from the Internet and any other external connection by a firewall.	1. Obtain the network architecture of the CAs system and check the following: a. Networks that operate at varying security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet and any other external connection by a firewall c. Vulnerability assessment is performed on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.	Mandatory	IT CA Rules SCHEDULE II 18	Yes	3.1.11.3-365	
3.1.11.4	All firewalls shall be subjected to thorough test for	1. Obtain the network architecture of the CAs system and check the following: a. Networks that operate at varying	Mandatory	IT CA Rules SCHEDULE II 18	Yes	3.1.11.4-366	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	vulnerability prior to being put to use and at least half-yearly thereafter.	security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet and any other external connection by a firewall c. Vulnerability assessment is performed on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.					
3.1.11.5	All web servers for access by Internet users shall be isolated from other data and host servers.	1. Obtain the network architecture of the CAs system and check the following: a. Networks that operate at varying security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet and any other external connection by a firewall c. Vulnerability assessment is performed on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.	Mandatory	IT CA Rules SCHEDULE II 18	Yes	3.1.11.5-368	

3.1.12. Connectivity

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Connectivity							
3.1.12.1	Organization shall establish procedure for allowing connectivity of their computer network or computer system to non-organization computer system or networks. The permission to connect other networks and computer system shall be approved by the Network Administrator and documented	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks d. suitability of new hardware/software particularly the protocol compatibility is assessed before connecting the same to the CA's network e. Internet access is not allowed to database server/ file server or server hosting sensitive data	Mandatory	IT CA Rules SCHEDULE II 19	Yes	3.1.12.1-369	
3.1.12.2	All unused connections and network segments should be disconnected from	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization	Mandatory	IT CA Rules SCHEDULE II 19	Yes	3.1.12.2-370	

CCA - AUDIT REPORT

	active networks. The computer system/personal computer or outside terminal accessing an organization's host system must adhere to the general system security and access control guidelines	computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks d. suitability of new hardware/software particularly the protocol compatibility is assessed before connecting the same to the CA's network e. Internet access is not allowed to database server/ file server or server hosting sensitive data					
3.1.12.3	The suitability of new hardware/software particularly the protocol compatibility should be assessed before connecting the same to the organization's network.	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks d. suitability of new hardware/software particularly the protocol compatibility is assessed before connecting the same to the CA's network e. Internet access is not allowed to database server/ file server or server hosting sensitive data	Mandatory	IT CA Rules SCHEDULE II 19	Yes	3.1.12.3-371	
3.1.12.4	No Internet access should be allowed to database server/ file server or server hosting sensitive data.	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks d. suitability of new hardware/software particularly the protocol compatibility is assessed before connecting the same to the CA's network e. Internet access is not allowed to database server/ file server or server hosting sensitive data	Mandatory	IT CA Rules SCHEDULE II 19	Yes	3.1.12.4-372	

3.1.13. Technical Security Controls

Control	Control	Audit Checks	Control	References	Compliance	Document	Remarks

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

No.			Type				
Activation Data							
3.1.13.1	The activation data used to unlock private keys, in conjunction with any other access control, shall have an appropriate level of strength for the keys or data to be protected and shall meet the applicable security policy requirements of the cryptographic module used to store the keys. Activation data may be user selected. If the activation data must be transmitted, it shall be via an appropriately protected channel, and distinct in time and place from the associated cryptographic module	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure 3. Check the data used to unlock private keys is protected from disclosure and account gets temporarily locker after a number of failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components covered in control 3.2.13.4	Mandatory	X.509 Policy 6.4.1	Yes	3.1.13.1-373	
3.1.13.2	Data used to unlock private keys shall be protected from disclosure. After a predetermined number of failed login attempts, a facility to temporarily lock the account shall be provided	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure 3. Check the data used to unlock private keys is protected from disclosure and account gets temporarily locker after a number of failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components covered in control 3.2.13.4	Mandatory	X.509 Policy 6.4.2	Yes	3.1.13.2-374	
3.1.13.3	CAs, CSPs, shall change the activation data whenever the token is re-keyed or returned from maintenance	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure	Mandatory	X.509 Policy 6.4.3	Yes	3.1.13.3-375	

COMPANY AUDIT REPORT

		3. Check the data used to unlock private keys is protected from disclosure and account gets temporarily locker after a number of failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components covered in control 3.2.13.4					
3.1.13.4	All CA and CSP components shall regularly synchronize with a time service such as Indian Standard Time Service. Time derived from the time service shall be used for establishing the time of: • Initial validity time of a Subscriber's Certificate • Revocation of a Subscriber's Certificate • Posting of CRL updates • OCSP or other CSP responses	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure 3. Check the data used to unlock private keys is protected from disclosure and account gets temporarily locker after a number of failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components covered in control 3.2.13.4	Mandatory	X.509 Policy 6.8	Yes	3.1.13.4-376	

3.1.14. Network Communication Security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Network Communication Security							
3.1.14.1	All sensitive information on the network shall be protected by using appropriate techniques. The critical network devices such as routers, switches and modems should be protected from physical damage	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator's approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security	Mandatory	IT CA Rules SCHEDULE II 17	Yes	3.1.14.1-377	

COA AUDIT REPORT

		against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis					
3.1.14.2	The network configuration and inventories shall be documented and maintained.	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator’s approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis	Mandatory	IT CA Rules SCHEDULE II 17	Yes	3.1.14.2-378	
3.1.14.3	Prior authorization of the Network Administrator shall be obtained for making any changes to network configuration. The changes made in the network configuration shall be documented. The threat and risk assessment of the network after changes in the network configuration shall be reviewed. The network operation shall be monitored for any security irregularity. A formal procedure should be in place for identifying and resolving security problems.	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator’s approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis	Mandatory	IT CA Rules SCHEDULE II 17	Yes	3.1.14.3-379	
3.1.14.4	As far as possible, transmission medium within the Certifying Authority's	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage	Mandatory	IT CA Rules SCHEDULE II 17	Yes	3.1.14.4-380	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	operational site should be secured against electromagnetic transmission. In this regard, use of Optical Fibre Cable and armored cable may be preferred as transmission media as the case may be.	3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator's approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis					
3.1.14.5	Network diagnostic tools, e.g., spectrum analyzer, protocol analyzer should be used on a need basis	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator's approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis	Mandatory	IT CA Rules SCHEDULE II 17	Yes	3.1.14.5-381	
Network Administrator							
3.1.14.6	Each organization shall designate a properly trained "Network Administrator" who will be responsible for operation, monitoring security and functioning of the network.	1. Obtain name of the Network administrator and verify the following: a. Network Administrator is properly trained b. Network Administrator regularly undertakes the review of network and also takes adequate measures to provide physical, logical and procedural safeguards for its security c. Network Administrator promptly investigates unusual activity or pattern of access on the computer network d. Network Administrator is alerted in case of a possible breach	Mandatory	IT CA Rules SCHEDULE II 20	Yes	3.1.14.6-382	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.1.14.7	Network Administrator shall regularly undertake the review of network and also take adequate measures to provide physical, logical and procedural safeguards for its security. Appropriate follow up of any unusual activity or pattern of access on the computer network shall be investigated promptly by the Network Administrator	1. Obtain name of the Network administrator and verify the following: a. Network Administrator is properly trained b. Network Administrator regularly undertakes the review of network and also takes adequate measures to provide physical, logical and procedural safeguards for its security c. Network Administrator promptly investigates unusual activity or pattern of access on the computer network d. Network Administrator is alerted in case of a possible breach	Mandatory	IT CA Rules SCHEDULE II 20	Yes	3.1.14.7-383	
3.1.14.8	System must include a mechanism for alerting the Network Administrator of possible breaches in security, e.g., unauthorized access, virus infection and hacking.	1. Obtain name of the Network administrator and verify the following: a. Network Administrator is properly trained b. Network Administrator regularly undertakes the review of network and also takes adequate measures to provide physical, logical and procedural safeguards for its security c. Network Administrator promptly investigates unusual activity or pattern of access on the computer network d. Network Administrator is alerted in case of a possible breach	Mandatory	IT CA Rules SCHEDULE II 20	Yes	3.1.14.8-384	
3.1.14.9	Secure Network Management System should be implemented to monitor functioning of the computer network. Broadcast of network traffic should be minimized.	1. Verify secure network management system is implemented to monitor functioning of computer network 2. Validate only authorized and legalsoftware are used on the network 3. Check the shared computer systems, network devices used for business applications comply with the requirement established in 3.1.6	Mandatory	IT CA Rules SCHEDULE II 20	Yes	3.1.14.9-385	
3.1.14.10	Only authorized and legal software shall be used on the network.	1. Verify secure network management system is implemented to monitor functioning of computer network 2. Validate only authorized and legalsoftware are used on the network 3. Check the shared computer systems, network devices used for business applications comply with the requirement established in 3.1.6	Mandatory	IT CA Rules SCHEDULE II 20	Yes	3.1.14.10-386	
3.1.14.11	Shared computer systems, network	1. Verify secure network management system is implemented to monitor	Mandatory	IT CA Rules SCHEDULE II 20	Yes	3.1.14.11-387	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	devices used for business applications shall comply with the requirement established in System Integrity and Security Measures (Section 3.1.6).	functioning of computer network 2. Validate only authorized and legalsoftware are used on the network 3. Check the shared computer systems, network devices used for business applications comply with the requirement established in 3.1.6					
3.1.14.12	Network connections from the Certifying Authority's system to external networks shall be restricted to only those connections which are essential to facilitate Certifying Authority's functional processes and services. Such network connections to the external network shall be properly secured and monitored regularly.	1. Understand the network connection process and check the following: a. Network connections for CA’s system to external networks are restricted to only essential connections b. Network connection are secured and monitored regularly c. Network connections are initiated by the systems performing the functions of generation and management of DSC to connect those systems performing the registration and repositoryfunctions but not vice versa	Mandatory	IT CA Rules SCHEDULE III 8	Yes	3.1.14.12-388	
3.1.14.13	Network connections should be initiated by the systems performing the functions of generation and management of DigitalSignature Certificate to connect those systems performing the registration and repository functions but not vice versa. If this isnot possible, compensating controls (e.g. use of proxy servers) shall be implemented to protect the systems performing the function of generation and management of Digital Signature Certificate from potential attacks	1. Understand the network connection process and check the following: a. Network connections for CA’s system to external networks are restricted to only essential connections b. Network connection are secured and monitored regularly c. Network connections are initiated by the systems performing the functions of generation and management of DSC to connect those systems performing the registration and repositoryfunctions but not vice versa	Mandatory	IT CA Rules SCHEDULE III 8	Yes	3.1.14.13-389	
3.1.14.14	Systems	1. Verify Systems performing the DSC	Mandatory	T CA Rules SCHEDULE III 8	Yes	3.1.14.14-390	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	performing the Digital Signature Certification function should be isolated to minimise their exposure to attempts to compromise the confidentiality, integrity and availability of the certification function.	function are isolated to minimize their exposure to attempts to compromise the confidentiality, integrity and availability of thecertification function 2. communications between the CA's systems connected on a network should be secured (encrypted and digitally signed) 3. Intrusion detection tools are deployed to monitor critical networks and perimeter networks and alert administrators of network intrusions and penetration attempts in a timely manner					
3.1.14.15	Communication between the Certifying Authority systems connected on a network shall be secure to ensure confidentiality and integrity of the information. For example, communications between the Certifying Authority's systems connected on a network should be encrypted and digitally signed	1. Verify Systems performing the DSC function are isolated to minimize their exposure to attempts to compromise the confidentiality, integrity and availability of thecertification function 2. communications between the CA's systems connected on a network should be secured (encrypted and digitally signed) 3. Intrusion detection tools are deployed to monitor critical networks and perimeter networks and alert administrators of network intrusions and penetration attempts in a timely manner	Mandatory	IT CA Rules SCHEDULE III 8	Yes	3.1.14.15-391	
3.1.14.16	Intrusion detection tools should be deployed to monitor critical networks and perimeter networks and alert administrators of network intrusions and penetration attempts in a timely manner	1. Verify Systems performing the DSC function are isolated to minimize their exposure to attempts to compromise the confidentiality, integrity and availability of thecertification function 2. communications between the CA's systems connected on a network should be secured (encrypted and digitally signed) 3. Intrusion detection tools are deployed to monitor critical networks and perimeter networks and alert administrators of network intrusions and penetration attempts in a timely manner	Mandatory	IT CA Rules SCHEDULE III 8	Yes	3.1.14.16-392	

3.2. Key Management Controls

3.2.1. Key Lifecycle Management Controls

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Key Generation							
3.2.1.1	The Certifying Authority shall use methods, which are	1. Conduct a walkthrough of the key generation process and check the following	Mandatory	IT CA Rules SCHEDULE III 18.1, IT Regulations 3	Yes	3.2.1.1-393	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	approved by the Controller, to verify the identity of a subscriber before issuing or renewing any Public Key Certificate. The subscriber's key pair shall be generated by the subscriber or on a key generation system in the presence of the subscriber.	a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber’s key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity					
3.2.1.2	The key generation process shall generate statistically random key values that are resistant to known attacks	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber’s key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity	Mandatory	IT CA Rules SCHEDULE III 18.1	Yes	3.2.1.2-394	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.2.1.3	Generation of CA keys shall occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS. Such cryptographic devices perform key generation using a random number generator (RNG) or pseudo random number generator (PRNG).	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity	Mandatory	WebTrust 4.1.1. CA Browser Forum 6.1	Yes	3.2.1.3-395	
3.2.1.4	The CA shall generate its own key pair in the same cryptographic device in which it will be used or the key pair shall be injected directly from the device where it was generated into the device where it will be used.	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle	Mandatory	WebTrust 4.1.2	Yes	3.2.1.4-396	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		2. Verify the steps by referring a recent key generation activity					
3.2.1.5	CA key generation generates keys that: • use a key generation algorithm as disclosed within the CA's CP and/or CPS; • have a key length that is appropriate for the algorithm and for the validity period of the CA certificate as disclosed in the CA's CP and/or CPS. The public key length to be certified by a CA is less than or equal to that of the CA's private signing key; and • take into account requirements on parent and subordinate CA key sizes and have a key size in accordance with the CA's CP and/or CPS.	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity	Mandatory	WebTrust 4.1.3	Yes	3.2.1.5-397	
3.2.1.6	CA key generation ceremonies are independently witnessed by internal or external auditors. The private key of the Certifying Authority shall be adequately secured at each phase of its life cycle, i.e. key generation, distribution, storage, usage, backup, archival and destruction.	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are	Mandatory	WebTrust 4.1.4, IT Regulations 3	Yes	3.2.1.6-398	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity					
3.2.1.7	The CA follows a CA key generation script for key generation ceremonies that includes the following: • definition and assignment of participant roles and responsibilities; • management approval for conduct of the key generation ceremony; • specific cryptographic hardware, software and other materials including identifying information, e.g., serial numbers; • specific steps performed during the key generation ceremony • physical security requirements for the ceremony location (e.g., barriers, access controls and logging controls); • procedures for secure storage of cryptographic hardware and activation materials following the key generation ceremony (e.g., detailing the allocation of materials between storage locations); • sign-off on the script or in a log from participants and witnesses indicating whether key generation ceremony was performed in accordance with the detailed key generation ceremony script; and • notation of any deviations from the key generation ceremony script (e.g., documentation of steps taken to address any technical issues)	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity	Mandatory	WebTrust 4.1.5	Yes	3.2.1.7-399	
3.2.1.8	The integrity of the hardware/software used for key generation and the interfaces to the	1. Conduct a walkthrough of the key generation process and check the following a. CA uses methods approved by	Mandatory	WebTrust 4.1.6	Yes	3.2.1.8-400	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	hardware/software is tested before production usage.	Controller to verify identity of subscriber before issuing or renewing public key certificate b. Subscriber's key pair is generated by the subscriber or on a key generation system in the presence of the subscriber. c. key generation process generates statistically random key values that are resistant to known attacks d. Generation of CA keys occur within a cryptographic module meeting the applicable requirements of ISO 15782-1/FIPS 140-2 (or equivalent)/ANSI X9.66 and the business requirements in accordance with the CPS e. CA generates its own key pair in the same cryptographic device in which it will be used f. CA generates keys in compliance with the requirements mentioned in 3.3.1.5 g. CA key generation ceremonies are independently witnessed by internal or external auditors. h. Private key of CA is adequately secured at each phase of its lifecycle 2. Verify the steps by referring a recent key generation activity					
Key Storage, Backup, and Recovery							
3.2.1.9	The CA's private (signing and confidentiality) keys are stored and used within a secure cryptographic device meeting the appropriate ISO 15408 protection profile or FIPS 140-1 level 3 recommendations for Cryptographic Modules Validation Listbased on a risk assessment and the business requirements of the CA and in accordance with the CA's CPS and applicable Certificate Policy(s)	1. For the Key Storage, Backup, and Recovery process, verify the following: a. CA's private (signing and confidentiality) keys are stored and used within a secure cryptographic device meeting the appropriate ISO 15408 protection profile or or FIPS 140-1 level 3 recommendations for Cryptographic Modules b. CA private key is generated, stored and used within the same cryptographic module if CA's private keys are not exported from a secure cryptographic module c. When CA's private keys are exported from a secure cryptographic module the requirements mentioned in control 3.3.1.11 d. Backup copies of the CA's private keys are maintained with the same or greater level of security controls as keys currently in use e. recovery of the CA's keys is carried out in as secure a manner as the backup process, using multi-person control.	Mandatory	WebTrust 4.2.1, IT Regulations 3, CA Browser Forum 6.2.7, X.	Yes	3.2.1.9-401	
3.2.1.10	If the CA's private keys are not exported from a secure cryptographic	1. For the Key Storage, Backup, and Recovery process, verify the following:	Mandatory	WebTrust 4.2.2	Yes	3.2.1.10-402	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	module, then the CA private key is generated, stored and used within the same cryptographic module.	a. CA's private (signing and confidentiality) keys are stored and used within a secure cryptographic device meeting the appropriate ISO 15408 protection profile or or FIPS 140-1 level 3 recommendations for Cryptographic Modules b. CA private key is generated, stored and used within the same cryptographic module if CA's private keys are not exported from a secure cryptographic module c. When CA's private keys are exported from a secure cryptographic module the requirements mentioned in control 3.3.1.11 d. Backup copies of the CA's private keys are maintained with the same or greater level of security controls as keys currently in use e. recovery of the CA's keys is carried out in as secure a manner as the backup process, using multi-person control.					
3.2.1.11	If the CA's private keys are exported from a secure cryptographic module to secure storage for purposes of offline processing or backup and recovery, then they are exported within a secure key management scheme that may include any of the following: • as cipher-text using a key which is appropriately secured; • as encrypted key fragments using multiple control and split knowledge/ownership; or • In another secure cryptographic module such as a key transportation device using multiple control.	1. For the Key Storage, Backup, and Recovery process, verify the following: a. CA's private (signing and confidentiality) keys are stored and used within a secure cryptographic device meeting the appropriate ISO 15408 protection profile or or FIPS 140-1 level 3 recommendations for Cryptographic Modules b. CA private key is generated, stored and used within the same cryptographic module if CA's private keys are not exported from a secure cryptographic module c. When CA's private keys are exported from a secure cryptographic module the requirements mentioned in control 3.3.1.11 d. Backup copies of the CA's private keys are maintained with the same or greater level of security controls as keys currently in use e. recovery of the CA's keys is carried out in as secure a manner as the backup process, using multi-person control.	Mandatory	WebTrust 4.2.3	Yes	3.2.1.11-403	
3.2.1.12	Backup copies of the CA's private keys are subject to the same or greater level of security controls as keys currently in use. The recovery of the CA's keys is carried out in as secure a manner as the	1. For the Key Storage, Backup, and Recovery process, verify the following: a. CA's private (signing and confidentiality) keys are stored and used within a secure cryptographic device meeting the appropriate ISO 15408 protection profile or or FIPS 140-1 level 3 recommendations for	Mandatory	WebTrust 4.2.4	Yes	3.2.1.12-404	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	backup process, using multi-person control.	Cryptographic Modules b. CA private key is generated, stored and used within the same cryptographic module if CA's private keys are not exported from a secure cryptographic module c. When CA's private keys are exported from a secure cryptographic module the requirements mentioned in control 3.3.1.11 d. Backup copies of the CA's private keys are maintained with the same or greater level of security controls as keys currently in use e. recovery of the CA's keys is carried out in as secure a manner as the backup process, using multi-person control.					
Key Distribution							
3.2.1.13	Keys shall be transferred from the key generation system to the storage device (if the keys are not stored on the key generation system) using a secure mechanism that ensures confidentiality and integrity	1. Verify the key is transferred from the key generation system to the storage device using a secure mechanism that ensures confidentiality and integrity	Mandatory	IT CA Rules SCHEDULE III 18.2	Yes	3.2.1.13-405	
3.2.1.14	The initial distribution mechanism for the CA's public key is controlled and initially distributed within a Certificate using one of the following methods: • machine readable media (e.g., smart card, flash drive, CD ROM) from an authenticated source; • embedding in an entity's cryptographic module; or • other secure means that ensure authenticity and integrity.	1. Validate the initial distribution mechanism for the CA's public key is controlled and initially distributed within a Certificate using one of the methods mentioned in control description	Mandatory	WebTrust 4.3.2	Yes	3.2.1.14-406	
3.2.1.15	The CA's public key is changed (rekeyed) periodically according to the requirements of the CPS with advance notice provided to avoid disruption of the CA services	1. Verify by checking documentation of frequency of change of public key and validate CA's public key is changed (rekeyed) periodically according to the requirements	Mandatory	WebTrust 4.3.3	Yes	3.2.1.15-407	
3.2.1.16	The subsequent	1. On a sample basis verify the	Mandatory	WebTrust 4.3.4	Yes	3.2.1.16-408	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	distribution mechanism for the CA's public key is controlled in accordance with the CA's disclosed business practices.	distribution mechanism for the CA's public key is controlled in accordance with the CA's disclosed business practices					
3.2.1.17	If an entity already has an authenticated copy of the CA's public key, a new CA public key is distributed using one of the following methods: • direct electronic transmission from the CA; • placing into a remote cache or directory; • loading into a cryptographic module; or • any of the methods used for initial distribution	1. Validate on a sample basis if an entity has an authenticated copy of CAs public key, a new CA public key is distributed using one of the methods mentioned in control description	Mandatory	WebTrust 4.3.5	Yes	3.2.1.17-409	
3.2.1.18	The CA provides a mechanism for validating the authenticity and integrity of the CA's public keys.The CA provides a mechanism for validating the authenticity and integrity of the CA's public keys.	1. Verify CA has a mechanism in place for validating the authenticity and integrity of the CA's public keys	Mandatory	WebTrust 4.3.6	Yes	3.2.1.18-410	
Key Usage							
3.2.1.19	A system and software integrity check shall be performed prior to Certifying Authority's key loading. Custody of and access to the Certifying Authority's keys shall be under split control. In particular, Certifying Authority's key loading shall be performed under split control	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading b. Custody of and access to the CA's keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers' certificates. g. CA ceases to use a key pair at the	Mandatory	IT CA Rules SCHEDULE III 18.4	Yes	3.2.1.19-411	

CC AUDIT REPORT

		end of the key pair’s defined operational lifetime					
3.2.1.20	The activation of the CA private signing key shall be performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs).	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading b. Custody of and access to the CA’s keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers’ certificates. g. CA ceases to use a key pair at the end of the key pair’s defined operational lifetime	Mandatory	WebTrust 4.4.1	Yes	3.2.1.20-412	
3.2.1.21	The activation of the CA private key shall be performed using multi-factor authentication (e.g., smart card and password, biometric and password, etc.).	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading b. Custody of and access to the CA’s keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers’ certificates. g. CA ceases to use a key pair at the end of the key pair’s defined operational lifetime	Mandatory	WebTrust 4.4.2	Yes	3.2.1.21-413	
3.2.1.22	CA signing key(s) used for generating certificates and/or issuing revocation status information, shall not be	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading	Mandatory	WebTrust 4.4.3	Yes	3.2.1.22-414	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	used for any other purpose.	b. Custody of and access to the CA's keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers' certificates. g. CA ceases to use a key pair at the end of the key pair's defined operational lifetime					
3.2.1.23	In the event of a compromise of the private key the Certifying Authority shall follow the established procedures for immediate revocation of the affected subscribers' certificates. The CA ceases to use a key pair at the end of the key pair's defined operational lifetime or when the compromise of the private key is known or suspected	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading b. Custody of and access to the CA's keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers' certificates. g. CA ceases to use a key pair at the end of the key pair's defined operational lifetime	Mandatory	IT Regulations 3, WebTrust 4.4.4	Yes	3.2.1.23-415	
3.2.1.24	An annual review is required by the PA on key lengths to determine the appropriate key usage period with recommendations acted upon.	1. For the CAs key usage process, check the following: a. A system and software integrity check is performed prior to Certifying Authority's key loading b. Custody of and access to the CA's keys is under split control c. activation of the CA private signing key is performed using multi-party control (i.e., m of n) with a minimum value of m (e.g., m greater than 2 for Root CAs) d. activation of the CA private key is performed using multi-factor authentication	Mandatory	WebTrust 4.4.5	Yes	3.2.1.24-416	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		e. CA signing key(s) used for generating certificates and/or issuing revocation status information, are not used for any other purpose f. CA follows established procedures in event of a compromise of private key of the CA for immediate revocation of the affected subscribers' certificates. g. CA ceases to use a key pair at the end of the key pair's defined operational lifetime					
3.2.1.25	Private Keys corresponding to Root Certificates MUST NOT be used to sign Certificates except in the following cases: • Self-signed Certificates to represent the Root CA itself; • Certificates for Subordinate CAs and Cross Certificates; • Certificates for infrastructure purposes (administrative role certificates, internal CA operational device certificates); and • Certificates for OCSP Response verification	1. Verify the private keys corresponding to Root Certificate are not used to sign Certificates except in the cases mentioned in control description	Mandatory	CA Browser Forum 6.1.7, X.509 Policy 6.1.7	Yes	3.2.1.25-417	
Key Archival							
3.2.1.26	Archived CA keys are subject to the same or greater level of security controls as keys currently in use.	1. For the key archival process, check the following: a. Archived CA keys are subject to the same or greater level of security controls as keys currently in use b. For sample archived CA keys, verify, these were destroyed at the end of the archive period using dual control in a physically secure site. c. Subscriber private signature keys is not archived by the CA d. Archived keys are only accessed where historical evidence requires validation e. Archived keys are recovered for the shortest possible time period technically permissible to meet business requirements f. Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period	Mandatory	WebTrust 4.5.1 CA Browser Forum 6.3.1, X.509 Policy 6.3.1	Yes	3.2.1.26-418	
3.2.1.27	All archived CA keys are destroyed at the end of the archive period using dual control in a physically secure site.	1. For the key archival process, check the following: a. Archived CA keys are subject to the same or greater level of security controls as keys currently in use	Mandatory	WebTrust 4.5.2, X.509 Policy 6.2.5	Yes	3.2.1.27-419	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	Subscriber private signature keys shall not be archived by the CA	b. For sample archived CA keys, verify, these were destroyed at the end of the archive period using dual control in a physically secure site. c. Subscriber private signature keys is not archived by the CA d. Archived keys are only accessed where historical evidence requires validation e. Archived keys are recovered for the shortest possible time period technically permissible to meet business requirements f. Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period					
3.2.1.28	Archived keys are only accessed where historical evidence requires validation. Control processes are required to ensure the integrity of the CA systems and the key sets.	1. For the key archival process, check the following: a. Archived CA keys are subject to the same or greater level of security controls as keys currently in use b. For sample archived CA keys, verify, these were destroyed at the end of the archive period using dual control in a physically secure site. c. Subscriber private signature keys is not archived by the CA d. Archived keys are only accessed where historical evidence requires validation e. Archived keys are recovered for the shortest possible time period technically permissible to meet business requirements f. Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period	Mandatory	WebTrust 4.5.3	Yes	3.2.1.28-420	
3.2.1.29	Archived keys are recovered for the shortest possible time period technically permissible to meet business requirements.	1. For the key archival process, check the following: a. Archived CA keys are subject to the same or greater level of security controls as keys currently in use b. For sample archived CA keys, verify, these were destroyed at the end of the archive period using dual control in a physically secure site. c. Subscriber private signature keys is not archived by the CA d. Archived keys are only accessed where historical evidence requires validation e. Archived keys are recovered for the shortest possible time period technically permissible to meet business requirements f. Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period	Mandatory	WebTrust 4.5.4	Yes	3.2.1.29-421	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.2.1.30	Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period.	1. For the key archival process, check the following: a. Archived CA keys are subject to the same or greater level of security controls as keys currently in use b. For sample archived CA keys, verify, these were destroyed at the end of the archive period using dual control in a physically secure site. c. Subscriber private signature keys is not archived by the CA d. Archived keys are only accessed where historical evidence requires validation e. Archived keys are recovered for the shortest possible time period technically permissible to meet business requirements f. Archived keys are periodically verified to ensure that they are properly destroyed at the end of the archive period	Mandatory	WebTrust 4.5.5	Yes	3.2.1.30-422	
Key Destruction							
3.2.1.31	Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space must be securely destroyed by over-writing. Private key destruction procedures must be described in the Certification Practice Statement or other publicly available document.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are	Mandatory	IT CA Rules SCHEDULE III 20	Yes	3.2.1.31-423	

CCA IT AUDIT REPORT

		destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.32	The CA's private keys shall be destroyed only if the business purpose or application has ceased to have value or legal obligations have expired as disclosed within the CA's CPS.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.6.1	Yes	3.2.1.32-424	

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.2.1.33	The CA's private keys shall be destroyed only if the business purpose or application has ceased to have value or legal obligations have expired as disclosed within the CA's CPS.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.6.1	Yes	3.2.1.33-425	
3.2.1.34	Authorization to destroy a CA private key and how the CA's private key is destroyed (e.g., token surrender, token destruction, or key overwrite) are limited in accordance with the CA's CPS.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value	Mandatory	WebTrust 4.6.2	Yes	3.2.1.34-426	

CC AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.35	All copies and fragments of the CA's private key are destroyed at the end of the key pair life cycle in a manner such that the private key cannot be retrieved.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a	Mandatory	WebTrust 4.6.3	Yes	3.2.1.35-427	

CC AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.36	If a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed	Mandatory	WebTrust 4.6.4	Yes	3.2.1.36-428	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.37	If a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the	Mandatory	WebTrust 4.6.5	Yes	3.2.1.37-429	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		process					
3.2.1.38	If a CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.6.6	Yes	3.2.1.38-430	
3.2.1.39	Backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS	Mandatory	WebTrust 4.6.7	Yes	3.2.1.39-431	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.40	The CA follows a CA key destruction script for key destruction ceremonies that includes the following: • definition and assignment of participant roles and responsibilities; • management approval for conduct of the key destruction ceremony; • specific cryptographic hardware, software and other materials including identifying information, e.g., serial numbers, that contain the CA key copies to be destroyed; • specific steps performed during the key destruction	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private keys stored within the device that	Mandatory	WebTrust 4.6.8	Yes	3.2.1.40-432	

CC AUDIT REPORT

	ceremony, including; o HSM and/or cryptographic hardware zeroisation/initialisation o HSM and/or cryptographic hardware physical destruction o Deletion of any encrypted files containing the CA key or fragments thereof • physical security requirements for the ceremony location(e.g., barriers, access controls and logging controls); • procedures for secure storage of cryptographic hardware and any associated activation materials following the key destruction ceremony pending their disposal or additional destruction • sign-off on the script or in a log from participants and witnesses indicating whether the key destruction ceremony was performed in accordance with the detailed key destruction ceremony script; and • notation of any deviations from the key destruction ceremony script (e.g., documentation of steps taken to address any technical issues).	have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.41	CA key destruction ceremonies are independently witnessed by internal or external auditors.	1. Conduct walkthrough of the key destruction process and check the following: a. Upon termination of use of a private key, all copies of the private key in computer memory and shared disk space are securely destroyed by over-writing b. Private key destruction procedures must be described in the CPS c. CA's private keys is destroyed only if the business purpose or application has ceased to have value or legal obligations have expired d. Authorization to destroy a CA private key and how the CA's private key is destroyed is done in accordance with CA's CPS 2. Validate if in case a secure cryptographic device is accessible and known to be permanently removed from service, all CA private	Mandatory	WebTrust 4.6.9	Yes	3.2.1.41-433	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		keys stored within the device that have ever been or potentially could be used for any cryptographic purpose are destroyed. 3. Validate if a CA cryptographic device is being permanently removed from service, then any key contained within the device that has been used for any cryptographic purpose is erased from the device. 4. Verify if the CA cryptographic device case is intended to provide tamper-evident characteristics and the device is being permanently removed from service, then the case is destroyed 5. Validate backup or additional copies of CA keys that no longer serve a valid business purpose are destroyed in accordance with the CA's disclosed business practices 6. Verify the CA follows a CA key destruction script for key destruction ceremonies that includes the requirements covered n control 3.3.1.39 7. For a recent key destruction ceremony, verify name of the auditor who independently witnessed the process					
Key Compromise							
3.2.1.42	A procedure shall be pre-established to handle cases where a compromise of the Certifying Authority's Digital Signature private key has occurred.	1. Conduct walkthrough of the key compromise process and check the following for sample incidents: a. Procedure has been pre-established to handle cases where a compromise of the CA's Digital Signature private key has occurred. b. CA immediately revokes all affected subscriber DSC c. CAs public keys are archived permanently to facilitate audit d. Archives of CA's publickeys are protected from unauthorized modification	Mandatory	IT CA Rules SCHEDULE III 21.3, IT Regulations 3, X.509 Polic	Yes	3.2.1.42-434	
3.2.1.43	The Certifying Authority should immediately revoke the affected keys and Digital Signature Certificates in the case of Subscriber private key compromise.	1. Conduct walkthrough of the key compromise process and check the following for sample incidents: a. Procedure has been pre-established to handle cases where a compromise of the CA's Digital Signature private key has occurred. b. CA immediately revokes all affected subscriber DSC c. CAs public keys are archived permanently to facilitate audit d. Archives of CA's publickeys are protected from unauthorized modification	Mandatory	IT CA Rules SCHEDULE III 21.3, IT Regulations 3	Yes	3.2.1.43-435	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.2.1.44	The Certifying Authority's public keys shall be archived permanently to facilitate audit or investigation requirements	1. Conduct walkthrough of the key compromise process and check the following for sample incidents: a. Procedure has been pre-established to handle cases where a compromise of the CA's Digital Signature private key has occurred. b. CA immediately revokes all affected subscriber DSC c. CAs public keys are archived permanently to facilitate audit d. Archives of CA's publickeys are protected from unauthorized modification	Mandatory	IT CA Rules SCHEDULE III 21.3	Yes	3.2.1.44-436	
3.2.1.45	Archives of Certifying Authority's public keys shall be protected from unauthorized modification	1. Conduct walkthrough of the key compromise process and check the following for sample incidents: a. Procedure has been pre-established to handle cases where a compromise of the CA's Digital Signature private key has occurred. b. CA immediately revokes all affected subscriber DSC c. CAs public keys are archived permanently to facilitate audit d. Archives of CA's publickeys are protected from unauthorized modification	Mandatory	IT CA Rules SCHEDULE III 21.3	Yes	3.2.1.45-437	
3.2.1.46	The CA's business continuity plans address the compromise or suspected compromise of a CA's private keys as a disaster.	1. Verify the CA's business continuity plans address the compromise or suspected compromise of a CA's private keys as a disaster 2. Validate disaster recovery procedures include the revocation and reissuance of all certificates that were signed with that CA's private key, in the event of the compromise or suspected compromise 3. Check the recovery procedures used if the CA's private key covers the requirements mentioned in control 3.3.1.47	Mandatory	WebTrust 4.7.1	Yes	3.2.1.46-438	
3.2.1.47	Disaster recovery procedures include the revocation and reissuance of all certificates that were signed with that CA's private key, in the event of the compromise or suspected compromise of a CA's private signing key.	1. Verify the CA's business continuity plans address the compromise or suspected compromise of a CA's private keys as a disaster 2. Validate disaster recovery procedures include the revocation and reissuance of all certificates that were signed with that CA's private key, in the event of the compromise or suspected compromise	Mandatory	WebTrust 4.7.2	Yes	3.2.1.47-439	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		3. Check the recovery procedures used if the CA's private key covers the requirements mentioned in control 3.3.1.47					
3.2.1.48	The recovery procedures used if the CA's private key is compromised include the following actions: • how secure key usage in the environment is re-established; • how the CA's old public key is revoked; • how affected parties are notified (e.g., impacted CAs, Repositories, Subscribers and CVSPs); • how the CA's new public key is provided to the end entities and Relying Parties together with the mechanism for their authentication; and • how the subscriber's public keys are re-certified.	1. Verify the CA's business continuity plans address the compromise or suspected compromise of a CA's private keys as a disaster 2. Validate disaster recovery procedures include the revocation and reissuance of all certificates that were signed with that CA's private key, in the event of the compromise or suspected compromise 3. Check the recovery procedures used if the CA's private key covers the requirements mentioned in control 3.3.1.47	Mandatory	WebTrust 4.7.3	Yes	3.2.1.48-440	
3.2.1.49	In the event that the CA has to replace its Root CA private key, procedures are in place for the secure and authenticated revocation of the following: • the old CA root public key; • the set of all certificates (including any self-signed) issued by a Root CA or any CA based on the compromised private key; and • any subordinate CA public keys and corresponding certificates that require recertification	1. Validate CA has a procedure in place in the event that the CA has to replace its private key	Mandatory	WebTrust 4.7.4	Yes	3.2.1.49-441	
3.2.1.50	The CA's business continuity plan for key compromise addresses who is notified and what actions are taken with system software and hardware, symmetric and asymmetric keys, previously generated signatures and encrypted data.	1. Verify CA's business continuity plan addresses list of people to be notified and what actions are taken with system software and hardware, symmetric and asymmetric keys, previously generated signatures and encrypted data	Mandatory	WebTrust 4.7.5	Yes	3.2.1.50-442	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

Cryptographic Hardware Life Cycle Management							
3.2.1.51	To prevent tampering, CA cryptographic hardware is stored and used in a secure site, with access limited to authorized personnel, having the following characteristics: • inventory control processes and procedures to manage the origination, arrival, condition, departure and destination of each device; • access control processes and procedures to limit physical access to authorized personnel; • recording of all successful or failed access attempts to the CA facility and device storage mechanism (e.g., a safe) in audit logs; • incident handling processes and procedures to handle abnormal events, security breaches, and investigation and reports; and • monitoring processes and procedures to verify the ongoing effectiveness of the controls.	1. Conduct a walkthrough of process of transfer of cryptographic hardware 2. Verify for sample cryptographic hardware which does not contain CA keys is sent from the manufacturer or alternate CA site via registered mail (or equivalent) using tamper evident packaging 3. Validate the cryptographic hardware from the manufacturer, acceptance testing and verification of firmware settings is performed upon the receipt of CA 4. Validate CA takes measure to prevent tampering of cryptographic hardware covering the characteristics mentioned in control (3.3.1.52) description	Mandatory	WebTrust 4.8.3	Yes	3.2.1.51-445	
3.2.1.52	Correct processing of CA cryptographic hardware is verified on a periodic basis.	1. Validate the processing of cryptographic hardware is verified on a periodic basis.	Mandatory	WebTrust 4.8.7	Yes	3.2.1.52-449	
3.2.1.53	Diagnostic support is provided during troubleshooting of CA cryptographic hardware in the presence of no less than two trusted employees	1. Validate diagnostic support is provided and check the names of trusted employees responsible for overlooking support	Mandatory	WebTrust 4.8.8	Yes	3.2.1.53-450	
3.2.1.54	CA cryptographic hardware which does not contain CA keys is sent from the manufacturer or alternate CA site via registered mail (or equivalent) using tamper evident packaging.	1. Conduct a walkthrough of process of transfer of cryptographic hardware 2. Verify for sample cryptographic hardware which does not contain CA keys is sent from the manufacturer or alternate CA site via registered mail (or equivalent) using tamper evident packaging 3. Validate the cryptographic	Mandatory	WebTrust 4.8.1	Yes	3.2.1.54-443	

CC AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	Upon the receipt of CA cryptographic hardware from the manufacturer or alternate site, authorized CA personnel inspects the tamper evident packaging to determine whether the seal is intact.	hardware from the manufacturer, acceptance testing and verification of firmware settings is performed upon the receipt of CA 4. Validate CA takes measure to prevent tampering of cryptographic hardware covering the characteristics mentioned in control (3.3.1.52) description					
3.2.1.55	Upon the receipt of CA cryptographic hardware from the manufacturer, acceptance testing and verification of firmware settings is performed. Upon the receipt of CA cryptographic hardware that has been serviced or repaired, acceptance testing and verification of firmware settings is performed.	1. Conduct a walkthrough of process of transfer of cryptographic hardware 2. Verify for sample cryptographic hardware which does not contain CA keys is sent from the manufacturer or alternate CA site via registered mail (or equivalent) using tamper evident packaging 3. Validate the cryptographic hardware from the manufacturer, acceptance testing and verification of firmware settings is performed upon the receipt of CA 4. Validate CA takes measure to prevent tampering of cryptographic hardware covering the characteristics mentioned in control (3.3.1.52) description	Mandatory	WebTrust 4.8.2	Yes	3.2.1.55-444	
3.2.1.56	When not attached to the CA system, the CA cryptographic hardware is stored in a tamper resistant container that is stored securely under multiple controls (i.e., a safe)	1. Validate use of tamper resistant containers to store the CA cryptographic hardware	Mandatory	WebTrust 4.8.4	Yes	3.2.1.56-446	
3.2.1.57	The handling of CA cryptographic hardware, including the following tasks, is performed in the presence of no less than two trusted employees: • installation of CA cryptographic hardware; • removal of CA cryptographic hardware from production; • servicing or repair of CA cryptographic hardware (including installation of new hardware, firmware, or software); and • disassembly and permanent removal from use	1. Obtain names of employees responsible for handling of CA cryptographic hardware 2. Validate by discussing with them if they were present during installation, removal servicing, repair, disassembly and permanent removal of CA cryptographic hardware	Mandatory	WebTrust 4.8.5	Yes	3.2.1.57-447	
3.2.1.58	Devices used for private	1. Verify by checking reports of the	Mandatory	WebTrust 4.8.6	Yes	3.2.1.58-448	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	key storage and recovery and the interfaces to these devices are tested before usage for integrity.	testing performed on devices used 1for private key storage					
Key Escrow							
3.2.1.59	If a third party provides CA private key escrow services, a contract exists that outlines the liabilities and remedies between the parties.	1. Verify if third party provides CA private key escrow services, a contract exists that outlines the liabilities and remedies between the parties 2. Validate if CA private keys are held in escrow, escrowed copies of CA private signing keys have the same or greater level of se urity controls as keys currently in use	Mandatory	WebTrust 4.9.1	Yes	3.2.1.59-451	
3.2.1.60	If CA private signing keys are held in escrow, escrowed copies of the CA private signing keys have the same or greater level of security controls as keys currently in use.	1. Verify if third party provides CA private key escrow services, a contract exists that outlines the liabilities and remedies between the parties 2. Validate if CA private keys are held in escrow, escrowed copies of CA private signing keys have the same or greater level of se urity controls as keys currently in use	Mandatory	WebTrust 4.9.2	Yes	3.2.1.60-452	
Key Transportation							
3.2.1.61	CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for	Mandatory	WebTrust 4.10.1	Yes	3.2.1.61-453	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.62	CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.10.2	Yes	3.2.1.62-454	
3.2.1.63	CA keys are only transported on hardware devices and in tamper-evident packaging as disclosed in the CA's business practices.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control	Mandatory	WebTrust 4.10.3	Yes	3.2.1.63-455	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.64	If the hardware device contains the entire CA key, it is physically transported by at least two CA employees and remains under multi-person control from origin to destination.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging	Mandatory	WebTrust 4.10.4	Yes	3.2.1.64-456	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.65	If the CA key is divided into fragments on multiple hardware devices: • If transported by CA employees, each fragment is transported separately using different transportation routes, methods, and/or times; or • If transported by common carrier, each fragment is sent using a different common carrier at different times. Shipments require signature service, tracking, are insured.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.10.5	Yes	3.2.1.65-457	
3.2.1.66	Activation materials are transported separately from the CA key (i.e. by a different method and/or at a different time) in tamper-evident	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under	Mandatory	WebTrust 4.10.6	Yes	3.2.1.66-458	

CCA - AUDIT REPORT

	packaging	multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.67	Upon receipt at the destination, packaging for CA keys and activation materials are reviewed for evidence of tampering. If evidence of tampering is discovered, the Policy Authority is notified of a possible breach event	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are	Mandatory	WebTrust 4.10.7	Yes	3.2.1.67-459	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.68	Upon receipt at the destination, CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.10.8	Yes	3.2.1.68-460	
3.2.1.69	Personnel involved in a CA key transportation event are in Trusted Roles and have received	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport	Mandatory	WebTrust 4.10.9	Yes	3.2.1.69-461	

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	training in their role and responsibilities.	in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.70	A log is maintained of all actions taken as part of the CA key transportation event and is retained in accordance with the CA's disclosed business practices.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control	Mandatory	WebTrust 4.10.10	Yes	3.2.1.70-462	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process					
3.2.1.71	Internal or external auditors accompany CA personnel during CA key transportation events.	1. Conduct walkthrough of the key transportation process and check the following: a. CA keys are prepared for transport in a physically secure environment by personnel in Trusted Roles and under multi-person control b. CA has individuals assigned for Trusted Roles and they have received training to perform their responsibilities. c. CA keys remain in a physically secure environment until ready to be transported by CA personnel or common carrier d. CA keys are only transported on hardware devices and in tamper-evident packaging e. For hardware device containing entire CA key, two CA employees will be required to physical transport the key f. For CA key divided into fragments on multiple hardware devices, measures mentioned in control 3.3.1.64 are followed g. Activation materials are transported separately from the CA key in tamper evident packaging h. Packaging for CA keys and activation materials are reviewed for evidence of tampering upon receipt i. CA keys and activation materials are stored in a physically secure environment by personnel in Trusted Roles and under multi-person control upon receipt j. All CA key transportation activities are logged k. For a recent key transportation ceremony, verify name of the auditor who independently witnessed the process	Mandatory	WebTrust 4.10.11	Yes	3.2.1.71-463	
Key Changeover							

CONFIDENTIAL AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.2.1.72	Certifying Authority and Subscriber keys shall be changed periodically. Key change shall be processed as per Key Generation guidelines.	1. Conduct walkthrough of the key changeover process and check the following: a. The frequency of changing CA and subscriber keys b. Key change is processed as per Key Generation guidelines c. CA provides reasonable notice to subscriber's relying parties of any change to new key pair used by CA d. All keys have validity period less than 5 years e. Validity period of keys is defined as per requirements mentioned in control 3.3.1.75 f. Key is often changed to minimize risk from compromise	Mandatory	IT CA Rules SCHEDULE III 21.1, X.509 Policy 5.6, CA Browser	Yes	3.2.1.72-464	
3.2.1.73	The Certifying Authority shall provide reasonable notice to the Subscriber's relying parties of any change to a new key pair used by the Certifying Authority to sign Digital Signature Certificates.	1. Conduct walkthrough of the key changeover process and check the following: a. The frequency of changing CA and subscriber keys b. Key change is processed as per Key Generation guidelines c. CA provides reasonable notice to subscriber's relying parties of any change to new key pair used by CA d. All keys have validity period less than 5 years e. Validity period of keys is defined as per requirements mentioned in control 3.3.1.75 f. Key is often changed to minimize risk from compromise	Mandatory	IT CA Rules SCHEDULE III 21.1	Yes	3.2.1.73-465	
3.2.1.74	The Certifying Authority shall define its key change process that ensures reliability of the process by showing how the generation of key interlocks – such as signing a hash of the new key with the old key.	1. Conduct walkthrough of the key changeover process and check the following: a. The frequency of changing CA and subscriber keys b. Key change is processed as per Key Generation guidelines c. CA provides reasonable notice to subscriber's relying parties of any change to new key pair used by CA d. All keys have validity period less than 5 years e. Validity period of keys is defined as per requirements mentioned in control 3.3.1.75 f. Key is often changed to minimize risk from compromise	Mandatory	IT CA Rules SCHEDULE III 21.1	Yes	3.2.1.74-466	
3.2.1.75	All CA keys must have validity periods of no more than ten years.	1. Conduct walkthrough of the key changeover process and check the following: a. The frequency of changing CA and subscriber keys b. Key change is processed as per Key Generation guidelines c. CA provides reasonable notice to subscriber's relying parties of any change to new key pair used by CA	Mandatory	IT CA Rules SCHEDULE III 21.1	Yes	3.2.1.75-467	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		d. All keys have validity period less than 5 years e. Validity period of keys is defined as per requirements mentioned in control 3.3.1.75 f. Key is often changed to minimize risk from compromise					
3.2.1.76	To minimize risk from compromise of a CA's private signing key, that key may be changed often; from that time on, only the new key shall be used for certificate signing purposes. The older, but still valid, certificate will be available to verify old signatures until all of the certificates signed using the associated private key have also expired. If the old private key is used to sign CRLs, then the old key shall be retained and protected.	1. Conduct walkthrough of the key changeover process and check the following: a. The frequency of changing CA and subscriber keys b. Key change is processed as per Key Generation guidelines c. CA provides reasonable notice to subscriber's relying parties of any change to new key pair used by CA d. All keys have validity period less than 5 years e. Validity period of keys is defined as per requirements mentioned in control 3.3.1.75 f. Key is often changed to minimize risk from compromise	Mandatory	X.509 Policy	Yes	3.2.1.76-468	
Key Migration							
3.2.1.77	The CA follows a CA key migration script for key migration events that includes the following: • definition and assignment of participant roles and responsibilities; • management approval for conduct of the key migration event • specific cryptographic hardware, software and other materials including identifying information, e.g., serial numbers, that contain the CA key copies to be migrated and new hardware where the keys are being migrated to; • specific steps performed during the key migration ceremony, including; • Hardware preparation o Software tool installation and setup o Cryptographic hardware setup and initialization	1. Obtain a copy of the CA key migration script and check the following: a. Script covers roles assigned, management approval,serial numbers, procedures for secure storage of cryptographic hardware etc. b. Steps for performing key migration are stated clearly in the script c. physical security requirements for the ceremony location are met d. sign-off is given for the key migration ceremony e. notation of any deviations from the key generation ceremony script are addressed	Mandatory	WebTrust 4.11.4	Yes	3.2.1.77-472	

CCA - AUDIT REPORT

	o CA key migration o CA key verification • physical security requirements for the event location (e.g., barriers, access controls and logging controls); • procedures for secure storage of cryptographic hardware and any associated activation materials following the migration event • sign-off on the script or in a log from participants and witnesses indicating whether the key migration was performed in accordance with the detailed key migration script; and • notation of any deviations from the key migration script (e.g., documentation of steps taken to address any technical issues).						
3.2.1.78	CA key migration events occur in a physically secure environment by those in Trusted Roles under multi-person control	1. Validate CA migration is done in a physically secure environment 2. Check vendor-supplied hardware and software tools are tested by the CA prior the key migration event 3. Verify In house developed software tools are developed and tested by the CA prior to the key migration event	Mandatory	WebTrust 4.11.1	Yes	3.2.1.78-469	
3.2.1.79	Vendor-supplied hardware and software tools are tested by the CA prior the key migration event, and are operated in accordance with vendor-supplied documentation and instructions.	1. Validate CA migration is done in a physically secure environment 2. Check vendor-supplied hardware and software tools are tested by the CA prior the key migration event 3. Verify In house developed software tools are developed and tested by the CA prior to the key migration event	Mandatory	WebTrust 4.11.2	Yes	3.2.1.79-470	
3.2.1.80	In-house developed software tools are developed and tested by the CA prior to the key migration event in accordance with its standard software development process	1. Validate CA migration is done in a physically secure environment 2. Check vendor-supplied hardware and software tools are tested by the CA prior the key migration event 3. Verify In house developed software tools are developed and tested by the CA prior to the key migration event	Mandatory	WebTrust 4.11.3	Yes	3.2.1.80-471	
3.2.1.81	The CA follows a CA key migration script for	1. Obtain a copy of the CA key migration script and check the	Mandatory	WebTrust 4.11.4	Yes	3.2.1.81-473	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	key migration events that includes the following: • definition and assignment of participant roles and responsibilities; • management approval for conduct of the key migration event • specific cryptographic hardware, software and other materials including identifying information, e.g., serial numbers, that contain the CA key copies to be migrated and new hardware where the keys are being migrated to; • specific steps performed during the key migration ceremony, including; • Hardware preparation o Software tool installation and setup o Cryptographic hardware setup and initialization o CA key migration o CA key verification • physical security requirements for the event location (e.g., barriers, access controls and logging controls); • procedures for secure storage of cryptographic hardware and any associated activation materials following the migration event • sign-off on the script or in a log from participants and witnesses indicating whether the key migration was performed in accordance with the detailed key migration script; and • notation of any deviations from the key migration script (e.g., documentation of steps taken to address any technical issues).	following: a. Script covers roles assigned, management approval,serial numbers, procedures for secure storage of cryptographic hardware etc. b. Steps for performing key migration are stated clearly in the script c. physical security requirements for the ceremony location are met d. sign-off is given for the key migration ceremony e. notation of any deviations from the key generation ceremony script are addressed					
3.2.1.82	A log is maintained of all actions taken as part of the CA key migration event and is retained in accordance with the CA's disclosed business practices.	1. Validate logs are maintained for CA key migration event 2. For a recent key migration ceremony, verify name of the auditor who independently witnessed the process 3. Verify upon successful completion	Mandatory	WebTrust 4.11.5	Yes	3.2.1.82-474	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		of a CA key migration event, remaining copies of the CA keys, and older cryptographic hardware that no longer serve a business purpose shall be securely destroyed					
3.2.1.83	CA key migration events shall be witnessed by internal or external auditors	1. Validate logs are maintained for CA key migration event 2. For a recent key migration ceremony, verify name of the auditor who independently witnessed the process 3. Verify upon successful completion of a CA key migration event, remaining copies of the CA keys, and older cryptographic hardware that no longer serve a business purpose shall be securely destroyed	Mandatory	WebTrust 4.11.6	Yes	3.2.1.83-475	
3.2.1.84	Upon successful completion of a CA key migration event, remaining copies of the CA keys, and older cryptographic hardware that no longer serve a business purpose shall be securely destroyed in accordance with the CA's disclosed business practices	1. Validate logs are maintained for CA key migration event 2. For a recent key migration ceremony, verify name of the auditor who independently witnessed the process 3. Verify upon successful completion of a CA key migration event, remaining copies of the CA keys, and older cryptographic hardware that no longer serve a business purpose shall be securely destroyed	Mandatory	WebTrust 4.11.7	Yes	3.2.1.84-476	
Private Key Protection and Cryptographic Module Engineering Controls							
3.2.1.85	The Certifying Authority must protect its private keys from disclosure. The Certifying Authority must back-up its private keys. Backed-up keys must be stored in encrypted form and protected at a level no lower than those followed for storing the primary version of the key.	1. Conduct walkthrough of Private Key Protection and Cryptographic Module Engineering Controls and check the following: a. CA protects private keys from disclosure b. CA backs up its private keys and stores them in encrypted format c. private key backups are stored in a secure storage facility, away from where the original key is stored d. Backup measures are taken to ensure continued availability of private key e. Use of a CA private signing key requires action by at least two persons f. Signature keys are not escrowed by a third party	Mandatory	IT CA Rules SCHEDULE III 19	Yes	3.2.1.85-477	
3.2.1.86	The Certifying Authority's private key backups should be stored in a secure storage facility, away from where the original key is stored. Continued availability of the private key be ensured	1. Conduct walkthrough of Private Key Protection and Cryptographic Module Engineering Controls and check the following: a. CA protects private keys from disclosure b. CA backs up its private keys and stores them in encrypted format c. private key backups are stored in a	Mandatory	IT CA Rules SCHEDULE III 19, IT Regulations 3	Yes	3.2.1.86-478	

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	through approved backup measures in the event of loss or corruption of its private key.	secure storage facility, away from where the original key is stored d. Backup measures are taken to ensure continued availability of private key e. Use of a CA private signing key requires action by at least two persons f. Signature keys are not escrowed by a third party					
3.2.1.87	Use of a CA private signing key shall require action by at least two persons	1. Conduct walkthrough of Private Key Protection and Cryptographic Module Engineering Controls and check the following: a. CA protects private keys from disclosure b. CA backs up its private keys and stores them in encrypted format c. private key backups are stored in a secure storage facility, away from where the original key is stored d. Backup measures are taken to ensure continued availability of private key e. Use of a CA private signing key requires action by at least two persons f. Signature keys are not escrowed by a third party	Mandatory	X.509 Policy 6.2.2	Yes	3.2.1.87-479	
3.2.1.88	The cryptographic module may store Private Keys in any form as long as the keys are not accessible without authentication mechanism that is in compliance with FIPS 140-2 rating of the cryptographic module.	1. Conduct walkthrough of Private Key Protection and Cryptographic Module Engineering Controls and check the following: a. CA protects private keys from disclosure b. CA backs up its private keys and stores them in encrypted format c. private key backups are stored in a secure storage facility, away from where the original key is stored d. Backup measures are taken to ensure continued availability of private key e. Use of a CA private signing key requires action by at least two persons f. Signature keys are not escrowed by a third party	Recommended	X.509 Policy 6.2.7	Yes	3.2.1.88-480	

3.2.2. Subscriber Key Lifecycle Controls

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
CA-Provided Subscriber Key Generation Services							
3.2.2.1	The Certifying Authority's public verification key must be delivered to the prospective	1. Conduct walkthrough and check the following: a. CAs public verification key is delivered to the prospective Digital Signature Certificate holder in an on-	Optional				

COPY - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	Digital Signature Certificate holder in an on-line transaction in accordance with PKIX-3 Certificate Management Protocol, or via an equally secure manner. The Certifying Authority shall ensure that the subscriber can verify the Certifying Authority's Public Key Certificate, if he chooses to do so, by having access to the Public Key Certificate of the Controller	line transaction in accordance with PKIX-3 Certificate Management Protocol, or via an equally secure manner. b. Certifying Authority ensures that the subscriber can verify the Certifying Authority's Public Key Certificate, if he chooses to do so, by having access to the Public Key Certificate of the Controller					
3.2.2.2	Subscriber key generation is performed within a secure cryptographic device meeting the applicable ISO 15782-1/FIPS140-2/ANSI x9.66 requirements based on a risk assessment and the business requirements of the CA and in accordance with the applicable CP.	1. No action is required from the auditor to check the controls as Subscriber key generations services are not provided by CAs	Not Applicable	WebTrust 5.1.1, CA Browser Forum 6.1.1.3			
3.2.2.3	Subscriber key generation performed by the CA (or RA or card bureau) uses a key generation algorithm as specified in the CP.	1. No action is required from the auditor to check the controls as Subscriber key generations services are not provided by CAs	Not Applicable	WebTrust 5.1.2			
3.2.2.4	Subscriber key generation performed by the CA (or RA) uses a prime number generator as specified in an ANSI X9 or ISO standard	1. No action is required from the auditor to check the controls as Subscriber key generations services are not provided by CAs	Not Applicable	WebTrust 5.1.3			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.2.2.5	Subscriber key generation performed by the CA (or RA or card bureau) results in key sizes in accordance with the CP.	1. No action is required from the auditor to check the controls as Subscriber key generations services are not provided by CAs	Not Applicable	WebTrust 5.1.4			
3.2.2.6	Subscriber key generation performed by the CA (or RA) is performed by authorized personnel in accordance with the CA's CPS.	1. No action is required from the auditor to check the controls as Subscriber key generations services are not provided by CAs	Not Applicable	WebTrust 5.1.5			
3.2.2.7	When subscriber key generation is performed by the CA (or RA or card bureau), the CA (or RA or card bureau) securely (confidentially) delivers the subscriber key pair(s) generated by the CA (or RA or card bureau) to the subscriber in accordance with the CP.	1. No action is required from the auditor to check the controls as Subscriber key generations services are not provided by CAs	Not Applicable	WebTrust 5.1.6			
CA-Provided Subscriber Key Storage and Recovery Services							
3.2.2.8	Certifying Authority's keys shall be stored in tamper-resistant devices and can only be activated under split-control by parties who are not involved in the set-up and maintenance of the systems and operations of the Certifying Authority. The key of the Certifying Authority may be stored in a tamper-resistant cryptographic module or split into sub-keys stored in tamper-resistant devices under the custody of the key	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized	Mandatory	IT CA Rules SCHEDULE III 18.3			

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	custodians	personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.					
3.2.2.9	The Certifying Authority's key custodians shall ensure that the Certifying Authority's key component or the activation code is always under his sole custody. Change of key custodians shall be approved by the Certifying Authority's management and documented	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.	Mandatory	IT CA Rules SCHEDULE III 18.3documented			
3.2.2.10	Subscriber private keys stored by the CA (or RA) are stored in encrypted form using a cryptographic algorithm and key length based on a risk assessment and requirements of the CP.	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca	Mandatory	WebTrust 5.2.1			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.					
3.2.2.11	If the CA generates key pair(s) on behalf of a Subscriber, the CA (or RA) ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys.	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.	Mandatory	WebTrust 5.2.2			
3.2.2.12	If the CA (or RA) generates public/private signing key pair(s), it does not maintain a copy of any private signing key, once the subscriber confirms receipt of that key.	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form	Mandatory	WebTrust 5.2.3			

COA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.					
3.2.2.13	If the CA (or RA) provides subscriber (confidentiality) key storage, backup and recovery, subscriber private (confidentiality) key backup and recovery services are only performed by authorized personnel.	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.	Mandatory	WebTrust 5.2.4			
3.2.2.14	If the CA (or RA) provides subscriber key storage, backup and recovery, controls exist to ensure that the integrity of the	1. Conduct walkthrough of the CA-Provided Subscriber Key Storage and Recovery Services and check the following: a. CAs key is stored in tamper resistant device b. CAs key custodians ensure that the CA's key component or the activation	Mandatory	WebTrust 5.2.5			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	subscriber's private (confidentiality) key is maintained throughout its life cycle.	code is always under his sole custody c. Change of key custodian is approved by CAs management and documented d. Subscriber private keys stored by the CA are stored in encrypted form using a cryptographic algorithm and key length e. CA ensures that the subscriber's private keys are not disclosed to any entity other than the owner (i.e., the subscriber) of the keys if Ca generates key pair(s) on behalf of subscriber f. CA does not maintain a copy of any private signing key g. key backup and recovery services are only performed by authorized personnel if the CA provides subscriber (confidentiality) key storage, backup and recovery, subscriber private h. Backup and recovery, controls exist for encryptions to ensure that the integrity of the subscriber's private (confidentiality) key is maintained throughout its life cycle.					
Requirements for Subscriber Key Management							
3.2.2.15	The CP specifies the appropriate ISO 15782-1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for	Mandatory	WebTrust 5.4.1			

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.2.2.16	The CP specifies the key generation algorithm(s) that is used for subscriber key generation.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for	Mandatory	WebTrust 5.4.2			

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.2.2.17	The CP specifies the acceptable key sizes for subscriber key generation.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.	Mandatory	WebTrust 5.4.3			
3.2.2.18	The CA or RA provides or makes	1. Conduct walkthrough of the CA-Provided Subscriber Key	Not Applicable	WebTrust 5.4.4			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	available the mechanisms to allow the Subscriber to access (i.e., private key owner verification method), manage and control the usage of their private keys.	Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.2.2.19	The CP specifies the private key protection requirements for stored subscriber private keys.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key	Mandatory	WebTrust 5.4.5			

COPY - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.2.2.20	The CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys	Mandatory	WebTrust 5.4.6			

COPY AUDIT REPORT

		stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.2.2.21	The CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber	Mandatory	WebTrust 5.4.7			

COPY AUDIT REPORT

		private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.2.2.22	Subscriber Agreements describe the required processes to be followed by the Subscriber of any use of the cryptographic mechanism (e.g., HSM or ICC and software application).	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of	Mandatory	Subscriber Agreements describe the required processes to be			

COMPLIANCE AUDIT REPORT

		the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.2.2.23	The CP specifies the acceptable uses for subscriber key pairs.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.	Mandatory	WebTrust 5.4.9			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.2.2.24	The CP specifies the requirements for subscriber key usage.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.	Mandatory	WebTrust 5.4.10			
3.2.2.25	The CP specifies the private key protection requirements for archived subscriber private keys.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber	Mandatory	WebTrust 5.4.11			

COPY AUDIT REPORT

		key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.2.2.26	The CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key	Mandatory	WebTrust 5.4.12			

COPY AUDIT REPORT

		protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.2.2.27	The CP specifies the means through which subscriber key destruction is performed.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key	Mandatory	WebTrust 5.4.13			

COPY AUDIT REPORT

		protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.2.2.28	The CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all	Mandatory	WebTrust 5.4.14			

COPY AUDIT REPORT

		copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.					
3.2.2.29	CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes (and subsequent actions) where the cryptographic hardware is in other physical locations (i.e., an HSM attached to a mainframe or remote server).	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.	Mandatory	WebTrust 5.4.15			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.2.2.30	The CP specifies the requirements for notification of the CA or RA in the event of subscriber key compromise.	1. Conduct walkthrough of the CA-Provided Subscriber Key Management process and check the following: a. CP specifies the appropriate ISO 15782- 1/FIPS 140-2 level requirement for cryptographic modules used for subscriber key generation b. CP specifies the key generation algorithm(s) that is used for subscriber key generation c. CP specifies the acceptable key sizes for subscriber key generation d. CP specifies the private key protection requirements for stored subscriber private keys e. CP states the circumstances and authority of when the subscriber's private key will be restored and the control processes f. CP specifies the private key protection requirements for backup copies of subscriber private keys stored by the subscriber. g. Subscriber Agreements describe the required processes to be followed by the Subscriber h. CP specifies acceptable uses for subscriber key pairs i. CP specifies the requirements for subscriber key usage. j. CP specifies the private key protection requirements for archived subscriber private keys k. CP specifies the requirements for destruction of archived subscriber keys at the end of the archive period l. CP specifies the means through which subscriber key destruction is performed m. CP or CPS specifies the requirements for destruction of all copies and fragments of the subscriber's private key at the end of the key pair life cycle n. CP specifies the requirements for use and handling of cryptographic hardware and subscriber authentication processes o. CP specifies the requirements for notification of the CA in the event of subscriber key compromise.	Mandatory	WebTrust 5.4.16			
Certificate Operational Periods and Key Pair Usage Periods							
3.2.2.31	Subscriber SSL Certificates issued after 1 March 2018 must have a Validity Period no greater than 825 days. Subscriber Certificates issued after 1 July 2016	1. For sample SSL certificates issued after 1 March 2018, verify the validity period is not greater than 825 days 2. For sample certificates issued after 1 July 2016 but prior to 1 March 2018, verify the validity period is not greater than 39 months	Applicable for SSL Certificate	CA Browser Forum 6.3.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	but prior to 1 March 2018 must have a Validity Period no greater than 39 months.						
Confidentiality of Subscriber's Information							
3.2.2.32	Procedures and security controls to protect the privacy and confidentiality of the subscribers' data under the Certifying Authority's custody shall be implemented. Confidential nformation provided by the subscriber must not be disclosed to a third party without the subscribers' consent, unless the information is required to be disclosed under the law or a court order.	1. Verify CA has implemented procedures and security controls to protect privacy and confidentiality of subscribers' data 2. Validate confidential information provided by the subscriber is not disclosed to a third party without the subscribers' consent, unless the information is required to be disclosed under the law or a court order 3. Check the data on usage of DSC and transactional data is protected to ensure the subscribers' privacy 4. Verify a secure communication channel between the CA and its subscribers is established to ensure the authenticity, integrity and confidentiality of the exchange	Mandatory	IT CA Rules SCHEDULE III 22			
3.2.2.33	Data on the usage of the Digital Signature Certificates by the subscribers and other transactional data relating to the subscribers' activities generated by the Certifying Authority in the course of its operation shall be protected to ensure the subscribers' privacy	1. Verify CA has implemented procedures and security controls to protect privacy and confidentiality of subscribers' data 2. Validate confidential information provided by the subscriber is not disclosed to a third party without the subscribers' consent, unless the information is required to be disclosed under the law or a court order 3. Check the data on usage of DSC and transactional data is protected to ensure the subscribers' privacy 4. Verify a secure communication channel between the CA and its subscribers is established to ensure the authenticity, integrity and confidentiality of the exchange	Mandatory	IT CA Rules SCHEDULE III 22			
3.2.2.34	A secure communication channel between the Certifying Authority and its subscribers shall be established to ensure the authenticity, integrity and	1. Verify CA has implemented procedures and security controls to protect privacy and confidentiality of subscribers' data 2. Validate confidential information provided by the subscriber is not disclosed to a third party without the subscribers' consent, unless the information is required to be disclosed under the law or a court order 3. Check the data on usage of DSC and	Mandatory	IT CA Rules SCHEDULE III 22			

CCA IT AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	confidentiality of the exchanges (e.g. transmission of Digital Signature Certificate, password, private key) during the Digital Signature Certificate issuance process.	transactional data is protected to ensure the subscribers' privacy 4. Verify a secure communication channel between the CA and its subscribers is established to ensure the authenticity, integrity and confidentiality of the exchange					

3.3. Certificate Management Controls

3.3.1. Certificate Lifecycle Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Subscriber Registration							
3.3.1.1	For authenticated certificates, the CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP.	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP for authenticated certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates c. CA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP	Mandatory	WebTrust 6.1.1			
3.3.1.2	For domain and/or IP address validated certificates, the CA validates or requires that the RA validate (as determined by the CP) the organization's	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP for authenticated	Mandatory	WebTrust 6.1.2			

COPY AUDIT REPORT

	ownership, control, or right to use the domain name and/or IP address	certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates c. CA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP					
3.3.1.3	The CA or RA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP.	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP for authenticated certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates c. CA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP	Mandatory	WebTrust 6.1.3			
3.3.1.4	The CA or RA checks the Certificate Request for errors or omissions in accordance with the CP.	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority	Mandatory	WebTrust 6.1.4			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		to perform a specific role in accordance with the requirements of the CP for authenticated certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates c. CA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP					
3.3.1.5	For end entity certificates, the CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission.	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP for authenticated certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates c. CA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP	Mandatory	WebTrust 6.1.5			
3.3.1.6	The CA verifies the uniqueness of the subscriber's distinguished name within the	1. Conduct a walkthrough of the Subscriber registration process and check the following for a sample of subscriber registrations: a. CA verifies or requires that the RA verify the credentials	Mandatory	WebTrust 6.1.6			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	boundaries or community defined by the CP.	presented by a subscriber as evidence of identity or authority to perform a specific role in accordance with the requirements of the CP for authenticated certificates b. the CA validates or requires that the RA validate (as determined by the CP) the organization's ownership, control, or right to use the domain name and/or IP address for domain and/or IP address validated certificates c. CA verifies the accuracy of the information included in the requesting entity's certificate request in accordance with the CP d. CA checks the Certificate Request for errors or omissions in accordance with the CP e. CA uses the RA's public key contained in the requesting entity's Certificate Request to verify signature on the Certificate Request submission for end entity certificates f. CA verifies the uniqueness of the subscriber's distinguished name within the boundaries or community defined by the CP					
3.3.1.7	Encryption and access controls are used to protect the confidentiality and integrity of registration data in transit and in storage.	1. Verify encryption and access controls are used to protect the confidentiality and integrity of registration data in transit and in storage.	Mandatory	WebTrust 6.1.7			
3.3.1.8	At the point of registration (before certificate issuance) the RA or CA informs the Subscriber of the terms and conditions regarding use of the certificate.	1. Conduct walkthrough and check the following: a. Before certificate issuance the CA informs the Subscriber of the terms and conditions regarduse of the certificate. b. The entity requesting a certificate prepares and submits the appropriate certificate request data (Registration Request) to an RA (or the CA) as specified in the CP.	Mandatory	WebTrust 6.1.8			
3.3.1.9	The CA requires that an entity requesting a certificate must prepare and submit the appropriate certificate request data (Registration Request) to an RA (or the CA) as specified in the CP.	1. Conduct walkthrough and check the following: a. Before certificate issuance the CA informs the Subscriber of the terms and conditions regarduse of the certificate. b. The entity requesting a certificate prepares and submits the appropriate certificate request data (Registration Request) to an RA (or the CA) as specified in the CP.	Mandatory	WebTrust 6.1.10			
3.3.1.10	The CA requires that the requesting	1. Verify requesting entity submits its public key in a self-signed message to the CA for	Mandatory	WebTrust 6.1.11			

CCA - IT AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	entity submit its public key in a self-signed message to the CA for certification. The CA requires that the requesting entity digitally sign the Registration Request using the private key that relates to the public key contained in the Registration Request in order to: • allow the detection of errors in the certificate application process; and • Prove possession of the companion private key for the public key being registered.	certification 2. Validate the requesting entity digitally signs the Registration Request using the private key that relates to the public key contained in the Registration Request 3. Validate certificate request is treated as acceptance of the terms of conditions by the requesting entity 4. Check the identity of RA authorized to issue registration requests is validated by the CA					
3.3.1.11	The certificate request is treated as acceptance of the terms of conditions by the requesting entity to use that certificate as described in the Subscriber Agreement	1. Verify requesting entity submits its public key in a self-signed message to the CA for certification 2. Validate the requesting entity digitally signs the Registration Request using the private key that relates to the public key contained in the Registration Request 3. Validate certificate request is treated as acceptance of the terms of conditions by the requesting entity 4. Check the identity of RA authorized to issue registration requests is validated by the CA	Mandatory	WebTrust 6.1.12			
3.3.1.12	The CA validates the identity of the RA authorized to issue registration requests under a specific CP.	1. Verify requesting entity submits its public key in a self-signed message to the CA for certification 2. Validate the requesting entity digitally signs the Registration Request using the private key that relates to the public key contained in the Registration Request 3. Validate certificate request is treated as acceptance of the terms of conditions by the requesting entity 4. Check the identity of RA authorized to issue registration requests is validated by the CA	Mandatory	WebTrust 6.1.13			
3.3.1.13	The CA requires that RAs submit the requesting entity's certificate request data to the CA in a message (Certificate Request) signed by the RA. The CA verifies the RA's	1. Verify the RAs submit the requesting entity's certificate request data to the CA in a message (Certificate Request) signed by the RA	Mandatory	WebTrust 6.1.14			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	signature on the Certificate Request.						
3.3.1.14	The CA requires that the RA secure that part of the certificate application process for which it (the RA) assumes responsibility in accordance with the CA's CPS.	1. Verify that the RA secures that part of the certificate application process for which it assumes responsibility in accordance with the CA's CPS	Mandatory	WebTrust 6.1.15			
3.3.1.15	The CA requires that RAs record their actions in an audit log.	1. Verify all RA activities are recorded in an audit log	Mandatory	WebTrust 6.1.16			
3.3.1.16	The CA verifies the authenticity of the submission by the RA in accordance with the CA's CPS.	1. Check that the authenticity of the submission by the RA is verified by the CA	Mandatory	WebTrust 6.1.17			
Certificate Issuance							
3.3.1.17	The CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile in accordance with ISO 9594/X.509 and ISO 15782-1 formatting rules as disclosed within the CP.CA shall verify the source of a certificate request before issuance.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the	Mandatory	WebTrust 6.4.1,CA Browser Forum 4.3, X.509 Policy 4.3			

COPY - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		appropriate period of time specified in the CP					
3.3.1.18	Validity periods are set in the CP and are formatted in accordance with ISO 9594/X.509 and ISO 15782-1 as disclosed within the CP.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP	Mandatory	WebTrust 6.4.2			
3.3.1.19	Extension fields are formatted in accordance with ISO 9594/X.509 and ISO 15782-1 as disclosed within the CP.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation	Mandatory	WebTrust 6.4.3			

COA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP					
3.3.1.20	The CA signs the end entity's public key and other relevant information with the CA's private signing key.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP	Mandatory	WebTrust 6.4.4			
3.3.1.21	The CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the	Mandatory	WebTrust 6.4.5, CA Browser Forum 4.3			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP					
3.3.1.22	When an RA is used, the CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request. Certificate issuance by the Root CA SHALL require an individual authorized by the CA (i.e. the CA system operator, system officer, or PKI administrator) to deliberately issue a direct command in order for the Root CA to perform a certificate signing operation.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP	Mandatory	WebTrust 6.4.6			
3.3.1.23	Certificates are issued based on approved subscriber registration, certificate renewal	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile	Mandatory	WebTrust 6.4.7			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	or certificate rekey requests in accordance with the CP.	b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP					
3.3.1.24	The CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued	Mandatory	WebTrust 6.4.8, X.509 Policy 4.3			

COA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		l. copies of certificates are retained for the appropriate period of time specified in the CP					
3.3.1.25	The CA issues an out-of-band notification to the Subscriber when a certificate is issued. Where this notification includes initial activation data, then control processes ensure safe delivery to the Subscriber.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP	Mandatory	WebTrust 6.4.9			
3.3.1.26	Whether certificates expire, are revoked or are suspended, copies of certificates are retained for the appropriate period of time specified in the CP.	1. Conduct walkthrough of the Certificate Issuance process to check the following: a. CA generates certificates using Certificate Request Data and manufactures the certificate as defined by the appropriate Certificate Profile b. CA verifies source of certificate request before issuance c. Validity periods are set by CA in compliance with the CP d. Extension fields are formatted in accordance with with the CP e. CA signs the end entity's public key and other relevant information with the CA's private signing key f. CA publishes the certificate after the certificate has been accepted by the requesting entity as disclosed in the CA's business practices g. CA notifies the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request h. Authorized individual issues direct command for Root CA to perform a	Mandatory	WebTrust 6.4.10			

COA - AUDIT REPORT

		certificate signing operation i. Certificates are issued based on approved subscriber registration, certificate renewal or certificate rekey requests in accordance with the CP j. CA issues a signed notification to the RA when a certificate is issued to a subscriber for whom the RA submitted a certificate request k. CA issues an out-of-band notification to the Subscriber when a certificate is issued l. copies of certificates are retained for the appropriate period of time specified in the CP					
Certificate Distribution							
3.3.1.27	Only authorized CA personnel administer the CA's repository or alternative distribution mechanism.	1. Conduct walkthrough of certificate distribution process to check the following: a. Only authorized CA personnel administer the CA's repository or alternative distribution mechanism b. performance of the CA's repository or alternative distribution mechanism is monitored and managed c. integrity of the repository or alternative distribution mechanism is maintained and administered	Mandatory	WebTrust 6.5.2			
3.3.1.28	The performance of the CA's repository or alternative distribution mechanism is monitored and managed.	1. Conduct walkthrough of certificate distribution process to check the following: a. Only authorized CA personnel administer the CA's repository or alternative distribution mechanism b. performance of the CA's repository or alternative distribution mechanism is monitored and managed c. integrity of the repository or alternative distribution mechanism is maintained and administered	Mandatory	WebTrust 6.5.3			
3.3.1.29	The integrity of the repository or alternative distribution mechanism is maintained and administered.	1. Conduct walkthrough of certificate distribution process to check the following: a. Only authorized CA personnel administer the CA's repository or alternative distribution mechanism b. performance of the CA's repository or alternative distribution mechanism is monitored and managed c. integrity of the repository or alternative distribution mechanism is maintained and administered	Mandatory	WebTrust 6.5.4			
Certificate Acceptance							
3.3.1.30	Procedures shall be developed for certificate acceptance and publication of the certificate by the CA.The subject must confirm acceptance of the certificate upon	1. Verify procedures have been developed for certificate acceptance and publication and subject confirms acceptance of certificate 2. Verify CA notifies of certificate issuance to other entities	Mandatory	X.509 Policy 4.4, CA Browser Forum 4.4			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	notification of issuance bythe CA.						
3.3.1.31	Notification of certificate issuance by the CA to other entities	1. Verify procedures have been developed for certificate acceptance and publication and subject confirms acceptance of certificate 2. Verify CA notifies of certificate issuance to other entities	Mandatory	X.509 Policy 4.4, CA Browser Forum 4.4			
Key Pair and Certificate Usage							
3.3.1.32	Subscribers and CAs shall protect their private keys from access by any other party. Subscribers and CAs shall use their private keys for the purposes as constrained by the extensions (such as key usage, extended key usage, certificate policies, etc.) in the certificates issued to them	1. Check that the CAs protect their private keys from access by any other party. 2. Verify CAs use their private keys for the purposes as constrained by the extensions in the certificates issued to them	Mandatory	X.509 Policy 4.5.1, CA Browser Forum 4.5			
Certificate Renewal							
3.3.1.33	A certificate may be renewed if the public key has not reached the end of its validity period, the associated private key has not been revoked or compromised, and the Subscriber name and attributes are unchanged.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	X.509 Policy 4.6			
3.3.1.34	In addition, the validity period of the certificate must not exceed the remaining lifetime of the private key	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	X.509 Policy 4.6			
3.3.1.35	The Certificate Renewal Request includes at least the subscriber's Distinguished Name, the Serial Number of the certificate (or other information th0 at identifies the	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.1			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	certificate), and the requested validity period. (The CA will only renew certificates that were issued by itself.)						
3.3.1.36	The CA requires that the requesting entity digitally sign the Certificate Renewal Request using the private key that relates to the public key contained in the requesting entity's existing public key certificate	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.2			
3.3.1.37	The CA issues a new certificate using the subscriber's previously certified public key, only if its cryptographic security is still sufficient for the new certificate's intended lifetime and no indications exist that the subscriber's private key has been compromised	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.3			
3.3.1.38	For renewal of authenticated certificates, the CA or the RA process the certificate renewal data to verify the identity of the requesting entity and to identify the certificate to be renewed.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.4			
3.3.1.39	For domain validated certificates, the CA or the RA process the certificate renewal data to re-validate the domain in accordance with the requirements of the CP.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.5			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.3.1.40	The CA or the RA validate the signature on the Certificate Renewal Request	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.6			
3.3.1.41	The CA verifies the existence and validity of the certificate The CA verifies the existence and validity of the certificate to be renewed. The CA does not renew certificates that have been revoked, expired or suspended to be renewed. The CA does not renew certificates that have been revoked, expired or suspended	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.7			
3.3.1.42	The CA or the RA verifies that the request, including the extension of the validity period, meets the requirements defined in the CP.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.8			
3.3.1.43	The CA requires that RAs submit the Certificate Renewal Data to the CA in a message (Certificate Renewal Request) signed by the RA.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.9			
3.3.1.44	The CA requires that the RA secures that part of the certificate renewal process for which it (the RA) assumes responsibility in accordance with the CP.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.10			
3.3.1.45	The CA requires that RAs record their actions in an audit log.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.11			

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.3.1.46	The CA verifies the authenticity of the submission by the RA.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.12			
3.3.1.47	The CA verifies the RA's signature on the Certificate Renewal Request	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.13			
3.3.1.48	The CA checks the Certificate Renewal Request for errors or omissions. This function may be delegated explicitly to the RA	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.14			
3.3.1.49	The CA or RA notifies Subscribers prior to the expiration of their certificate of the need for renewal in accordance with the CP	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.15			
3.3.1.50	The CA issues a signed notification indicating the certificate renewal has been successful.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.16			
3.3.1.51	The CA makes the new certificate available to the end entity in accordance with the CP.	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	WebTrust 6.2.17			
3.3.1.52	A certificate renewal shall be achieved using one of the following processes: • Initial registration process • Identification & Authentication for Re-key, except the old key can also be used as the new key	1. Certificate renewal is not performed as part of current CA systems Hence all the controls are not applicable and no action is required from the auditor's side.	Not Applicable	X.509 Policy 4.6.3			
Certificate Re-Key							

CCA - AUDIT REPORT

3.3.1.53	A certificate re-key shall be achieved using one of the following processes: • Initial registration process • Identification & Authentication for Re-key	1. Verify Certificate re-key is achieved using one of the following processes: a. Initial registration process	Mandatory	X.509 Policy 4.7.3, CA Browser Forum 4.7, X.509 Policy 4.7			
Certificate Validation							
3.3.1.54	The CA makes certificate status information available to relevant entities (Relying Parties or their agents) using an established mechanism in accordance with the CP. This is achieved using: • Request Response Method – A request signed by the Relying Party to the Certificate Status Provider's responder. In turn, the Certificate Status Provider's responder responds with the certificate status duly signed. (OCSP is an example protocol using this method.) • Delivery Method – A CRL signed by the CA and published within the policy's time frame.	1. Check that the certificate status information is made available to relevant entities by the CA using an established mechanism in accordance with the CP 2. Verify Request Response Method and Delivery Method are used for Validation	Mandatory	WebTrust 6.8.1			
Certificate Revocation List (CRL) Controls							
3.3.1.55	The CA digitally signs each CRL that it issues so that entities can validate the integrity of the CRL and the date and time of issuance.	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA	Mandatory	WebTrust 6.8.2			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.					
3.3.1.56	The CA issues CRLs at regular intervals, as specified in the CP, even if no changes have occurred since the last issuance.	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.	Mandatory	WebTrust 6.8.3			
3.3.1.57	At a minimum, a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period.	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.	Mandatory	WebTrust 6.8.4			
3.3.1.58	If certificate suspension is supported, a certificate suspension (hold) entry, with its original action date and expiration date remain on the CRL until the normal expiration of the certificate or until the suspension is lifted	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.	Mandatory	WebTrust 6.8.5			

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.3.1.59	CRLs are archived in accordance with the requirements of the CP including the method of retrieval.	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.	Mandatory	WebTrust 6.8.6			
3.3.1.60	CAs include a monotonically increasing sequence number for each CRL issued by that CA	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.	Mandatory	WebTrust 6.8.7			
3.3.1.61	The CRL contains entries for all revoked unexpired certificates issued by the CA.	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made 3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.	Mandatory	WebTrust 6.8.8			
3.3.1.62	Old CRLs are retained for the appropriate period of time specified in	1. Verify that the CRL issued by the CA is digitally signed by the CA 2. Validate that the CRLs are issued at fixed intervals even if no changes have been made	Mandatory	WebTrust 6.8.9			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	the CA's CP.	3. Validate on sample basis a CRL entry identifying a revoked certificate remains on the CRL until the end of the certificate's validity period. 4. CRLs are archived in accordance with the requirements of the CP including the method of retrieval 5. CAs include a monotonically increasing sequence number for each CRL issued by that CA 6. CRL contains entries for all revoked unexpired certificates issued by the CA 7. Old CRLs are retained for the appropriate period of time specified in the CA's CP.					
Certificate Revocation and Suspension							
3.3.1.63	A certificate shall be revoked when the binding between the subject and the subject's public key defined within a certificate is no longer considered valid. The CA SHALL provide a process for Subscribers to request revocation of their own Certificates. The process MUST be described in the CA's Certificate Policy or Certification Practice Statement. The CA SHALL maintain a continuous 24x7 ability to accept and respond to revocation requests and related inquiries	1. For sample cases, validate certificate is revoked when the binding between the subject and the subject's public key defined within a certificate is no longer considered valid 2. Verify the CA provides a process for Subscribers to request revocation of their own Certificates and the process is described in the CA's Certificate Policy or CCA-CAAC Ver 1.6 122 Certification Practice Statement. 3. Check the CA maintains a continuous 24x7 ability to accept and respond to revocation requests and related inquiries	Mandatory	X.509 Policy 4.9.1, CA Browser Forum 4.9			
3.3.1.64	The CA provides a means of rapid communication to facilitate the secure and authenticated revocation or renovation of the following: • one or more certificates of one or more subscribers; • the set of all certificates issued by a CA based on a single public/private key pair used by a CA	1. Check that the CA provides a means of rapid communication to facilitate the secure and authenticated revocation or renovation of the elements mentioned in the control 2. Verify the CA provides Subscribers, Relying Parties, Application Software Suppliers, and other third parties with clear instructions for reporting suspected Private Key Compromise, Certificate misuse, or other types of fraud, compromise, misuse, inappropriate conduct, or any other matter related to Certificates. 3. Validate the CA has publicly disclosed the instructions through a readily accessible online means	Mandatory	WebTrust 6.6.1, X.509 Policy 4.9.3, CA Browser Forum 4.9.3			

COPY NOT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	to generate certificates; and • all certificates issued by a CA, regardless of the public/private key pair used. The CA SHALL provide Subscribers, Relying Parties, Application Software Suppliers, and other third parties with clear instructions for reporting suspected Private Key Compromise, Certificate misuse, or other types of fraud, compromise, misuse, inappropriate conduct, or any other matter related to Certificates. The CA SHALL publicly disclose the instructions through a readily accessible online means.						
3.3.1.65	The CA provides a means of rapid communication to facilitate the secure and authenticated revocation or renovation of the following: • one or more certificates of one or more subscribers; • the set of all certificates issued by a CA based on a single public/private key pair used by a CA to generate certificates; and • all certificates issued by a CA, regardless of the public/private key pair used.The CA SHALL provide Subscribers, Relying Parties,	1. Validate that CA verifies the identity and authority of the entity requesting revocation or suspension and reactivation of a certificate in accordance with the CP 2. Verify the Subscriber or Issuing CA can initiate revocation.	Mandatory	WebTrust 6.6.1, X.509 Policy 4.9.3, CA Browser Forum 4.9.3			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	Application Software Suppliers, and other third parties with clear instructions for reporting suspected Private Key Compromise, Certificate misuse, or other types of fraud, compromise, misuse, inappropriate conduct, or any other matter related to Certificates. The CA SHALL publicly disclose the instructions through a readily accessible online means.						
3.3.1.66	The CA verifies or requires that the RA verify the identity and authority of the entity requesting revocation or suspension and reactivation of a certificate in accordance with the CP. The Subscriber, RA, or Issuing CA can initiate revocation. Additionally, Subscribers, Relying Parties, Application Software Suppliers, and other third parties may submit Certificate Problem Reports informing the issuing CA of reasonable cause to revoke the certificate	1. Validate that CA verifies the identity and authority of the entity requesting revocation or suspension and reactivation of a certificate in accordance with the CP 2. Verify the Subscriber or Issuing CA can initiate revocation.	Mandatory	WebTrust 6.6.2, X.509 Policy 4.9.2, CA Browser Forum 4.9.2			
3.3.1.67	If an external RA accepts and forwards revocation requests to the CA, the CA provides a signed acknowledgement of the revocation request and confirmation of actions to the requesting RA.	1. Verify for past instances where the CA provides a signed acknowledgement of the revocation request and confirmation of action	Mandatory	WebTrust 6.6.4			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.3.1.68	The CA updates the Certificate Revocation List (CRL) and other certificate status mechanisms in the timeframes specified within the CP and in accordance with the format defined in ISO 9594/X.509 and ISO 15782-1.	1. Verify that the CA maintains and updates the Certificate Revocation List (CRL)	Mandatory	WebTrust 6.6.5			
3.3.1.69	The Certifying Authority shall publish a notice of suspension or revocation of any certificate in the Certificate Revocation List in its repository immediately after receiving an authorised request of such suspension or revocation. The CA records all certificate revocation requests and their outcome in an audit log.	1. Verify CA publishes a notice of suspension or revocation of any certificate in the Certificate Revocation List in its repository immediately after receiving an authorised request of such suspension or revocation. 2. Check all certification revocation requests and their outcome are logged	Mandatory	IT Regulation 3, WebTrust 6.6.6			
3.3.1.70	Once a certificate suspension (hold) has been issued, the suspension is handled in one of the following three ways: • an entry for the suspended certificate remains on the CRL with no further action; • the CRL entry for the suspended certificate is replaced by a revocation entry for the same certificate; or • the suspended certificate is explicitly released and the entry removed from the CRL.	1. Check the following on a sample basis: a. Subscriber of a revoked or suspended certificate is informed of the change of status of its certificate. b. Certificate suspension requests are processed and validated in accordance with the requirements of the CP c. CA notifies the Subscriber in the event of a certificate suspension d. CA updates the Certificate Revocation List (CRL) and other certificate status mechanisms upon certificate suspension e. Suspension is handled in one of the three ways mentioned in the control description (3.4.1.56) f. certificate suspension (hold) entry remains on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first g. CA verifies or requires that the external RA verify the identity and authority of the entity requesting that the suspension of a certificate be lifted h. Certificate suspensions and the lifting of	Mandatory	WebTrust 6.7.8			

CCTL AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		certificate suspensions are recorded in an audit log					
3.3.1.71	A certificate suspension (hold) entry remains on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first.	1. Check the following on a sample basis: a. Subscriber of a revoked or suspended certificate is informed of the change of status of its certificate. b. Certificate suspension requests are processed and validated in accordance with the requirements of the CP c. CA notifies the Subscriber in the event of a certificate suspension d. CA updates the Certificate Revocation List (CRL) and other certificate status mechanisms upon certificate suspension e. Suspension is handled in one of the three ways mentioned in the control description (3.4.1.56) f. certificate suspension (hold) entry remains on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first g. CA verifies or requires that the external RA verify the identity and authority of the entity requesting that the suspension of a certificate be lifted h. Certificate suspensions and the lifting of certificate suspensions are recorded in an audit log	Mandatory	WebTrust 6.7.9			
3.3.1.72	The CA verifies or requires that the external RA verify the identity and authority of the entity requesting that the suspension of a certificate be lifted.	1. Check the following on a sample basis: a. Subscriber of a revoked or suspended certificate is informed of the change of status of its certificate. b. Certificate suspension requests are processed and validated in accordance with the requirements of the CP c. CA notifies the Subscriber in the event of a certificate suspension d. CA updates the Certificate Revocation List (CRL) and other certificate status mechanisms upon certificate suspension e. Suspension is handled in one of the three ways mentioned in the control description (3.4.1.56) f. certificate suspension (hold) entry remains on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first g. CA verifies or requires that the external RA verify the identity and authority of the entity requesting that the suspension of a certificate be lifted	Mandatory	WebTrust 6.7.11			

COR - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		h. Certificate suspensions and the lifting of certificate suspensions are recorded in an audit log					
3.3.1.73	Certificate suspensions and the lifting of certificate suspensions are recorded in an audit log.	1. Check the following on a sample basis: a. Subscriber of a revoked or suspended certificate is informed of the change of status of its certificate. b. Certificate suspension requests are processed and validated in accordance with the requirements of the CP c. CA notifies the Subscriber in the event of a certificate suspension d. CA updates the Certificate Revocation List (CRL) and other certificate status mechanisms upon certificate suspension e. Suspension is handled in one of the three ways mentioned in the control description (3.4.1.56) f. certificate suspension (hold) entry remains on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first g. CA verifies or requires that the external RA verify the identity and authority of the entity requesting that the suspension of a certificate be lifted h. Certificate suspensions and the lifting of certificate suspensions are recorded in an audit log	Mandatory	WebTrust 6.7.12			
Certificate Status Services							
3.3.1.74	Revocation entries on a CRL or OCSP Response must NOT be removed until after the Expiry Date of the revoked Certificate	1. Check the certificate status services for the following: a. Revocation entries on a CRL or OCSP Response are not removed until after the Expiry Date of the revoked Certificate b. CA operates and maintains its CRL and OCSP capability with resources sufficient to provide a response time of ten seconds or less under normal operating.conditions. c. CA maintains an online 24x7 Repository that application software can use to automatically check the current status of all unexpired Certificates d. CA maintains a continuous 24x7 ability to respond internally to a high-priority Certificate Problem Report	Mandatory	CA Browser Forum 4.10.1			
3.3.1.75	The CA shall operate and maintain its CRL and OCSP capability with resources sufficient to provide a	1. Check the certificate status services for the following: a. Revocation entries on a CRL or OCSP Response are not removed until after the Expiry Date of the revoked Certificate b. CA operates and maintains its CRL and OCSP capability with	Mandatory	CA Browser Forum 4.10.2			

COPY - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	response time of ten seconds or less under normal operating conditions.	resources sufficient to provide a response time of ten seconds or less under normal operating.conditions. c. CA maintains an online 24x7 Repository that application software can use to automatically check the current status of all unexpired Certificates d. CA maintains a continuous 24x7 ability to respond internally to a high-priority Certificate Problem Report					
3.3.1.76	The CA shall maintain an online 24x7 Repository that application software can use to automatically check the current status of all unexpired Certificates issued by the CA.	1. Check the certificate status services for the following: a. Revocation entries on a CRL or OCSP Response are not removed until after the Expiry Date of the revoked Certificate b. CA operates and maintains its CRL and OCSP capability with resources sufficient to provide a response time of ten seconds or less under normal operating.conditions. c. CA maintains an online 24x7 Repository that application software can use to automatically check the current status of all unexpired Certificates d. CA maintains a continuous 24x7 ability to respond internally to a high-priority Certificate Problem Report	Mandatory	CA Browser Forum 4.10.2			
3.3.1.77	The CA shall maintain a continuous 24x7 ability to respond internally to a high-priority Certificate Problem Report, and where appropriate, forward such a complaint to law enforcement authorities, and/or revoke a Certificate that is the subject of such a complaint	1. Check the certificate status services for the following: a. Revocation entries on a CRL or OCSP Response are not removed until after the Expiry Date of the revoked Certificate b. CA operates and maintains its CRL and OCSP capability with resources sufficient to provide a response time of ten seconds or less under normal operating.conditions. c. CA maintains an online 24x7 Repository that application software can use to automatically check the current status of all unexpired Certificates d. CA maintains a continuous 24x7 ability to respond internally to a high-priority Certificate Problem Report	Mandatory	CA Browser Forum 4.10.2			

3.3.2. Subordinate CA Certificate and Cross Certificate Lifecycle Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Subordinate CA Certificate and Cross Certificate Lifecycle Management							
3.3.2.1	The Parent CA authenticates the Sub-CA certificate rekey request in accordance with the CP.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.7			

CCA - AUDIT REPORT

3.3.2.2	The Parent CP specifies the requirements for submission of Sub-CA and cross certification requests.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.1			
3.3.2.3	The Parent CA authenticates the Sub-CA or cross certificate request in accordance with the Parent's CP.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.2			
3.3.2.4	The Parent CA performs an assessment of the Sub-CA or cross certificate applicant's compliance with the requirements of the Parent CA's CP before approving a Sub-CA or cross certificate request, or alternatively the Sub-CA or cross certificate applicant presents its CPS for assessment.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.3			
3.3.2.5	Where Sub-CA and cross certificate renewal is permitted, the Parent CA's CP specifies the requirements for submission of Sub-CA or cross certificate renewal requests	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.4			
3.3.2.6	Where Sub-CA certificate and cross certificate renewal is permitted, the Parent CA authenticates the Sub-CA or cross certificate renewal request in accordance with the CA's CP.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.5			
3.3.2.7	The Parent CA's CP specifies the requirements for	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the	Not Applicable	WebTrust 7.1.6			

COA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	submission of Sub-CA rekey requests	controls are not applicable					
3.3.2.8	The Parent CA generates certificates: • using the appropriate certificate profile in accordance with the CP and ISO 9594/X.509 and ISO 15782-1 formatting rules; • with the validity periods formatted in accordance with ISO 9594/X.509, ISO 15782-1 and the CP; and • where extensions are used, with extension fields formatted in accordance with ISO 9594/X.509, ISO 15782-1 and the CP	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.8			
3.3.2.9	The Parent CA signs the Sub-CA or cross certificate with the Parent CA's private signing key	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.9			
3.3.2.10	The Parent CA makes Sub-CA and cross certificates available to relevant entities (e.g., Relying Parties) using an established mechanism (e.g., a repository such as a directory) in accordance with the Parent CA's CP.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.10			
3.3.2.11	The Parent CA verifies the identity and authority of the entity requesting revocation of a Sub-CA or cross certificate in accordance with the Parent CA's CP.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.11			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.3.2.12	The Parent CA updates the Certificate Revocation List (CRL) and other Sub-CA or cross certificate status mechanisms upon certificate revocation in accordance with the Parent CA's CP.	1. No action required from auditor to check the controls as there is no provision for subordinate CA in the current system. Hence all the controls are not applicable	Not Applicable	WebTrust 7.1.12			

3.3.3. Publication and repository responsibilities

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Repositories							
3.3.3.1	The CA shall develop, implement, enforce, and annually update a Certificate Policy and/or Certification Practice Statement that describes in detail how the CA implements the latest version of these Requirements	1. Verify the CA develops, implements, enforces, and annually updates a Certificate Policy and/or Certification Practice Statement that describes in detail how the CA implements the latest version of these Requirements 2. Check the CA makes revocation information for Subordinate Certificates and Subscriber Certificates available in accordance with this Policy 3. Validate CA ensures continued accessibility and availability of its Public Key Certificates and Certificate Revocation Lists in its repository to its subscribers and relying parties	Mandatory	CA Browser Forum 2			
3.3.3.2	The CA shall make revocation information for Subordinate Certificates and Subscriber Certificates available in accordance with this Policy. The Certifying Authority shall ensure the continued accessibility and availability of its Public Key Certificates and Certificate Revocation Lists in its repository to its subscribers and relying parties.	1. Verify the CA develops, implements, enforces, and annually updates a Certificate Policy and/or Certification Practice Statement that describes in detail how the CA implements the latest version of these Requirements 2. Check the CA makes revocation information for Subordinate Certificates and Subscriber Certificates available in accordance with this Policy 3. Validate CA ensures continued accessibility and availability of its Public Key Certificates and Certificate Revocation Lists in its repository to its subscribers and relying parties	Mandatory	CA Browser Forum 2.1, IT Regulations 3			
Publication of information							

CCA IT AUDIT REPORT

3.3.3.3	The CA shall host test Web pages that allow Application Software Suppliers to test their software with Subscriber Certificates that chain up to each publicly trusted Root Certificate. At a minimum, the CA shall host separate Web pages using Subscriber Certificates that are (i) valid, (ii) revoked, and (iii) expired	Check that the CA's repository is publically available in read only format	Mandatory	CA Browser Forum 2.3			
3.3.3.4	The CA shall publicly disclose its Certificate Policy and/or Certification Practice Statement through an appropriate and readily accessible online means that is available on a 24x7 basis.	1. Verify the CA has publicly disclosed its CP and CPS and these are readily accessible online on a 24x7 basis 2. Validate the CP and CPS are structured in accordance with RFC 3647 3. Validate the CA publicly gives effect to the Requirements mentioned in control description (3.4.3.5) and represents that it will adhere to the latest published version 4. Check that the CA hosts test web pages to allow ASPs to test their software with Subscriber 5. Verify the CA hosts separate Web pages using Subscriber Certificates that are (i) valid, (ii) revoked, and (iii) expired	Mandatory	CA Browser Forum 2.2			
3.3.3.5	Effective as of 31 May 2018, the Certificate Policy and/or Certification Practice Statement must be structured in accordance with RFC 3647. Prior to 31 May 2018, the Certificate Policy and/or Certification Practice Statement must be structured in accordance with either RFC 2527 or RFC 3647. The Certificate Policy and/or Certification Practice Statement must include all material required by RFC 3647 or, if structured as such, RFC 2527.	1. Verify the CA has publicly disclosed its CP and CPS and these are readily accessible online on a 24x7 basis 2. Validate the CP and CPS are structured in accordance with RFC 3647 3. Validate the CA publicly gives effect to the Requirements mentioned in control description (3.4.3.5) and represents that it will adhere to the latest published version 4. Check that the CA hosts test web pages to allow ASPs to test their software with Subscriber 5. Verify the CA hosts separate Web pages using Subscriber Certificates that are (i) valid, (ii) revoked, and (iii) expired	Mandatory	CA Browser Forum 2.2			
3.3.3.6	The CA shall publicly give effect to these Requirements and represent that it will adhere to the latest published version. The CA may fulfill this requirement by incorporating these Requirements directly into	1. Verify the CA has publicly disclosed its CP and CPS and these are readily accessible online on a 24x7 basis 2. Validate the CP and CPS are structured in accordance with RFC 3647 3. Validate the CA publicly gives effect to the Requirements mentioned in control description (3.4.3.5) and	Mandatory	CA Browser Forum 2.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	its Certificate Policy and/or Certification Practice Statements or by incorporating them by reference using a clause such as the following (which must include a link to the official version of these Requirements): [Name of CA] conforms to the current version of the Baseline Requirements for the Issuance and Management of Publicly-Trusted Certificates published at http://www.cabforum.org. In the event of any inconsistency between this document and those Requirements, those Requirements take precedence over this document.	represents that it will adhere to the latest published version 4. Check that the CA hosts test web pages to allow ASPs to test their software with Subscriber 5. Verify the CA hosts separate Web pages using Subscriber Certificates that are (i) valid, (ii) revoked, and (iii) expired					
Access controls on repositories							

3.3.4. Certificate, crl and oscp profiles

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Certificate profile							
3.3.4.1	Effective September 30, 2016, CAs shall generate non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG.	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the following: a. Certificates is of type X.509 v3 b. basicConstraints extension appears as a critical extension c. basicConstraints extension is set true d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present	Mandatory	CA Browser Forum 7.1			
3.3.4.2	Certificates must be of type X.509 v3.	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the following: a. Certificates is of type X.509 v3	Mandatory	CA Browser Forum 7.1.1			

CCA AUDIT REPORT

		b. basicConstraints extension appears as a critical extension c. basicConstraints extension is set true d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present					
3.3.4.3	basicConstraints - This extension must appear as a critical extension. The CA field must be set true. The pathLenConstraint field should NOT be present	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the following: a. Certificates is of type X.509 v3 b. basicConstraints extension appears as a critical extension c. basicConstraints extension is set true d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present	Mandatory	CA Browser Forum 7.1.2.1			
3.3.4.4	keyUsage - This extension must be present and must be marked critical. Bit positions for keyCertSign and cRLSign must be set. If the Root CA Private Key is used for signing OCSP responses, then the digitalSignature bit must be set.	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the following: a. Certificates is of type X.509 v3 b. basicConstraints extension appears as a critical extension c. basicConstraints extension is set true d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present	Mandatory	CA Browser Forum 7.1.2.1			
3.3.4.5	certificatePolicies - This extension should NOT be present	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the	Mandatory	CA Browser Forum 7.1.2.2			

CCIE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		following: a. Certificates is of type X.509 v3 b. basicConstraints extension appears as a critical extension c. basicConstraints extension is set true d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present					
3.3.4.6	extendedKeyUsage - This extension must NOT be present	1. Verify CAs generates non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits of output from a CSPRNG. 2. For sample Certificates, check the following: a. Certificates is of type X.509 v3 b. basicConstraints extension appears as a critical extension c. basicConstraints extension is set true d. pathLenConstraint field is not present e. keyUsage extension is present and marked critical f. Bit positions for keyCertSign and cRLSign are set g. digitalSignature bit is set, If the Root CA Private Key is used for signing OCSP responses h. certificatePolicies and extendedKeyUsage are not present	Mandatory	CA Browser Forum 7.1.2.1			
CRL Profile							
3.3.4.7	CA shall make a full and complete CRL available to the OCSP Responders	1. Check that the CA has made the full and complete CRL available to the OCSP responder	Mandatory	X.504 Policy 7.2.1			
OCSP Profiles							
3.3.4.8	OCSP requests and responses shall be in accordance with RFC 2560	1. Verify the OCSP requests and responses are in accordance with RFC 2560	Mandatory	X.504 Policy 7.3			

3.4. Identity Verification Controls

3.4.1. Naming

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Naming							

CONFIDENTIAL - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.4.1.1	Rules for interpreting name forms shall be in accordance with applicable Standards	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same	Mandatory	X.509 Policy 3.1.4, CA BrowserForum 3.1.4			
3.4.1.2	The CAs shall generate and sign certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields. Subject Alternative Name may also be used, if marked non-critical.	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same	Mandatory	X.509 Policy 3.1.1, CA Browser Forum 3.1.1			
3.4.1.3	The certificates issued pursuant to CP are meaningful only if the names that appear in the certificates can be understood and used by Relying Parties. Names used in the certificates must identify the person or object to which they are assigned in a meaningful way.	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms	Mandatory	X.509 Policy 3.1.2, CA Browser Forum 3.1.2			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same					
3.4.1.4	All DNs and associated directory information tree shall accurately reflect organizational structures.	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same	Mandatory	X.509 Policy 3.1.2, CA Browser Forum 3.1.2			
3.4.1.5	CA and subscriber certificates shall not contain anonymous or pseudonymous identities.	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same	Mandatory	X.509 Policy 3.1.3, CA Browser Forum 3.1.3			
3.4.1.6	Name uniqueness of Root CA, licensed CA and SubCA shall be enforced	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the	Mandatory	X.509 Policy 3.1.5, CA Browser Forum 3.1.5			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same					
3.4.1.7	The CCA shall resolve any name collisions (other than subscribers) brought to its attention that may affect interoperability or trustworthiness	1. Verify the CA generates and signs certificates containing an X.500 Distinguished Name (DN) in the Issuer and in Subject fields 2. Conduct walkthrough to check the following on sample basis: a. Names used in the certificates identify the person or object to which they are assigned in a meaningful way. b. All DNs and associated directory information tree accurately reflect organizational structures. c. CA and subscriber certificates do not contain anonymous or pseudonymous identities d. Rules for interpreting name forms are in accordance with applicable Standards e. Name uniqueness of Root CA, licensed CA and SubCA is enforced f. CCA resolves name collisions, check by identifying cases of name collisions that were encountered and the process followed to resolve the same	Mandatory	X.509 Policy 3.1.7, CA Browser Forum 3.1.7			

3.4.2. Initial identity validation

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.4.3. Identification and authentication for revocation request

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Identification and authentication for revocation request							
3.4.3.1	Revocation requests shall be authenticated. Requests to revoke a certificate may be authenticated using that certificate's	1. For sample revocation requests, verify the revocation requests are authenticated 2. Validate CA has a process implemented to suspend/revoke the certificate on verifying the subscriber’s identity in case of loss of key	Mandatory	X.509 Policy 3.4, , CA Browser Forum 3.4			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	associated public key, regardless of whether or not the private key has been compromised						
3.4.3.2	In the case of loss of key, CA can suspend/revoke the certificate on verifying the subscriber's identity. In the case where subscriber is not in a position to communicate (death, unconscious state, mental disorder), on receiving such information CA can suspend the certificate and after verification the certificate can be revoked.	1. For sample revocation requests, verify the revocation requests are authenticated 2. Validate CA has a process implemented to suspend/revoke the certificate on verifying the subscriber's identity in case of loss of key	Mandatory	X.509 Policy 3.4, CA Browser Forum 3.4			

3.4.4. Identification and authentication for re key requests

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.4.5. General Guidelines to CAs

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.4.6. Guidelines for maintaining eKYC account by CA

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.4.7. Guidelines for issuance of special purpose DSC

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.4.8. Initial identity validation

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Initial identity validation							
3.4.8.1	In all cases where the party named in a certificate generates its own keys that party shall be required to prove possession of the private key, which corresponds	1. Verify using samples, cases where the party named in a certificate generates its own keys that party is required to prove possession of the private key, which corresponds to the public key in the certificate request 2. Validate using samples, cases where the requests for certificates in the name of an organizational user include the user name,	Mandatory	X.509 Policy 3.2.1, CA Browser Forum 3.2.1			

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	to the public key in the certificate request. For signature keys, this may be done by the entity using its private key to sign a value and providing that value to the issuing CA. The CA shall then validate the signature using the party's public key	organization name, address, and documentation of the existence of the organization 3. Check the CA ensures the applicant's identity information is verified 4. Verify the process documentation and authentication is done as per description given in control 3.5.2.4					
3.4.8.2	Requests for certificates in the name of an organizational user shall include the user name, organization name, address, and documentation of the existence of the organization. The CA shall verify the information relating to the authenticity of the requesting representative.	1. Verify using samples, cases where the party named in a certificate generates its own keys that party is required to prove possession of the private key, which corresponds to the public key in the certificate request 2. Validate using samples, cases where the requests for certificates in the name of an organizational user include the user name, organization name, address, and documentation of the existence of the organization 3. Check the CA ensures the applicant's identity information is verified 4. Verify the process documentation and authentication is done as per description given in control 3.5.2.4	Mandatory	X.509 Policy 3.2.2, CA Browser Forum 3.2.2			
3.4.8.3	A CA shall ensure that the applicant's identity information i verified. The CA shall ensure that the applicant's identity information and public key are properly bound. Additionally, the CA shall record the process that was followed for issuance of each certificate. Process information shall depend upon the certificate level of assurance and shall be addressed in the applicable CPS	1. Verify using samples, cases where the party named in a certificate generates its own keys that party is required to prove possession of the private key, which corresponds to the public key in the certificate request 2. Validate using samples, cases where the requests for certificates in the name of an organizational user include the user name, organization name, address, and documentation of the existence of the organization 3. Check the CA ensures the applicant's identity information is verified 4. Verify the process documentation and authentication is done as per description given in control 3.5.2.4	Mandatory	X.509 Policy 3.2.3, CA Browser Forum 3.2.3			
3.4.8.4	The process documentation and authentication requirements shall include the following:	1. Verify using samples, cases where the party named in a certificate generates its own keys that party is required to prove possession of the private key, which corresponds to the public key in the certificate request	Mandatory	X.509 Policy 3.2.3, CA Browser Forum 3.2.3			

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	• The identity of the person performing the identity verification; • A signed declaration by that person that he or she verified the identity of the applicant; • The applicant shall present one photo ID. The applicant shall also present a document as a proof of residential address. • Unique identifying numbers from the Identifier (ID) of the verifier and from an ID of the applicant; • The date and time of the verification; and • A declaration of identity signed by the applicant using a handwritten signature or equivalent per Indian Laws.	2. Validate using samples, cases where the requests for certificates in the name of an organizational user include the user name, organization name, address, and documentation of the existence of the organization 3. Check the CA ensures the applicant's identity information is verified 4. Verify the process documentation and authentication is done as per description given in control 3.5.2.4					
3.4.8.5	For Class 2 and Class 3 certificates, identity shall be established by in-person proofing before the CA, to confirm identities; information provided shall be verified to ensure legitimacy	1. Verify for Class 2 and Class 3 certificates, identity is established by in-person proofing before the CA, to confirm identities 2. Validate CA does not include any non-verified information in the certificates	Mandatory	X.509 Policy 3.2.3, CA Browser Forum 3.2.3			
3.4.8.6	Information that is not verified shall not be included in certificates.	1. Verify for Class 2 and Class 3 certificates, identity is established by in-person proofing before the CA, to confirm identities 2. Validate CA does not include any non-verified information in the certificates	Mandatory	X.509 Policy 3.2.4, CA Browser Forum 3.2.4			

3.4.9. dentification and authentication for revocation request

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.4.10. Identification and authentication for re key requests

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

Identification and authentication for re-key requests							
3.4.10.1	The CAs and subscribers shall identify themselves through use of their current Signing Key or by using the initial identity-proofing process	1. Verify CAs and subscribers identify themselves through use of their current Signing Key or by using the initial identity-proofing process 2. Validate identity is established through the initial identity proofing process for each assurance level as per the CP 3. Check on sample basis when current Signing Key is used for identification and authentication purposes, the life of the new certificate does not exceed beyond the initial identity-proofing times specified in the CP	Mandatory	X.509 Policy 3.3.1, CA BrowserForum 3.3.1			
3.4.10.2	Identity shall be established through the initial identity- proofing process for each assurance level per the CP	1. Verify CAs and subscribers identify themselves through use of their current Signing Key or by using the initial identity-proofing process 2. Validate identity is established through the initial identity proofing process for each assurance level as per the CP 3. Check on sample basis when current Signing Key is used for identification and authentication purposes, the life of the new certificate does not exceed beyond the initial identity-proofing times specified in the CP	Mandatory	X.509 Policy 3.3.1, CA Browser Forum 3.3.1			
3.4.10.3	When current Signing Key is used for identification and authentication purposes, the life of the new certificate shall not exceed beyond the initial identity-proofing times specified in the table above.	1. Verify CAs and subscribers identify themselves through use of their current Signing Key or by using the initial identity-proofing process 2. Validate identity is established through the initial identity proofing process for each assurance level as per the CP 3. Check on sample basis when current Signing Key is used for identification and authentication purposes, the life of the new certificate does not exceed beyond the initial identity-proofing times specified in the CP	Mandatory	X.509 Policy 3.3.1, CA Browser Forum 3.3.1			

3.4.11. General Guidelines to CAs

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
General							
3.4.11.1	CA shall make sure the following text shall be displayed to the user before submission / signing of DSC application form. Section 71 of IT Act stipulates that if anyone makes a misrepresentation or suppresses any material fact from the CCA or CA for obtaining any DSC	1. Validate the text mentioned in control 3.5.5.1 is displayed to the user before submission/ signing of DSC application form 2. Check eKYC information collected from applicant is not shared by CA and comply to all the provisions of IT Act for protecting the information specifically Rule 33 and 34 of IT CA Rules 3. Check that subscriber's registered information with CA such as video, photo, ID cards, phone number,	Mandatory	Identity Verification Guidelines (IVG) Section 1.1			

COMPLIANCE REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	such person shall be punishable with imprisonment up to 2 years or with fine up to one lakh rupees or with both	PAN/Aadhaar, other information submitted and not a part of certificate in readable form are confidential and its access has been limited to only authorized CA personnel.					
3.4.11.2	The eKYC information collected from applicant shall not be shared by CA and comply with all the provisions of IT Act for protecting the information specifically Rule 33 and 34 of IT CA Rules	1. Validate the text mentioned in control 3.5.5.1 is displayed to the user before submission/ signing of DSC application form 2. Check eKYC information collected from applicant is not shared by CA and comply to all the provisions of IT Act for protecting the information specifically Rule 33 and 34 of IT CA Rules 3. Check that subscriber's registered information with CA such as video, photo, ID cards, phone number, PAN/Aadhaar, other information submitted and not a part of certificate in readable form are confidential and its access has been limited to only authorized CA personnel.	Mandatory	IVG Sect. 1.1			
3.4.11.3	The subscriber's registered information with CA such as video, photo, ID cards, phone number, PAN/Aadhaar, other information submitted and not a part of certificate in readable form are confidential and its access shall be limited to only authorized CA personnel. Access, sharing, photographic images/video and/or retention of such information by anybody other than CA, as applicable under the provisions of IT Act, shall be liable for penalty for breach of confidentiality and privacy under section 72 of IT Act.	1. Validate the text mentioned in control 3.5.5.1 is displayed to the user before submission/ signing of DSC application form 2. Check eKYC information collected from applicant is not shared by CA and comply to all the provisions of IT Act for protecting the information specifically Rule 33 and 34 of IT CA Rules 3. Check that subscriber's registered information with CA such as video, photo, ID cards, phone number, PAN/Aadhaar, other information submitted and not a part of certificate in readable form are confidential and its access has been limited to only authorized CA personnel.	Mandatory	IVG Sect. 1.1			
eKYC Account							
3.4.11.4	eKYC account of DSC applicant is mandatory for applying for a DSC or availing eSign service. The verified information held by CA shall be used for issuance of DSC or eSign. For eSign service based on online Aadhaar authentication, eKYC account is not required	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been	Mandatory	IVG Sect. 1.2			

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with					

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.5	The eKYC account of the DSC applicant shall be created by CA based on eKYC of applicant (Bank, Organisational, PAN and Offline Aadhaar) or a direct verification (Foreign Nationals) . The information which are required in DSC application form and not present in the eKYC of applicant shall be submitted by the eKYC applicant and verified by CA before activating the eKYC account.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same.	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.6	Prior to submitting information for the eKYC account creation of an applicant, the CA shall authenticate the applicant using the applicant's mobile number and the same mobile number shall be used in the subsequent authentication also. Upon successful authentication of the applicant, start a new session for all the associated with the eKYC account creation process and continue the session till its completion. Also, the same mobile number should be a part of the eKYC account of the applicant.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.7	For eKYC account creation, CA shall provide the	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand	Mandatory	IVG Sect. 1.2			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	interface only to the applicant. Also, CA shall not provide any provision to submit the applicant's details other than the applicant.	validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for					

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.8	The DSC applicant's access to the website of CA for submission of details for eKYC account creation, video verification and Online Aadhaar authentication shall be only through a single & dedicated interface provided by CA and link-based access shall not be permitted for these interfaces	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant.	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.9	In case eKYC account holder requires more than one account (fore.g personal and organizational), eKYC account holder must undergo all the verification procedures mentioned for the additional eKYC option. CA should treat both eKYC accounts logically under one eKYC account of the eKYC applicant. The mobile number and PAN can be the same. For user authentication, CA shall provide an option for selecting the account mode	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation.	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	(personal/organizational)	• Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed					

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.10	The validity of eKYC account shall not be more than 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant under these guidelines.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.11	In case CA is not able to ascertain the genuineness of the e-KYC data submitted by applicant, CA shall reject the request	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.12	CA shall notify applicant the subscriber agreement for the use of KYC information for DSC issuance by CA on successful authentication by the applicant. The applicant shall have option to accept or reject the same	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in	Mandatory	IVG Sect. 1.2			

CCA-AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN.					

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.13	Applicant shall be able to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account maintained by CA.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.14	Applicant shall have an option to activate, deactivate and close account at any point.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.15	Appropriate fraud detection and preventive	Conduct a walkthrough of the e KYC facility and check the following:	Mandatory	IVG Sect. 1.2			

CCA – AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	security mechanisms shall be implemented against enrollment frauds. Specifically CA should make sure that the page capturing PIN shall be free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc	1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for					

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.16	CA shall have approval of CCA for maintaining eKYC account for applicants.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.17	The format of the eKYC account ID shall be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the	Mandatory	IVG Sect. 1.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate, deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured					

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
3.4.11.18	The PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.	Conduct a walkthrough of the e KYC facility and check the following: 1. Take details of issued certificatesand validate on sample basis CA maintains eKYC account of DSC applicant for applying for a DSC or availing eSign services and verified information held by CA is only used for issuance of DSC or providing eSign service. 2. Verifyinformation which is required in DSC application form and not present in the eKYC of applicant has been submitted by the eKYC applicant and verified by CA before activating the eKYC account. 3. Verify • the mobile authentication of applicant is implemented by CA before accessing the web interface for submitting the details for the eKYC account creation. • Inspect the coverage of sessions till completion. • Check whether the CA software accepts mobile number other than that used for authentication. 4. Examine how CA prevent the access to the web interface for submission of applicant details other than the designated single and dedicated web interface. 5. Validate how CA prevent link based access for the submission of DSC applicant details. 6. Verify CA maintains a logical one account in case the eKYC account holder requires more than one accounts (for e.g personal and organizational), and CA carried out all verification procedures for each eKYC option included and provides an option to the user for selecting the account mode (personal/organizational). 7. The maximum validity of eKYC account is 2 years. The account (with same username, PAN, Mobile) can be extended only through carrying a fresh verification of the applicant. 8. Validate CA rejects the requests for which CA is not able to ascertain the genuineness of the eKYC data submitted by the applicant 9. Verify that CA notifies applicant about subscriber agreement for the use of KYC information for DSC issuance and provides option to accept or reject the same. 10. Verify option provided to applicant to access notifications, history of eSign transactions, account modification etc., activation & deactivation info and also manage any queries/disputes through eKYC account. 11. Verify an option to activate,	Mandatory	IVG Sect. 1.2			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		deactivate and close account is available for the applicant 12. Appropriate fraud detection and preventive security mechanisms have been implemented. Specifically check page capturing PIN is free from the threat like phishing attacks, malicious plug-in, hijack clicks/key strokes etc 13. Check CA has approval of CCA for maintaining eKYC for applicants for particular mode of eKYC (Aadhaar offline, Aadhaar online, Organizational KYC, Banking, PAN eKYC and eKYC for foreign applicants) 14. Verify the format of the eKYC account ID be of the format: id@id-type.esp-id. The allowed eKYC account id type are username, Mobile and PAN. The PIN shall be created along with eKYC account ID. eKYC account user ID change is not allowed after creation. 15. Verify that PIN reset shall be with mobile OTP and email verification. In the absence of email, it shall be mobile OTP and video verification. In the case of banking where email is not captured earlier, the PIN reset shall be allowed only after successful matching of fresh eKYC with the registered eKYC details.					
DSC Application Form							
3.4.11.19	DSC application form shall be generated by CA based on the verified information held in eKYC account maintained by CA after obtaining the two-factor authentication of the applicant.	1. Validate DSC application form can be generated by CA based on the verified information held in eKYC account maintained by CA after obtaining the two-factor authentication of the applicant. 2. Validate the electronic signature of the applicant in the DSC application form has been affixed using the eSign service of the CA. 3. Validate power of attorney is not allowed for the purpose of DSC application to CA and issuance of DSC.	Mandatory	IVG Sect. 1.3			
3.4.11.20	The electronic signature of the applicant in the DSC application form shall be affixed using the eSign service of the CA.	1. Validate DSC application form can be generated by CA based on the verified information held in eKYC account maintained by CA after obtaining the two-factor authentication of the applicant. 2. Validate the electronic signature of the applicant in the DSC application form has been affixed using the eSign service of the CA. 3. Validate power of attorney is not allowed for the purpose of DSC application to CA and issuance of DSC.	Mandatory	IVG Sect. 1.3			
3.4.11.21	Power of attorney is not allowed for the purpose of DSC application to CA	1. Validate DSC application form can be generated by CA based on the verified information held in eKYC account	Mandatory	IVG Sect. 1.3			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	and Issuance of DSC	maintained by CA after obtaining the two-factor authentication of the applicant. 2. Validate the electronic signature of the applicant in the DSC application form has been affixed using the eSign service of the CA. 3. Validate power of attorney is not allowed for the purpose of DSC application to CA and issuance of DSC.					
Mandatory Information in the DSC application Form							
3.4.11.22	Name, address (residence/organisation), email, Mobile Number, PAN/Aadhaar no (Last four digit), Photo, Date, type certificate (personal/organisational), signature of applicant and Class are mandatory in the eKYC account and DSC application form for issuance of DSC. Email is optional for eKYC account to be created only for the purpose of eSign.	1. Verify for mandatory information i.e., Name, address (residence/organisation), email, Mobile Number, PAN/Aadhaar no (Last four digit), Photo, Date, type certificate (personal organisational), signature of applicant and Class in the eKYC account and DSC application form for issuance of DSC. 2. Verify either PAN or Aadhaar Number taken for all categories of DSC applicants.	Mandatory	IVG Sect. 1.4			
3.4.11.23	For all categories of DSC applicants, it is mandatory to provide either PAN or Aadhaar Number.	1. Verify for mandatory information i.e., Name, address (residence/organisation), email, Mobile Number, PAN/Aadhaar no (Last four digit), Photo, Date, type certificate (personal organisational), signature of applicant and Class in the eKYC account and DSC application form for issuance of DSC. 2. Verify either PAN or Aadhaar Number taken for all categories of DSC applicants.	Mandatory	IVG Sect. 1.4			
Name							
3.4.11.24	The name of the DSC applicant shall be same as the name in respective eKYC	1. Validate name of the DSC applicant is same as the name in respective eKYC 2. Verify proof of Identity, copy of at least one photo Identity proof bearing name of the applicant as per IVG has been collected.	Mandatory	IVG Sect. 1.5			
3.4.11.25	For proof of Identity, copy of at least one photo Identity proof bearing name of the applicant , as mentioned in the Annexure IV , shall be submitted	1. Validate name of the DSC applicant is same as the name in respective eKYC 2. Verify proof of Identity, copy of at least one photo Identity proof bearing name of the applicant as per IVG has been collected.	Mandatory	IVG Sect. 1.5			
Address							
3.4.11.26	The address of the DSC	1. Validate residential or organizational	Mandatory	IVG Sect. 1.6			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	applicant shall be residential or organisational.	address be provided 2. Verify address proof of DSC applicant as per IVG collected.					
3.4.11.27	For address proof, the applicable list of documents are given in Annexure IV	1. Validate residential or organizational address be provided 2. Verify address proof of DSC applicant as per IVG collected.	Mandatory	IVG Sect. 1.6			
Mobile Number							
3.4.11.28	Mobile Number of applicant is a pre-requisite for creation of eKYC account by CA for applicant.	1. Mobile number is mentioned as mandatory pre-requisite for creation of eKYC account by CA 2. Validate CA send a SMS OTP for the proof of possession of mobile number and the same is verified by capturing through the interface provided by CA. Such verification OTP is random, communicated only to the mobile number under verification, and is not based on any predetermined parameters to avoid the compromise.	Mandatory	IVG Sect. 1.7			
3.4.11.29	For the proof possession of mobile number, CA shall send a SMS OTP and the same shall be verified by capturing through the interface provided by CA. Such verification OTP shall be random, communicated only to the mobile number under verification, and shall not be based on any predetermined parameters to avoid the compromise.	1. Mobile number is mentioned as mandatory pre-requisite for creation of eKYC account by CA 2. Validate CA send a SMS OTP for the proof of possession of mobile number and the same is verified by capturing through the interface provided by CA. Such verification OTP is random, communicated only to the mobile number under verification, and is not based on any predetermined parameters to avoid the compromise.	Mandatory	IVG Sect. 1.7			
Email Address							
3.4.11.30	Email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA. Email id is optional for the eKYC accounts activated only for the purpose of eSign	1. Validate email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA. 2. Validate unique email id for each applicant are included in DSC 3. Validate CA send an email OTP or challenge response or verification URL to the email of DSC applicant and verify response through the interface provided by CA. Such verification factors is random, communicated only to the email ID under verification, and not based on any predetermined parameters to avoid the compromise. 4. Verify CA preserve the proof of verification with their digital signature 5. Validate that no disposable email is accepted by CA	Mandatory	IVG Sect. 1.8			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.4.11.31	CAs shall put in measures to ensure that email addresses that are included in Digital Signature Certificates (DSC) are unique to the DSC applicant.	1. Validate email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA. 2. Validate unique email id for each applicant are included in DSC 3. Validate CA send an email OTP or challenge response or verification URL to the email of DSC applicant and verify response through the interface provided by CA. Such verification factors is random, communicated only to the email ID under verification, and not based on any predetermined parameters to avoid the compromise. 4. Verify CA preserve the proof of verification with their digital signature 5. Validate that no disposable email is accepted by CA	Mandatory	IVG Sect. 1.8			
3.4.11.32	Provisions can be made for issuance of multiple DSC with a single email Id where it is established that these multiple DSCs are being issued to same DSC applicant.	1. Validate email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA. 2. Validate unique email id for each applicant are included in DSC 3. Validate CA send an email OTP or challenge response or verification URL to the email of DSC applicant and verify response through the interface provided by CA. Such verification factors is random, communicated only to the email ID under verification, and not based on any predetermined parameters to avoid the compromise. 4. Verify CA preserve the proof of verification with their digital signature 5. Validate that no disposable email is accepted by CA	Mandatory	IVG Sect. 1.8			
3.4.11.33	For email verification, CA shall send an email OTP or challenge response or verification URL to the email of DSC applicant and verify response through the interface provided by CA. Such verification factors shall be random, communicated only to the email ID under verification, and shall not be based on any predetermined parameters to avoid the compromise. CA should preserve the proof of verification with their digital signature	1. Validate email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA. 2. Validate unique email id for each applicant are included in DSC 3. Validate CA send an email OTP or challenge response or verification URL to the email of DSC applicant and verify response through the interface provided by CA. Such verification factors is random, communicated only to the email ID under verification, and not based on any predetermined parameters to avoid the compromise. 4. Verify CA preserve the proof of verification with their digital signature 5. Validate that no disposable email is accepted by CA	Mandatory	IVG Sect. 1.8			
3.4.11.34	No disposable email (fast temporary email without registration) shall be accepted by CA.	1. Validate email id of the applicant is mandatory for issuance of DSC based on the eKYC account activated by CA. 2. Validate unique email id for each applicant are included in DSC 3. Validate CA send an email OTP or	Mandatory	IVG Sect. 1.8			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		challenge response or verification URL to the email of DSC applicant and verify response through the interface provided by CA. Such verification factors is random, communicated only to the email ID under verification, and not based on any predetermined parameters to avoid the compromise. 4. Verify CA preserve the proof of verification with their digital signature 5. Validate that no disposable email is accepted by CA					
PAN							
3.4.11.35	CA shall electronically verify the PAN number through the eKYC service provided by Income tax and accept only if the verification is successful, the name of the PAN holder and Date of Birth match and also the Aadhaar seeding status is operative. CA shall preserve the proof of verification with their digital signature.	1. Validate CA electronically verifes the PAN number with Income tax database through eKYC service and accept only if the verification is successful, the name of the PAN holder and Date of Birth match and also the Aadhaar seeding status is operative. 2. Verify CA preserve the proof of verification with their digital signature	Mandatory	IVG Sect. 1.9			
Verification							
3.4.11.36	Verification is the electronic verification of the identity and information submitted by eKYC applicant for the purpose of creating an eKYC account with CA for eSign or DSC issuance.	1. Validate verification for the purpose of creating an eKYC account with CA for eSign or DSC issuance is the electronic verification of the identity and nformation submitted by eKYC applicant. 2. Validate CA allow only the automatic population of digitally signed information received from source of eKYC . 3. The information received from the other source (like PAN and GSTN) is only used for cross verifying the information submitted by the applicant in the interface provided by CA.	Mandatory	IVG Sect.1.10			
3.4.11.37	CA shall allow only the automatic population of digitally signed information received from source of eKYC like Aadhaar or Bank in the electronic application form. The information received from the other source (like PAN and GSTN) shall be used only for cross verifying the information submitted by the applicant in the interface provided by CA.	1. Validate verification for the purpose of creating an eKYC account with CA for eSign or DSC issuance is the electronic verification of the identity and nformation submitted by eKYC applicant. 2. Validate CA allow only the automatic population of digitally signed information received from source of eKYC . 3. The information received from the other source (like PAN and GSTN) is only used for cross verifying the information submitted by the applicant in the	Mandatory	IVG Sect.1.10			

COMMENT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		interface provided by CA.					
Physical verification/Video verification							
3.4.11.38	The physical verification of DSC applicant shall be carried out using online interactive video verification directly by CA as per Annexure VI or by online Aadhaar eKYC Biometric Authentication	1. Validate physical verification of DSC applicant is carried out using online interactive video verification directly by CA as per Annexure VI of IVG or by online Aadhaar eKYC Biometric Authentication 2. Verify CA checks any indication of alteration or falsification in video recording	Mandatory	IVG Sect.1.11			
3.4.11.39	CA shall check any indication of alteration or falsification in video recording	1. Validate physical verification of DSC applicant is carried out using online interactive video verification directly by CA as per Annexure VI of IVG or by online Aadhaar eKYC Biometric Authentication 2. Verify CA checks any indication of alteration or falsification in video recording	Mandatory	IVG Sect.1.11			
Documents verification							
3.4.11.40	In lieu of the attestation of documents exists in the paper- based DSC application; CA shall verify the uploaded supporting documents using direct online interactive video verification of the original documents held by the DSC applicant or online verification from source of issuance of the documents	1. Validate CA verifies the uploaded supporting documents using direct online interactive video verification of the original documents held by the DSC applicant or online verification from source of issuance of the documents 2. Verify on sample basis originals of the identity and address proof has been verified during the video verification, if applicable as per IVG 3. Validate video verification of the original documents is carried out by CA as per Annexure VI of IVG	Mandatory	IVG Sect.1.12			
3.4.11.41	If applicable, the originals of the identity and address proof shall be verified during the video verification.	1. Validate CA verifies the uploaded supporting documents using direct online interactive video verification of the original documents held by the DSC applicant or online verification from source of issuance of the documents 2. Verify on sample basis originals of the identity and address proof has been verified during the video verification, if applicable as per IVG 3. Validate video verification of the original documents is carried out by CA as per Annexure VI of IVG	Mandatory	IVG Sect.1.12			
3.4.11.42	The video verification of the original documents shall be carried out as per Annexure VI	1. Validate CA verifies the uploaded supporting documents using direct online interactive video verification of the original documents held by the DSC applicant or online verification from source of issuance of the documents	Mandatory	IVG Sect.1.12			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		2. Verify on sample basis originals of the identity and address proof has been verified during the video verification, if applicable as per IVG 3. Validate video verification of the original documents is carried out by CA as per Annexure VI of IVG					
3.4.11.43	Using online verification, CA shall verify the authenticity of the document submitted and the digitally signed proof of the online verification shall be maintained.	Verify whether CA is verifying the authenticity of the documents through online process and proof retained	Mandatory	IVG Sect.1.12			
3.4.11.44	For the digitally signed documents received from the issuing authority or the same fetched through Digi locker by CA, further verification of supporting documents through video is not required.	Verify whether the documents fetched through Digilocker bearing the electronic signature of the issuer	Mandatory	IVG Sect.1.12			
Key pair generation/Storage							
3.4.11.45	Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs shall be as per annexure II. For individual signing certificates, the CA should verify the validity of the Key attestation by HSM and also verify no certificates with different DN have been issued earlier.	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation	Mandatory	IVG Sect.1.13			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM					
3.4.11.46	CA shall issue class 3 level individual signing certificate (both Personal & organizational) to the private key generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens) with both Class 2 and Class 3 OID in the policy field. CA shall not issue class 2 level individual Signing certificates alone instead CA shall issue Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. Class 3 individual signing certificates shall be qualified as both class 2 & class 3 individual signing certificates.	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3	Mandatory	IVG Sect.1.13			

CCA AUDIT REPORT

		Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM					
3.4.11.47	CA shall put procedure in place to ensure that no Class 3 individual Signing DSCs are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens).	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM	Mandatory	IVG Sect.1.13			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.4.11.48	For protection of crypto token against “PIN reset compromise , a) CA shall not support PIN reset procedure for subscriber’s crypto token, unless the crypto token is re- initialized / formatted. For the convenience of DSC applicant on such scenarios, CA shall re-issue the certificate for the remaining period of validity of the certificate. Such re-issuance shall be provided free of cost, at least once per certificate. CA may provide additional re-issuance which may be charged extra by CA to the user. CA shall carryout such re-issuance only after authentication of the subscriber. b) From 01.04.2023 onwards, CA shall not allow the download of DSC to crypto token having default password.	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM	Mandatory	IVG Sect.1.13			
3.4.11.49	A list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens must be published on the website of the CA.	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases	Mandatory	IVG Sect.1.13			

CCA IT AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM					
3.4.11.50	In respect of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk shall be made known to the DSC applicant and an undertaking shall be taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module.	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against “PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and	Mandatory	IVG Sect.1.13			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM					
3.4.11.51	For personal signing certificates, subscribers' key generation shall be strictly using the software provided by CA and shall not be generated outside of the crypto device.	1. Verify CA not issues any class 2 level individual Signing certificates (both Personal & organizational) alone instead CA issues Class 3 individual signing certificates with a combination of both class 2 & class 3 certificates by including Class 2 OID in the Class 3 certificates. 2. Verify CA has procedure in place to ensure that no class 3 level individual signing certificate are issued in cases where the key pair has not been generated on a FIPS 140-2 level 2/3 validated Hardware cryptographic module (crypto tokens). 3. Validate CA follows options mentioned under control 3.5.5.41for protection of crypto token against "PIN reset compromise 4. Verify a list of approved cryptographic device manufacturers / suppliers and information relating to their FIPS 140-2 Level 2/3 validated tokens is published on the website of the CA. 5. Check in case of Class 1 certificate, if the subscriber prefers to use software Cryptographic module, the corresponding risk is made known to the DSC applicant and an undertaking is taken to the effect that the DSC applicant is aware of the risk associated with	Mandatory				

CCA IT AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		storing private keys on a device other than a FIPS 140-2 Level 2/3 validated cryptographic module. 6. Verify the software is provided by CA for key generation and CA certify the public key only if the key pair generation is carried out using the same software provided by them. 7. CA shall verify the software provided for the key-pair generation is audited as per the Security guidelines 8. Verify the CA software not allow the download of DSC to crypto token having default password. 9. Check CA follows Terms and conditions for use of HSM for class 3 Organisational Person DSCs on FIPS 140-2 level 2/3 certified HSMs as per annexure II of IVG in case of DSC (Class 3) being applied for by Organisation person and key-pairs are proposed to be generated on HSM. Verify whether CA has verified the key attestation by HSM and the already issued cerificates to the key pair generated on the HSM					
Invoice/Acknowledgement							
3.4.11.52	To ensure there is no tax evasion in the DSC issuance service a) For Personal Digital Signature Certificate issuance (Class 3), CA shall generate, issue and send the GST tax invoice to the DSC applicant through email. b) For Organizational Person Digital Signature Certificate issuance (Class 2 and Class 3), CA shall generate, issue and send the GST tax invoice to the DSC applicant or applicant's organization through email. c) Except in the case of organisation person certificate through the organization, GeM, tender, person authorized by the organization, etc, CA shall not accept the payment towards DSC issuance in advance, directly or indirectly, causing financial liability in any manner, before the mobile authentication of the DSC applicant. CA shall carry out periodic reconciliation of invoices with corresponding DSC	1. Check Tax invoices are issued by CA as per the requiremenrs 2. Check CA has provided option for the online payment 3. Check the reconciliation report generated by CA. 4. Verify the TAX invoices have been preserved by CAs 5. Verify the proof of sending TAX invoice via email to the DSC applicant.	Mandatory	IVG Sect.1.14			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	issued to subscribers. The copy of the TAX invoice shall be preserved by CA. The applicant's interface software should be integrated with the payment gateway for accepting fees from DSC applicants for the issuance of certificates.						
Subscriber Agreement							
3.4.11.53	CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with the eKYC applicant.	1. Validate CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with the eKYC applicant.	Mandatory	IVG Sect.1.15			
3.4.11.54	For eKYC account creation based on the KYC information source such as Offline Aadhaar KYC, Banking and organisational , the eSign of the subscriber shall be based on the information received from the KYC information source.	2. Validate, for eKYC account creation based on the KYC information source such as Offline Aadhaar KYC, Banking and organisational , the eSign of the subscriber is based on the information received from the KYC information source	Mandatory	IVG Sect.1.15			
DSC Issuance							
3.4.11.55	DSC shall be issued only up on satisfying the verification requirements specified in the respective eKYC sections in this document. The maximum time limit for the download of DSC shall be 30 days from the date of completion of verification/approval. If the download of DSC is not carried out by the applicant within 30 days, applicable verification requirements specified in the respective eKYC sections in this document shall be carried out by CA before DSC issuance	1. Validate maximum time limit for the download of DSC is 30 days from the date of completion of verification/ approval. 2. Verify on sample basis, if the download of DSC is not carried out by the applicant within 30 days, applicable verification specified in the respective eKYC sections of IVG is carried out by CA before DSC issuance	Mandatory	IVG Sect.1.16			
Archival							
3.4.11.56	CAs shall preserve the digitally signed documents, proof of verification information, logs etc. as per the requirements mentioned	1. Check digitally signed documents, proof of verification information, logs etc. are preserved and archived by CA as per Act. 2. Check on sample basis archival information of the Digital Signature	Mandatory	IVG Sect.1.17			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	in the Information Technology Act.	Certificate is available for 7 years from the date of its expiry.					
3.4.11.57	Archival of information shall be 7 years from the date of expiry of the Digital Signature Certificate	1. Check digitally signed documents, proof of verification information, logs etc. are preserved and archived by CA as per Act. 2. Check on sample basis archival information of the Digital Signature Certificate is available for 7 years from the date of its expiry.	Mandatory	IVG Sect.1.17			
Role of Trusted person							
3.4.11.58	CA shall make sure that the CA Verification Officer's roles and responsibilities are not be delegated or controlled by anyone else.	1. Obtain the list of personnel having CA trusted roles 2. Verify the CA Verification Officer's roles and responsibilities are not being delegated or controlled by anyone else. 3. Check all the CA Verification Officers are exclusive employees of the CA and do not have any current or planned financial, legal or other relationship with any external entity facilitating DSC issuance. 4. Check only CA trusted persons/ Verification Officers approves and certify each account information including name timestamp etc. using their own digital signature 5. Check CA has sufficient Verification Officers by gauging the max. approval done in a day corresponding to the number of Verification Officer involved. 6. Submit the List of trusted personnel of CA to CCA.	Mandatory	IVG Sect.1.18			
3.4.11.59	All the CA Verification Officers shall be exclusive employees of the CA and shall not have any current or planned financial, legal or other relationship with any external entity facilitating DSC issuance.	1. Obtain the list of personnel having CA trusted roles 2. Verify the CA Verification Officer's roles and responsibilities are not being delegated or controlled by anyone else. 3. Check all the CA Verification Officers are exclusive employees of the CA and do not have any current or planned financial, legal or other relationship with any external entity facilitating DSC issuance. 4. Check only CA trusted persons/ Verification Officers approves and certify each account information including name timestamp etc. using their own digital signature 5. Check CA has sufficient Verification Officers by gauging the max. approval done in a day corresponding to the number of Verification Officer involved. 6. Submit the List of trusted personnel of CA to CCA.	Mandatory	IVG Sect.1.18			
3.4.11.60	CA trusted person/Verification Officer shall approve and	1. Obtain the list of personnel having CA trusted roles 2. Verify the CA Verification Officer's	Mandatory	IVG Sect.1.18			

CCA AUDIT REPORT

	certify each account information including name timestamp etc. using their own digital signature	roles and responsibilities are not being delegated or controlled by anyone else. 3. Check all the CA Verification Officers are exclusive employees of the CA and do not have any current or planned financial, legal or other relationship with any external entity facilitating DSC issuance. 4. Check only CA trusted persons/ Verification Officers approves and certify each account information including name timestamp etc. using their own digital signature 5. Check CA has sufficient Verification Officers by gauging the max. approval done in a day corresponding to the number of Verification Officer involved. 6. Submit the List of trusted personnel of CA to CCA.					
Special purpose certificates							
3.4.11.61	Apart from the details required for creation of eKYC account, the additional details shall be verified by CA in accordance with the type of special purpose certificate.	1. Validate, apart from the details required for creation of eKYC account, the additional details is verified by CA in accordance with the type of special purpose certificate. 2. Validate that only organisational persons are allowed to apply for special purpose certificate	Mandatory	IVG Sect.1.19			
3.4.11.62	Only organisational persons are allowed to apply for special purpose certificate.	1. Validate, apart from the details required for creation of eKYC account, the additional details is verified by CA in accordance with the type of special purpose certificate. 2. Validate that only organisational persons are allowed to apply for special purpose certificate	Mandatory	IVG Sect.1.19			
Encryption Certificate							
3.4.11.63	For encryption certificates, CA shall provide key escrow facility, where key pair is securely stored and managed by CA. The key shall be retrievable again by the DSC applicant at any point of time, even after expiry of the certificate. This shall be retained by CA for minimum of 7 years from the expiry of the certificate. CA shall allow the download of the escrowed key only after a successful video verification of the applicant.	1. Check for encryption certificates, CA provides key escrow facility, where key pair is securely stored and managed . 2. Check the key is retrievable again by the DSC applicant at any point of time, even after expiry of the certificate. 3. Check escrowed key is retained by CA for minimum of 7 years from the expiry of the certificate from Jan 01, 2021 onwards. 4. Check CA allows the download of the escrowed key only after a successful video verification of the applicant. 5. Validate CA allows subscriber to download encryption keys and certificates for preservation, also.	Mandatory	IVG Sect.1.20			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.4.11.64	The encryption keys and certificates shall be preserved by subscriber also.	1. Check for encryption certificates, CA provides key escrow facility, where key pair is securely stored and managed . 2. Check the key is retrievable again by the DSC applicant at any point of time, even after expiry of the certificate. 3. Check escrowed key is retained by CA for minimum of 7 years from the expiry of the certificate from Jan 01, 2021 onwards. 4. Check CA allows the download of the escrowed key only after a successful video verification of the applicant. 5. Validate CA allows subscriber to download encryption keys and certificates for preservation, also.	Mandatory	IVG Sect.1.20			
First factor Authentication							
3.4.11.65	The first factor authentication to eKYC account shall be PIN	1. Validate first factor authentication to eKYC account is PIN	Not Applicable				
Second factor Authentication							
3.4.11.66	The second factor authentication can be SMS-OTP or the other authentication mode specified in the eSign API	1. Validate second factor authentication is SMS-OTP or the other authentication mode specified in the eSign API 2. Validate eKYC account is activated using PIN and OTP only.	Mandatory	IVG Sect.1.21			
3.4.11.67	The eKYC account shall be activated using PIN and OTP. Subsequently other authentication can be used in place of OTP however OTP shall be retained as a fallback option.	1. Validate second factor authentication is SMS-OTP or the other authentication mode specified in the eSign API 2. Validate eKYC account is activated using PIN and OTP only.	Mandatory	IVG Sect.1.21			
SMS-OTP							
3.4.11.68	CA shall always send OTP to eKYC account holder with PURPOSE relevant to the authentication seeking for. OTP should be a newly generated random number for each transaction.	1. Validate CA always send OTP to eKYC account holder with PURPOSE relevant to the authentication seeking for 2. Verify whether the OTP is a newly generated random number for each transaction. 3. Validate OTP is sent only to the verified mobile number registered in the eKYC account.	Mandatory	IVG Sect.1.23			
3.4.11.69	OTP shall be sent only to the verified mobile number registered in the eKYC account.	1. Validate CA always send OTP to eKYC account holder with PURPOSE relevant to the authentication seeking for 2. Verify whether the OTP is a newly generated random number for each transaction. 3. Validate OTP is sent only to the verified mobile number registered in the eKYC account.	Mandatory	IVG Sect.1.23			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

Registration Authorities(RAs							
3.4.11.70	The role of RA is strictly restricted as a business partner. For business-related accounting purposes, the reference code of RA may be included in the DSC applicant's interface.	1. Verify whether CA software has any interface to RA.	Mandatory	IVG Sect.1.24			
Additional Physical verification							
3.4.11.71	The additional physical verification of DSC applicant is optional, however if opted the OID 2.16.356.100.10.2 shall be mentioned in the policy id field of certificate.	1. Verify whether CA has provided option for DSC applicant to opt for additional physical verification? 2. Check the list of authorised person employed by the CA and the mode of employment. 3. Inspect the proof of physical verification carried out by the authorised person	Mandatory	IVG Sect.1.25			
3.4.11.72	For highest level of assurance, in addition to all the requirements mentioned in this document, an authorised person employed by the CA shall verify the physical presence of DSC applicant and also verify the genuineness of all the documents submitted.	1. Verify whether CA has provided option for DSC applicant to opt for additional physical verification? 2. Check the list of authorised person employed by the CA and the mode of employment. 3. Inspect the proof of physical verification carried out by the authorised person	Mandatory	IVG Sect.1.25			
3.4.11.73	The authorised person employed by the CA shall also verify the possession and proof of registration of the mobile number, address proof, identity, ink signature verification, neighborhood enquiry etc. or any additional requirements to eliminate the possibility of impersonation.	1. Verify whether CA has provided option for DSC applicant to opt for additional physical verification? 2. Check the list of authorised person employed by the CA and the mode of employment. 3. Inspect the proof of physical verification carried out by the authorised person	Not Applicable				

3.4.12. Guidelines for maintaining eKYC account by CA

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Authentication for eKYC Account							
3.4.12.1	CA to verify the applicant one time and issue DSC subsequently based on 2-factor authentication by applicant. The two factor authentication	Conduct a walkthrough of the eKYC facility and check the following: 1. CA verifies the applicant and issued DSC based on 2-factor authentication by applicant 2. The two factor authentication includes the PIN set by the applicant and a second	Mandatory	Identity Verification Guidelines (IVG) Section 2.1			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	includes the PIN set by the applicant and a second factor, as permitted by the guidelines issued by CCA. (Eg: OTP sent to the verified mobile)	factor, as permitted by the guidelines issued by CCA. (Eg: OTP sent to the verified mobile) 3. Subscriber sets the PIN and UserID as mentioned in control 3.5.6.2					
3.4.12.2	As a part of KYC, before activation, subscriber shall set PIN and "user ID" a) The eSign Address is in the form "@.". b) The ESP-ids are eMudhra, nCode, CDAC, Capricorn, NSDLeGov etc. id-types are mobile number, PAN and username. c) To ensure ease of use by subscribers, it is recommended that CA shall keep user name limited to few characters. d) CA shall ensure username is unique within their system. For Personal eKYC accounts, the mobile number and PAN shall be unique.	null	Mandatory	IVG Sect. 2.1			
Aadhaar e KYC							
3.4.12.3	These guidelines are intended to be used to create eKYC account who have Aadhaar Number registered in UIDAI Database.	Check the following: 1. CA obtained approval of CCA for Online Aadhaar eKYC 2. Specify any major non-compliance in the audit period w.r.t UIDAI requirements	Mandatory	IVG Sect. 2.2			
3.4.12.4	CAs are required to follow the requirements specified by UIDAI strictly for eKYC authentication of DSC applicant	Check the following: 1. CA obtained approval of CCA for Online Aadhaar eKYC 2. Specify any major non-compliance in the audit period w.r.t UIDAI requirements	Mandatory	IVG Sect. 2.2			
3.4.12.5	As part of the e-KYC process prescribed by UIDAI under Aadhaar Act, the applicant for DSC authorizes CA (through Aadhaar eKYC) to obtain their demographic data along with his/her photograph (digitally signed and encrypted) to CAs for verification.	Check the following: 1. CA obtained approval of CCA for Online Aadhaar eKYC 2. Specify any major non-compliance in the audit period w.r.t UIDAI requirements	Mandatory	IVG Sect. 2.2			
Aadhaar online eKYC							

CCA AUDIT REPORT

3.4.12.6	This section is allowed as per the OM(File No. 13(6)/2018-EG- II(Pt)), dated 18 Jan 2022 , to use Aadhaar e-KYC authentication by Certifying Authorities under the CCA for issue of Digital Signature Certificate (DSC) under Section 3A of the IT Act along with the e-signature also in compliance with Section 4(4)(b)(i) of the Aadhaar Act, 2016 as amended.	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant	Mandatory	IVG Sect. 2.2.1			
3.4.12.7	CA shall be an authorized e-KYC User Agency (KUA) of Unique Identification Authority of India (UIDAI).	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.4.12.8	In the case of online Aadhaar Biometric/OTP-based eKYC account enrollment, in addition to the UIDAI requirements a) CA shall ensure that the applicant is already authenticated and started a session as per 1.3(3). b) CA shall start a new session and redirect the	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

	user to the dedicated CA interface page for capturing authentication information. (Aadhaar no, Biometric or OTP, consent, etc) . c) For each eKYC request to UIDAI, CA should implement validations at the server side which shall include parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. d) Only one Aadhaar authentication shall be processed per one session and session time shall be limited to 10 minutes. e) The Aadhaar Number shall not be displayed on the user interface. Only the Name, Last four digits of the Aadhaar and photo shall be displayed to the DSC applicants. f) CA shall look for any external sites linking to them in an unauthorized manner and consuming the purpose by spoofing or scraping the CA website/application. CA shall ensure that they use captcha implementation or similar security to avoid automated attacks and ensure only a human is doing the process on CA enrolment application steps. The request for Aadhaar authentication shall only be accepted directly from the CA-controlled application.	person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.4.12.9	Up on receipt of Aadhaar eKYC XML from UIDAI, CA	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference.	Mandatory	IVG Sect. 2.2.1			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	decrypts, validates UIDAI signature, reads and extracts demographic data, and photo.	2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.4.12.10	The verified information received through online Aadhaar e- KYC shall be used for creation eKYC account of user.	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.4.12.11	The DSC application form should be generated by populating the information received from UIDAI.	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.4.12.12	The application should be signed by DSC applicant. The verified information received through e-KYC services can be used for obtaining eSign of DSC applicant by CA through a separate user eKYC authentication.	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.4.12.13	If PAN of the applicant is to be included in eKYC account for embedding it in the certificate, CA shall verify the same prior to inclusion in the eKYC account.	Check the following: 1. CA maintained a copy of OM and it is available to employees for reference. 2. Verify the proof of e-KYC User Agency (KUA) 3. Check all the interface(s) provided by CA for key-in Aadhaar number /VID/OTP etc and verify it is direct or not. 4. Verify & confirm that CA has not provided any option to subscriber for changing the information received through Aadhaar eKYC 5. Check only the already authenticated person can perform aadhaar authentication. 6. Verify the implementation in respect of Session and re-direction of page for accessing CA interface page to capture the authentication information. 7. Verify the validation of the CA interface page to capture the authentication information includes parent page validation, CA OTP, captcha and session validation prior to submitting the request to UIDAI. 8. Check CA software allow more than one authentication in a single session. 9. Verify the display interface to user and check that only the Name, Last four	Mandatory	IVG Sect. 2.2.1			

CCA AUDIT REPORT

		digits of the Aadhaar and photo is displayed 10. Verify the webpage security parameters 11. Validate the verified information received through online Aadhaar e-KYC is used for creation eKYC account of user. 12. Validate the DSC application form is generated by populating the information received from UIDAI. 13. Verify that a separate authentication is obtained for eSign on the DSC application form(two authentication is mandatory. One for obtaining eKYC data from UIDAI and other for affixing signature of applicant on the application form) 14. Validate CA store the unique UID Token of Aadhaar holder against such eKYC Account. 15. Verify & confirm that email is captured and verified and included in the eKYC account. 16. Validate that CA l allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant					
3.4.12.14	On successful Aadhaar eKYC Authentication for the eKYC Account, CA shall store the unique UID Token for that Aadhaar holder against such eKYC Account. This shall be used for referring to same user during any re-verification requirements.	null	Mandatory	IVG Sect. 2.2.1			
3.4.12.15	For DSC issuance, email shall be included in the eKYC account after verification by CA	null	Mandatory	IVG Sect. 2.2.1			
3.4.12.16	CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	null	Mandatory	IVG Sect. 2.2.1			
3.4.12.17	Subscriber sets up initial PIN and user ID.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC	Mandatory	IVG Sect. 2.2.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.					
Aadhaar online eKYC – OTP							
3.4.12.18	Subscriber submits Aadhaar Number and performs provides OTP authentication through the interface provided by CA to UIDAI.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC -OTP 1. Subscriber submits Aadhaar Number OTP only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber,." 3. CA performs interactive video verification (Annexure VI) and also perform a photo match of Aadhaar eKYC photo with the video.. 4. For each DSC issuance, CA check the video verification/Biometric carried out is not older than 2 days.	Mandatory	IVG Sect. 2.2.1.1			
3.4.12.19	Up on Successful authentication, CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC -OTP 1. Subscriber submits Aadhaar Number OTP only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber,." 3. CA performs interactive video verification (Annexure VI) and also perform a photo match of Aadhaar eKYC photo with the video.. 4. For each DSC issuance, CA check the video verification/Biometric carried out is not older than 2 days.	Mandatory	IVG Sect. 2.2.1.1			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.4.12.20	The mobile number is mandatory. CA shall capture the mobile number of the user and carryout verification of Mobile Number.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC -OTP 1. Subscriber submits Aadhaar Number OTP only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber,." 3. CA performs interactive video verification (Annexure VI) and also perform a photo match of Aadhaar eKYC photo with the video.. 4. For each DSC issuance, CA check the video verification/Biometric carried out is not older than 2 days.	Mandatory	IVG Sect. 2.2.1.1			
3.4.12.21	CA does interactive video verification (Annexure VI) and also does a photo match of Aadhaar eKYC photo with the video.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC -OTP 1. Subscriber submits Aadhaar Number OTP only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber,." 3. CA performs interactive video verification (Annexure VI) and also perform a photo match of Aadhaar eKYC photo with the video.. 4. For each DSC issuance, CA check the video verification/Biometric carried out is not older than 2 days.	Mandatory	IVG Sect. 2.2.1.1			
3.4.12.22	For each DSC issuance, video verification shall have been carried out within last 2 days. The in-person verification can also be substituted by Aadhaar Biometric Authentication.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC -OTP 1. Subscriber submits Aadhaar Number OTP only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber,." 3. CA performs interactive video verification (Annexure VI) and also perform a photo match of Aadhaar eKYC photo with the video.. 4. For each DSC issuance, CA check the video verification/Biometric carried out is not older than 2 days.	Mandatory	IVG Sect. 2.2.1.1			
Aadhaar online eKYC – Biometric							
3.4.12.23	Subscriber submits Aadhaar Number and performs biometric authentication through the interface provided by CA to UIDAI.	Conduct walkthrough to check the following steps are performed for Aadhaar online eKYC	Mandatory	IVG Sect. 2.2.1.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.4.12.24	Up on successful authentication, CA receives Aadhaar e-KYC XML and creates e-KYC account for applicant.	-Biometric 1. Subscriber submits Aadhaar Number and perform Biometric only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber. 3. CA captures the mobile number of the applicant and carryout verification of Mobile Number. 4. For each DSC issuance, CA check the Biometric authentication carried out is not older than 2 days. 5. CA verifies the matching face in CA eKYC record/ photo submitted by applicant with face in Aadhaar Photo of the same applicant...	Mandatory	IVG Sect. 2.2.1.2			
3.4.12.25	The mobile number is mandatory. CA shall capture the mobile number of the applicant and carryout verification of Mobile Number.	-Biometric 1. Subscriber submits Aadhaar Number and perform Biometric only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber. 3. CA captures the mobile number of the applicant and carryout verification of Mobile Number. 4. For each DSC issuance, CA check the Biometric authentication carried out is not older than 2 days. 5. CA verifies the matching face in CA eKYC record/ photo submitted by applicant with face in Aadhaar Photo of the same applicant...	Mandatory	IVG Sect. 2.2.1.2			
3.4.12.26	For each DSC issuance, Aadhaar eKYC Biometric authentication of applicant shall have carried out within last 2 days and CA should accept only if the face in Aadhaar Photo matches against that in CA eKYC record of same applicant. The in-person verification can also be substituted by interactive video verification (Annexure VI) provided that CA should successfully verifies the matching face in video with the photograph of eKYC record of the same applicant.	-Biometric 1. Subscriber submits Aadhaar Number and perform Biometric only through the interface provided by CA 2. CA receive Aadhaar e-KYC XML and create e-KYC account for the applicant op on successful authentication by subscriber. 3. CA captures the mobile number of the applicant and carryout verification of Mobile Number. 4. For each DSC issuance, CA check the Biometric authentication carried out is not older than 2 days. 5. CA verifies the matching face in CA eKYC record/ photo submitted by applicant with face in Aadhaar Photo of the same applicant...	Mandatory	IVG Sect. 2.2.1.2			
Aadhaar offline eKYC							

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.4.12.27	Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" which is used to encrypt the offline KYC XML.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	Mandatory	IVG Sect. 2.2.2			
3.4.12.28	CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed	Mandatory	IVG Sect. 2.2.2			

CCA AUDIT REPORT

		subscriber agreement with eKYC applicant.					
3.4.12.29	CA shall accept the mobile number within offline KYC only, no changes are allowed.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	Mandatory	IVG Sect. 2.2.2			
3.4.12.30	For issuance of DSC, CA captures email for communications, alerts, and PIN reset options and it must be verified.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been	Mandatory	IVG Sect. 2.2.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.					
3.4.12.31	If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, CA shall verify the same prior to inclusion in the eKYC account.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	Mandatory	IVG Sect. 2.2.2			
3.4.12.32	CA does interactive video verification (Annexure VI) and also does a photo match of Aadhaar eKYC photo with the video.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID.	Mandatory	IVG Sect. 2.2.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.					
3.4.12.33	For each DSC issuance, video verification shall have carried out within last 2 days	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	Mandatory	IVG Sect. 2.2.2			
3.4.12.34	CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	Conduct walkthrough to check the following steps are performed for Aadhaar offline eKYC 1. Subscriber uploads eKYC XML within CA app/website and provides the "share code/phrase" 2. CA decrypts XML, validates UIDAI signature, reads the Aadhaar eKYC XML, and extracts demographic data, mobile number (when available), and photo. 3. CA uses the mobile number within offline KYC 4. CA captures email for communications, alerts, and PIN reset options. If CA captures email, it must be verified by sending an OTP to email. 5. If PAN of the applicant is to be included in eKYC account for embedding it into the certificate, check	Mandatory	IVG Sect. 2.2.2			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		CA verifies the same prior to inclusion in the eKYC account. 6. Subscriber sets up initial PIN and user ID. 7. CA does interactive video verification as per IVG and also does a photo match of Aadhaar eKYC photo with the video 8. Verify video verification has been carried out by CA within last 2 days of DSC issuance 9. CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.					
Organisational KYC for Organisational Person Certificates							
3.4.12.35	For organisational person certificate, the Organization Name (O Value) in the certificate shall match the organization name and also in compliance with naming convention specified CCAIOG	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA.	Mandatory	IVG Sect. 2.3			

CCA IT AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.4.12.36	The minimum requirements for Issuance of DSC to organisation person include: a) eKYC account of Applicant b) Applicant ID Proof or Proof of individuals association with organisation c) Letter of Authorization by Organization to Authorized Signatory for self authorisation and also to other DSC applicants. d) eKYC account of Authorized Signatory and authorization to DSC applicant e) Proof of existence of organization	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only,	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.4.12.37	CA shall carry out the verification of the existence of organization & authorised signatory of the organization as per IVG. All the information submitted by eKYC applicant for eKYC account shall be digitally signed by authorised signatory.	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.4.12.38	The criteria for the eligibility of government organisation and its authorised signatory are given in the annexure V of IVG	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance	Not Applicable				
3.4.12.39	KYC of organisational eKYC applicant shall be submitted to CA and CA carryout the verification.	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG	Mandatory	IVG Sect. 2.3			

CCA India AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.4.12.40	The eKYC account request shall include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. Them mobile number and PAN of the applicants are mandatory. The copy of the organisational ID card and PAN shall also be submitted to CA	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.4.12.41	CA shall carry out interactive video verification as per Annexure VI and shall verify the photo match of eKYC photo with the video. The original document verification is also a part of video verification. The in-person verification can also be substituted by Aadhaar eKYC Biometric Authentication provided that CA successfully verifies the face in Aadhaar Photo against	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory.	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	that in KYC record.	5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.4.12.42	CA activates eKYC account after mobile, email and PAN verification. CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification.	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.4.12.43	CA shall provide Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA.	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.4.12.44	In case of any change in account holder's status or information, the request for change shall be submitted with the authorization of authorised signatory.	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.4.12.45	CA shall accept the mobile number within Organisational KYC only, no changes are allowed.	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account	Mandatory	IVG Sect. 2.3			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
3.4.12.46	For DSC issuance, the video verification shall have carried out within last 2 days	1. Validate for organisation person certificate, Organization Name (O Value) in the certificate matches the organization name and also in compliance with naming convention specified CCAIOG 2. Validate minimum requirements for issuance of DSC by CA to organization person is as per control 3.5.6.13 3. Verify on sample basis CA carries out verification of the existence of organization & authorized signatory of the organization as per IVG. 4. Validate all the information submitted by eKYC applicant for eKYC account has to be digitally signed by authorized signatory. 5. Check CA follows criteria for the eligibility of government organisation and its authorised signatory as per IVG 6. KYC of organisational eKYCapplicant has been submitted to CA and CA has carried out the verification. 7. Check eKYC account request include Name, Office address, photo, PAN, mobile no, Organisational ID, email etc. 8. Validate mobile number and PAN of the applicants are mandatory. 9. Validate copy of the organisational ID card and PAN to be provided to CA. 10. Check CA carry out interactive video verification as per Annexure VI of IVG and verifies the photo match of eKYC photo with the video. 11. Check the face in Aadhaar Photo against that in KYC record is verified by CA in the case of online Aadhaar eKYC Biometric Authentication 12. Check CA does original document verification as part of video verification. 13. Check CA activates eKYC account after mobile, email and PAN verification 14. Check CA allows the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 15. Check CA provides Organizational	Mandatory	IVG Sect. 2.3			

CCA IS AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		eKYC applicant to set up PIN and user ID upon the authentication by CA. 16. Validate the request for change in account holder's status or information accepted by CA is with the authorization of authorised signatory. 17. Validate CA accepts the mobile number within Organisational KYC only, no changes are allowed. 18. Verify video verification has been carried out by CA within last 2 days of DSC issuance					
Verification of Authorised Signatory							
3.4.12.47	The scanned copy of the documents for existence of organization & authorization to authorized signatories as per Annexure I of IVG shall be submitted to CA and the originals shall be verified during video verification.	For verification of authorised signatory check the following: 1. CA accepts the scanned copy of the documents for existence of organization & authorization to authorized signatories as per IVG and verifies the originals during video verification. 2. The verification of authorised signatory is followed as per steps 4-7 of 2.3.1 of IVG 3. The proof of verification for the following are maintained by CA - Secondary verification like face-to-face interaction/web site reference/ call to organizational telephone numbers to confirm the organizational identity of authorised person. 4. Validate CA creates eKYC account after successful confirmation of organization identity of authorized person and DSC/eKYCaccount of authorized signatory has been mapped with the name of the verified organisation. 5. The certificate to authorised signatory is asserted with OID 2.16.356.100.10.3. 6. Validate CA verifies information on MCA website in case the company is a single director company with no other authorized signatories, or a proprietorship organization.	Mandatory	IVG Sect. 2.3.1			
3.4.12.48	The steps 4-7 of 2.3 shall be followed for the verification prior to the eKYC account creation.	For verification of authorised signatory check the following: 1. CA accepts the scanned copy of the documents for existence of organization & authorization to authorized signatories as per IVG and verifies the originals during video verification. 2. The verification of authorised signatory is followed as per steps 4-7 of 2.3.1 of IVG 3. The proof of verification for the following are maintained by CA - Secondary verification like face-to-face interaction/web site reference/ call to organizational telephone numbers to confirm the organizational identity of authorised person. 4. Validate CA creates eKYC account after successful confirmation of	Not Applicable				

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		organization identity of authorized person and DSC/eKYCaccount of authorized signatory has been mapped with the name of the verified organisation. 5. The certificate to authorised signatory is asserted with OID 2.16.356.100.10.3. 6. Validate CA verifies information on MCA website in case the company is a single director company with no other authorized signatories, or a proprietorship organization.					
3.4.12.49	CA shall also carryout secondary verification like face-to-face interaction/web site reference/call to organizational telephone numbers to confirm the organizational identity of authorised person and the proof of the verification shall be maintained.	For verification of authorised signatory check the following: 1. CA accepts the scanned copy of the documents for existence of organization & authorization to authorized signatories as per IVG and verifies the originals during video verification. 2. The verification of authorised signatory is followed as per steps 4-7 of 2.3.1 of IVG 3. The proof of verification for the following are maintained by CA - Secondary verification like face-to-face interaction/web site reference/ call to organizational telephone numbers to confirm the organizational identity of authorised person. 4. Validate CA creates eKYC account after successful confirmation of organization identity of authorized person and DSC/eKYCaccount of authorized signatory has been mapped with the name of the verified organisation. 5. The certificate to authorised signatory is asserted with OID 2.16.356.100.10.3. 6. Validate CA verifies information on MCA website in case the company is a single director company with no other authorized signatories, or a proprietorship organization.	Mandatory	IVG Sect. 2.3.1			
3.4.12.50	Upon successful confirmation of organizational identity of authorised person, CA shall create an eKYC account and may issue DSC to authorised signatory. The DSC/eKYC Account of the authorized signatory shall be registered with CA and shall be mapped with the name of the verified organisation. Subsequently all the information submitted by eKYC applicant for eKYC account shall be digitally signed by authorised signatory.	For verification of authorised signatory check the following: 1. CA accepts the scanned copy of the documents for existence of organization & authorization to authorized signatories as per IVG and verifies the originals during video verification. 2. The verification of authorised signatory is followed as per steps 4-7 of 2.3.1 of IVG 3. The proof of verification for the following are maintained by CA - Secondary verification like face-to-face interaction/web site reference/ call to organizational telephone numbers to confirm the organizational identity of authorised person. 4. Validate CA creates eKYC account after successful confirmation of organization identity of authorized person and DSC/eKYCaccount of	Mandatory	IVG Sect. 2.3.1			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	The DSC of the authorised signatory shall be asserted with OID 2.16.356.100.10.3 in the policy id field along with policy id for class of certificate	authorized signatory has been mapped with the name of the verified organisation. 5. The certificate to authorised signatory is asserted with OID 2.16.356.100.10.3. 6. Validate CA verifies information on MCA website in case the company is a single director company with no other authorized signatories, or a proprietorship organization.					
3.4.12.51	In case the company is a single director company with no other authorized signatories, or a proprietorship organization, it can be considered for self-authorization, provided that Information is verified in MCA website. In case of proprietorship organization where applicant himself/herself is the proprietorship, self authorization / no authorization is required.	For verification of authorised signatory check the following: 1. CA accepts the scanned copy of the documents for existence of organization & authorization to authorized signatories as per IVG and verifies the originals during video verification. 2. The verification of authorised signatory is followed as per steps 4-7 of 2.3.1 of IVG 3. The proof of verification for the following are maintained by CA - Secondary verification like face-to-face interaction/web site reference/ call to organizational telephone numbers to confirm the organizational identity of authorised person. 4. Validate CA creates eKYC account after successful confirmation of organization identity of authorized person and DSC/eKYCaccount of authorized signatory has been mapped with the name of the verified organisation. 5. The certificate to authorised signatory is asserted with OID 2.16.356.100.10.3. 6. Validate CA verifies information on MCA website in case the company is a single director company with no other authorized signatories, or a proprietorship organization.	Mandatory	IVG Sect. 2.3.1			
Banking eKYC for Banking Customers							
3.4.12.52	This section is applicable only for persons having Banking account and Banks submit the KYC of the Banking Customer to CA directly after obtaining consent and authentication from the customer. The video verification is not mandatory.	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.4.12.53	CA shall verify the source of the request and signature of bank prior to accept KYC information	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.	Mandatory	IVG Sect. 2.4			
3.4.12.54	CA shall have an agreement/undertaking with Bank.	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

		4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.4.12.55	CA shall carry out verification of existence of Bank, authorised signatory's identity as mentioned in Annexure I of the Identity Verification guidelines	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.4.12.56	The DSC to be used for signature by bank shall be registered with CA and shall be mapped with the bank ID/Name	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.	Mandatory	IVG Sect. 2.4			
3.4.12.57	The KYC details shall include Name, address, photo, PAN/Aadhaar Number, mobile no, Bank account No, Bank IFSC code (if applicable).	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

		PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.4.12.58	The mobile number and PAN/Aadhaar Number(last four digit) of the applicants are mandatory	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.	Mandatory	IVG Sect. 2.4			
3.4.12.59	CA shall allow eKYC applicant to set up PIN and user ID up on the authentication by CA	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.4.12.60	CA activates eKYC account after mobile verification. CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant.	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

		12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.4.12.61	If email is not present in the KYC provided by Bank, the same can be captured by CA and shall accept only after verification.	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.	Mandatory	IVG Sect. 2.4			
3.4.12.62	CA shall accept the mobile number within bank KYC only, no changes are allowed	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory	Mandatory	IVG Sect. 2.4			

CCA AUDIT REPORT

		8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.					
3.4.12.63	For each DSC issuance, CA shall have received KYC of the account holder from the Bank within last 24 hours.	1. For banking eKYC for banking customers check the following: 2. CA verifies the source of request and signature of bank prior to accepting KYC information 3. CA has an agreement/undertaking with Bank 4. CA carries out verification of existence of Bank , authorized signatory's identity as mentioned the Identity Verification guidelines 5. DSC used for signature by bank is registered with CA and mapped with the bank ID/Name 6. KYC details should include Name, address, photo, PAN, mobile no, Bank account No, Bank IFSC code. 7. mobile number and PAN of the applicants are mandatory 8. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA 9. CA activates eKYC account after mobile verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement with eKYC applicant. 11. If email is not present in the KYC provided by Bank, the same is captured by CA and accepted only after verification 12. CA accepts the mobile number within bank KYC only, no changes are allowed 13. Verify CA received KYC of the account holder from the Bank within last 24 hours for DSC issuance.	Mandatory	IVG Sect. 2.4			
PAN eKYC for Personal Certificates							
3.4.12.64	This section is applicable only for persons who submit the	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the	Mandatory	IVG Sect. 2.5			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	PAN & other KYC information to CA directly. The mobile number, PAN of the applicant and Government ID having address (Annexure IV) are mandatory. The scanned copy of the PAN card and Government ID having address shall be submitted to CA	mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
3.4.12.65	CA shall carryout verification of Mobile Number and PAN(eKYC).	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form.	Mandatory	IVG Sect. 2.5			

CCA IT AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
3.4.12.66	The mobile number should be registered in the name of the eKYC applicant and the same shall be verified by CA through the services provided by Telecom companies. Or CA should use the banking penny drop process to cross verify (exact or reasonable match) the name of the DSC applicant with the name registered in the bank account. The proof of the verification shall be preserved.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification.	Not Applicable				

CCA AUDIT REPORT

		10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
3.4.12.67	The video verification of the applicant shall be carried out by CA as per Annexure VI of IVG. During the video verification, the applicant shall display original PAN card and Government ID having address for cross verification by CA. Both the PAN details and address in the Id captured in the video shall be in a clear and readable form.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.	Mandatory	IVG Sect. 2.5			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.4.12.68	CA shall electronically verify the PAN number with Income tax database through eKYC service and accept only if the name is matching correctly. The digitally signed proof of the verified response shall be preserved by CA.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.	Mandatory	IVG Sect. 2.5			
3.4.12.69	CA shall verify the Government ID having address submitted to CA against the original displayed during the video verification.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG.	Mandatory	IVG Sect. 2.5			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
3.4.12.70	The eKYC account request shall include Name (as in PAN), residential address (as in address id), photo, PAN, mobile no, email etc.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and	Mandatory	IVG Sect. 2.5			

CCA AUDIT REPORT

		residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
3.4.12.71	CA activates eKYC account after mobile, email, PAN and video verification. CA shall allow the usage of eKYC service only after having a digitally signed subscriber agreement with the eKYC applicant.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been	Mandatory	IVG Sect. 2.5			

CCA AUDIT REPORT

		carried out by CA within last 2 days of DSC issuance.					
3.4.12.72	In case of any change in account holder's information after activation of account, CA shall carry out fresh enrollment.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.	Mandatory	IVG Sect. 2.5			
3.4.12.73	CA shall allow eKYC applicant to set up PIN and user ID up on the authentication by CA.	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the	Mandatory	IVG Sect. 2.5			

CCA AUDIT REPORT

		banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
3.4.12.74	For DSC issuance, video verification shall have carried out within last 2 days	For PAN eKYC for customer, check the following: 1. The subscriber has submitted the mobile number, PAN and One Government ID with address. 2. CA carries out the verification of Mobile Number and PAN (eKYC) 3. Verify that the mobile number is registered in the name of applicant using sevices provided by the telecom companies. 4. Verify the name of applicant in the banking records using penny drop process 5. CA carries out video verification of applicant as per Annexure VI of IVG. The original PAN and Government ID having address displayed during video verification in a clear readable form. 6. CA verifies the PAN Number of the applicant through the electronic service provided by Income Tax. CA also verifies the name submitted by applicant is matching with the name in the response received from Income Tax. Also the proof of verification is archived. 7. CA verifies the Government ID having	Mandatory	IVG Sect. 2.5			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		address submitted to CA against the original displayed during the video verification. 8. CA accept only name as in PAN and residential address as in address proof 9. CA activates eKYC account after video, mobile, email and PAN verification. 10. CA allows usage of eKYC service only after having a digitally signed subscriber agreement obtained from eKYC applicant. 11. CA carries out fresh enrollment process to accept any change in account holder's information after activation of account. 12. CA allows eKYC applicant to set up PIN and user ID up on the authentication by CA. 10. Verify video verification has been carried out by CA within last 2 days of DSC issuance.					
eKYC for foreign applicants							
3.4.12.75	This section is applicable only for foreign applicants who submit the KYC information to CA directly. An applicant is deemed as foreign applicant if the address (residential or organizational) provided in the DSC application form does not belong to India or identity document submitted is not issued by authorities under Government of India.	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant.	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

		4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.4.12.76	For all categories of applicants, email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address are required to be submitted to CA.	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and	Mandatory	IVG Sect. 2.6			

CCA - AUDIT REPORT

		video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.4.12.77	For organisational person certificate, a) Scanned copy of Organisational id, Organisational email id, mobile number, Organisational address and letter of authorization from organisation are required. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry shall be provided. c) If the organisation is already registered/empanelled in government organizations of India, then the scanned copy of the letter of request issued from Indian government organisation with the details of DSC applicant can be accepted as address proof/existence of organisation for DSC issuance.	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.4.12.78	For Personal certificate, a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport can be submitted. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address can be provided	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.4.12.79	The video verification shall be carried out by CA as per Annexure VI of IVG. All the originals shall be verified during the video verification. The telephonic verification shall be carried out by direct call to the applicant or SMS OTP verification and the proof of verification shall be recorded. Email shall also be verified by CA.	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.4.12.80	For telephonic verification, CA can also verify over telephonic call, where CA originates to or receives the call from the mobile number under verification, and validates the number holder with at least 2 questions establishing relation to DSC application	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.	Mandatory	IVG Sect. 2.6			
3.4.12.81	CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA shall	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	allow the usage of eKYC service only after having a digitally signed subscriber agreement with the eKYC applicant.	copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.4.12.82	In case of any change in account holder's information after activation of account, CA shall carry out a fresh enrollment.	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.4.12.83	CA shall allow eKYC applicant to set up PIN and user ID up on the authentication by CA. Except in the case of mobile number verification, OTP can be sent to the email of the eKYC user.	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					
3.4.12.84	During the validity period of eKYC account, a fresh video verification shall have carried out for each DSC issuance within last 2 days	For eKYC for foreign applicants, check the following 1) The eKYC applicant has submitted email id, mobile number, photo, scanned copy of proof of identity and scanned copy of proof of address. 2) For organisational person certificate, a) Scanned copy of organisational id, organisational email id, organisational phone number, organisational address and letter of authorization from organisation are submitted. b) For the proof of organisational existence, publically verifiable and listed/recognized by local government reference of organisation in database/registry have been submitted by the applicant. c) the ekYC account created based on the receipt of letter of request issued from	Mandatory	IVG Sect. 2.6			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		Indian government organisation satisfy the following - The organisation is already registered/empanelled in government organizations of India, - The organizations submit the details of DSC applicant and address proof/existence of organisation. 3) For Personal certificate a) For identity proof, the scanned copy of Passport/Local Govt issued identity/PAN/OCI passport is received from DSC applicant. b) For the address proof the scanned copy of passport/OCI passport/local government issued id having address/bank details having address/any utility bills in the name of applicant issued within three months/ document issued from embassy with residential address is provided by the applicant. 4) CA carries out the video verification, document verification, telephonic verification and email verification. 5) CA activates eKYC account after mobile, email, PAN (if submitted) and video verification. CA obtains a digitally signed subscriber agreement from eKYC applicant. 6) The change in account holder's information after activation of account is not carried out by CA instead CA carry out a fresh enrollment. 7) A fresh video verification is carries out before each DSC issuance during the validity period of eKYC account. Such video verification for DSC issuance is valid for 2 days.					

3.4.13. Guidelines for issuance of special purpose DSC

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
SSL Certificate							
3.4.13.1	The issuances of SSL certificates by Licensed CAs are limited only to .IN domain.	For the issuances of SSL certificates by Licensed CAs, check the following :- The issuance of SSL certificates are only to .IN domain The applicants of SSL certificates are from organisation only The Applicant submit the following a. DSC Application Form b. Applicant ID Proof c. Authorization Letter by Organization Authorized Signatory d. Authorized Signatory Proof	Mandatory	IVG Sect.3.1			

CCA - AUDIT REPORT

		e. Proof of Organizational Existence					
3.4.13.2	Only organisational persons are eligible to apply for SSL certificates on behalf of their organizations.	For the issuances of SSL certificates by Licensed CAs, check the following :- The issuance of SSL certificates are only to .IN domain The applicants of SSL certificates are from organisation only The Applicant submit the following a. DSC Application Form b. Applicant ID Proof c. Authorization Letter by Organization Authorized Signatory d. Authorized Signatory Proof e. Proof of Organizational Existence	Mandatory	IVG Sect. 3.1			
3.4.13.3	The applicant (requestor) shall make an application to the CA in a digitally signed application form. This shall contain the domain name(s) to be certified, the Certificate Signing Request (CSR) and the information of the requestor and the organization. This shall be accompanied with necessary supporting documents. The minimum set of documents to be submitted includes: a. DSC Application Form b. Applicant ID Proof c. Authorization Letter by Organization Authorized Signatory d. Authorized Signatory Proof e. Proof of Organizational Existence	For the issuances of SSL certificates by Licensed CAs, check the following :- The issuance of SSL certificates are only to .IN domain The applicants of SSL certificates are from organisation only The Applicant submit the following a. DSC Application Form b. Applicant ID Proof c. Authorization Letter by Organization Authorized Signatory d. Authorized Signatory Proof e. Proof of Organizational Existence	Mandatory	IVG Sect. 3.1			
Domain Name Verification							
3.4.13.4	Each value provisioned for subject alternative names (dnsNames) shall undergo domain name verification to prove the ownership / control of the domain by the requestor of the certificate. This shall be accomplished by a) Validating the request by communication to: webmaster@domainname.com, administrator@domainname.com, admin@domainname.com,hostmaster@domainname.com, postmaster@domainname.com, or any email ID listed in the technical, registrant, or administrative contact field of the domain's Registrar record; OR b) Requiring a practical demonstration of domain control (Eg: making changes to DNS zone file or adding a unique file /	For domain verification check the following:- The emails with unique id send to email contain in technical, registrant, or administrative contact field of the domain's Registrar record and the receipt of confirmation Practical demonstration of domain control as mentioned in IVG	Mandatory	IVG Sect. 3.1			

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	filename on the domain under verification); This is achieved by CA sharing a unique Request Token or a Random Value, valid for a short duration, with the applicant and validating this data against the content of the file name provided or the DNS value (CNAME, TXT or CAA record) of the domain.						
3.4.13.5	In case of wildcard domains, these shall undergo additional checks, to not to wrongly issue, for a domain listed in public suffix list (PSL). If the domain is listed in PSL, the application shall be refused, unless applicant proves ownership of entire domain namespace.	Verify the additional verification in the case of wild card certificate as mentioned in IVG	Mandatory	IVG Sect. 3.1			
3.4.13.6	In case of IP Address, in place of domain name, it shall be verified to have the applicant's control over the IP, by means of (i) change in agreed information in an URL containing the IP address, OR (ii) IP assignment document of IANA or Regional Internet Registry, OR (iii) performing r-DNS lookup resulting in a domain name verified by above procedure.	Verify the procedure followed for applicant's control over the IP as mentioned in IVG	Mandatory	IVG Sect. 3.1			
Organization Person verification							
3.4.13.7	The verification of the identity & address of the applicant shall be made using, any one or more the following a) Identity of the applicant shall be verified by obtaining a legible copy of employment ID and PAN card which noticeably shows the Applicant's face. The copy of the document shall be inspected for any indication of alteration or falsification. A video verification as per the procedure mentioned in Identity Verification Guidelines should be carried out by CA to ascertain the photo match of applicant with the photo presented in the identity proof & DSC application form. The PAN number should be electronically verified with income tax database for matching of name as submitted in the DSC application form.	1. Check the verification procedure for identity & address of the applicant are followed as per IVG. 2. Examine audit trails of already issued certificates	Mandatory	IVG Sect. 3.1			
3.4.13.8	The applicant should submit an authorization letter from the authorized signatory of the organization stating the authorization to apply for SSL certificate. The letter should contain name, photo, designation and address of the applicant. CA may ask additional documents for the confirmation of applicant's affiliation to organization.	Check the procedure followed and audit trails of already issued certificates	Mandatory	IVG Sect. 3.1			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.4.13.9	CA should confirm that the applicant is able to receive communication to organisational telephone and email.	Check the procedure followed and audit trails of already issued certificates	Mandatory	IVG Sect. 3.1			
Organization Verification							
3.4.13.10	The organization verification includes authorization proof to applicant and existence of organization.	Verify the authorization proof to applicant and existence of organization in compliance with IVG	Mandatory	IVG Sect. 3.1			
3.4.13.11	Sufficient document evidence should be provided by the applicant for proof of authorized signatory	Check the procedure followed by CA meets the requirements	Mandatory	IVG Sect. 3.1			
3.4.13.12	Apart from the organizational person verification, the additional process documentation and authentication requirements for SSL certificate shall include the following: a) The organization owns the domain name, or the organization is given the exclusive right and authority to use the domain name b) Proof that the applicant has the authorization to apply for SSL certificate on behalf of the organization in the asserted capacity.(e.g. Authorization letter from organization to applicant) c) The documents/procedure required for proof of existence of organization are as per IVG	Verify the documents to check the compliance Check the documents/procedure required for proof of existence of organization are as per IVG	Mandatory	IVG Sect. 3.1			
Document Signer Certificate							
3.4.13.13	The applicant of Document Signer certificate should be an Organizational person of that Organization. The verification requirements for Document Signer Certificate shall be as per section 2.3 of IVG	1. Verify Document Signer Certificate is issued to an organizational person of the organization only and verification requirements as per section 2.3 of IVG has been followed for issuance of for Document Signer Certificate s. 2. Verify declaration mentioned in control 3.5.7.15 are obtained from subscribers.	Mandatory	IVG Sect. 3.2			
3.4.13.14	The following declarations should be obtained from subscriber in the Document Signer Certificate application form • I hereby declare and understand that Organizational Document Signer Certificate issued to us will be used only for automated signing of documents/information and will not be used in any other context including	1. Verify Document Signer Certificate is issued to an organizational person of the organization only and verification requirements as per section 2.3 of IVG has been followed for issuance of for Document Signer Certificate s.	Mandatory	IVG Sect. 3.2			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	individual signature. • I hereby declare that necessary controls have been built in software applications to ensure that there is no misuse • I hereby declare and understand that the documents/ messages authenticated using Organizational Document Signer Certificate issued to us is having organizational accountability.	2. Verify declaration mentioned in control 3.5.7.15 are obtained from subscribers.					

3.5. Extended Valid Certificate Controls

3.6. Online Certificate Status Protocol (OCSP) Controls

3.7. SSL Certificate Controls

3.8. E-Authentication Controls

3.8.1. Requirements for e-authentication using e-KYC Services

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Requirements for e-authentication using e-KYC Services							
3.8.1.1	eSign user should have unique id	1. Validate on a sample basis that each eSign user has an unique Id 2. Verify that the application service provider has gone through the approval process of ESP and has an agreement/undertaking 3. Validate the eSign service provider adheres to e-KYC compliance requirements independently 4. Check the eSign user Account with CA is as per CA eKYC Implementation Requirements	Mandatory	eSign Guidelines 2.1			
3.8.1.2	Application Service Provider should have gone through an approval process of ESP and should have agreement/ undertaking with them.	1. Validate on a sample basis that each eSign user has an unique Id 2. Verify that the application service provider has gone through the approval process of ESP and has an agreement/undertaking 3. Validate the eSign service provider adheres to e-KYC compliance requirements independently 4. Check the eSign user Account with CA is as per CA eKYC Implementation Requirements	Mandatory	eSign Guidelines 2.1			
3.8.1.3	eSign Service Provider should adhere to e-KYC compliance requirements independently	1. Validate on a sample basis that each eSign user has an unique Id 2. Verify that the application service provider has gone through the approval process of ESP and has an agreement/undertaking 3. Validate the eSign service provider	Mandatory	eSign Guidelines 2.1			

CCA AUDIT REPORT

		adheres to e-KYC compliance requirements independently 4. Check the eSign user Account with CA is as per CA eKYC Implementation Requirements					
3.8.1.4	eSign user Account with CA should be as per CA eKYC Implementation Requirements	1. Validate on a sample basis that each eSign user has an unique Id 2. Verify that the application service provider has gone through the approval process of ESP and has an agreement/undertaking 3. Validate the eSign service provider adheres to e-KYC compliance requirements independently 4. Check the eSign user Account with CA is as per CA eKYC Implementation Requirements	Mandatory	eSign Guidelines 2.1			

3.8.2. Authentication and DSC Application Form

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Authentication and DSC Application Form							
3.8.2.1	The mode of e-authentication should be biometric or OTP or PIN or combination of PIN and OTP in accordance with e-KYC Services	1. Verify the mode of e-authentication is biometric or OTP or PIN or combination of PIN and OTP in accordance with e-KYC Servicesby conducting a walkthrough 2. Obtain samples of digitally signed information received from e-KYC service provider 3. Verify the digitally signed information contains name, address, email id, mobile phone number, photo etc of eSign user and response code. 4. Validate response code is recorded on application form and included in DSC as well 5. Verify the application form is programmatically filled	Mandatory	eSign Guidelines 2.2			
3.8.2.2	DSC application form is based on the digitally signed information received from e-KYC service provider. The digitally signed information from e-KYC services include name, address, email id, mobile phone number, photo etc of eSign user and response code	1. Verify the mode of e-authentication is biometric or OTP or PIN or combination of PIN and OTP in accordance with e-KYC Servicesby conducting a walkthrough 2. Obtain samples of digitally signed information received from e-KYC service provider 3. Verify the digitally signed information contains name, address, email id, mobile phone number, photo etc of eSign user and response code. 4. Validate response code is recorded on application form and included in DSC as well 5. Verify the application form is programmatically filled	Mandatory	eSign Guidelines 2.2			

CCA - AUDIT REPORT

3.8.2.3	The response code, should be recorded on the application form and included in the DSC as well.	1. Verify the mode of e-authentication is biometric or OTP or PIN or combination of PIN and OTP in accordance with e-KYC Servicesby conducting a walkthrough 2. Obtain samples of digitally signed information received from e-KYC service provider 3. Verify the digitally signed information contains name, address, email id, mobile phone number, photo etc of eSign user and response code. 4. Validate response code is recorded on application form and included in DSC as well 5. Verify the application form is programmatically filled	Mandatory	eSign Guidelines 2.2			
3.8.2.4	The application form should programmatically be filled with the digitally signed information received from e-KYC services.	1. Verify the mode of e-authentication is biometric or OTP or PIN or combination of PIN and OTP in accordance with e-KYC Servicesby conducting a walkthrough 2. Obtain samples of digitally signed information received from e-KYC service provider 3. Verify the digitally signed information contains name, address, email id, mobile phone number, photo etc of eSign user and response code. 4. Validate response code is recorded on application form and included in DSC as well 5. Verify the application form is programmatically filled	Mandatory	eSign Guidelines 2.2			
3.8.2.5	The filled-in application form should be preserved. The following events should be recorded • Authentication of user • Response received from e-KYC ServicesCommunication with CAs for Certificate issuance	1. Obtain samples of filled in application forms 2. Verify the authentication of user, response received from e-KYC services and communication with CAs are recorded 3. Verify the consent of the eSign user for DSC is obtained electronically	Mandatory	eSign Guidelines 2.2			
3.8.2.6	The consent of the eSign user for getting a Digital Signature Certificate should be obtained electronically.	1. Obtain samples of filled in application forms 2. Verify the authentication of user, response received from e-KYC services and communication with CAs are recorded 3. Verify the consent of the eSign user for DSC is obtained electronically	Mandatory	eSign Guidelines 2.2			
3.8.2.7	The consent of the eSign user for digital signing of electronic record would have already been obtained electronically.	1. Check that CA stores the consent of eSign user for getting their consent 2. Validate that these consents are obtained electronically	Mandatory	eSign Guidelines 2.5			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.8.3. Security Procedure for Key Pair Generation and Certificate Issuance

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Key Pair Generation							
3.8.3.1	ESP should facilitate generation of key pairs on their Hardware Security Module. The key pairs shall be unique to the eSign user. The private key will be destroyed after one time use	1. Validate the ESP facilitates generation of key pairs of their HSM 2. Obtain samples and verify key pair is unique to each eSign user 3. Verify the private key is destroyed after one time use 4. Validate the private key is secured by HSM in in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List 5. Validate ESP's HSM is different from CAs HSM	Mandatory	eSign Guidelines 2.3			
3.8.3.2	The private key of the eSign user shall be secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List.	1. Validate the ESP facilitates generation of key pairs of their HSM 2. Obtain samples and verify key pair is unique to each eSign user 3. Verify the private key is destroyed after one time use 4. Validate the private key is secured by HSM in in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List 5. Validate ESP's HSM is different from CAs HSM	Mandatory	eSign Guidelines 2.3			
3.8.3.3	HSM of ESP should be separate from that of CAs for DSC issuance	1. Validate the ESP facilitates generation of key pairs of their HSM 2. Obtain samples and verify key pair is unique to each eSign user 3. Verify the private key is destroyed after one time use 4. Validate the private key is secured by HSM in in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List 5. Validate ESP's HSM is different from CAs HSM	Mandatory	eSign Guidelines 2.3			
Certificate Issuance							
3.8.3.4	The validity of the certificate shall be not more than 30 minutes for one time use only so revocation and suspension services will not be applicable vis-à-vis such certificates	1. Verify validity of certificate is limited to 30 minutes for one time use 2. Verify the Certificate Signing Request is sent to CA by ESP for issuing the DSC. 3. Obtain sample from the repository maintained by CA, and verify DSC is published in the repository	Mandatory	eSign Guidelines 2.4			
3.8.3.5	On successful key generation, the Certificate Signing Request is sent to CA by ESP for issuing the	1. Verify validity of certificate is limited to 30 minutes for one time use 2. Verify the Certificate Signing Request is sent to CA by ESP for issuing the DSC.	Mandatory	eSign Guidelines 2.4			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	DSC.	3. Obtain sample from the repository maintained by CA, and verify DSC is published in the repository					

3.8.4. Authentication of Electronic Record by Applying Digital Signature

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Authentication and DSC Application Form							
3.8.4.1	eSign user should be given an option to reject the Digital Signature Certificate	1. Validate that the CA gives an option of rejecting DSC to eSign user	Mandatory	eSign Guidelines 2.5			

3.8.5. Evidence Requirements and Essential Security Requirements

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Evidence Requirements							
3.8.5.1	Digital Signature Certificate issuance: Record all relevant information concerning the e-authentication of eSign user for generation of key pair and subsequent certification functions for a minimum period of 7 years (ref The Information Technology (Certifying Authorities) Rules, 2000, Rule 27), in particular for the purpose of providing evidence for certification purposes. Such electronic record should be preserved accordingly in secure environment	1. Obtain records of all relevant information for e-authentication of eSign user for generation of key pair 2. Validate that this data is stored for a minimum period of 7 years 3. Verify the records are preserved in a secure environment	Mandatory	eSign Guidelines 2.6			
3.8.5.2	Digital Signature creation: Record all relevant information concerning the e-authentication of eSign user for accessing the key pair for a minimum period of 7 years, in particular for the purpose of providing	1. Obtain records of all relevant information for e-authentication of eSign user for generation of key pair 2. Validate that this data is stored for a minimum period of 7 years 3. Verify the records are preserved in a secure environment	Mandatory	eSign Guidelines 2.6			

CCA AUDIT REPORT

	evidence of Digital signature creation. Such electronic record should be preserved accordingly in secure environment						
Essential Security Requirements							
3.8.5.3	eSign xml request and response should be as per the eSign API specification. The communication between ASP and ESP should be secured (e.g. SSL, VPN, etc).	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC provider's specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider's OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.	Mandatory	eSign Guidelines 2.7			
3.8.5.4	The eSign xml request should be digitally signed prior to sending it to ESP. ESP should verify	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is	Mandatory	eSign Guidelines 2.7			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	ASP's digital signature on each eSign xml request received.	secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC provider's specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider's OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.					
3.8.5.5	The e-KYC request should be as per e-KYC provider's specifications	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC provider's specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link	Mandatory	eSign Guidelines 2.7			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider's OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.					
3.8.5.6	The e-KYC response shall be as per e-KYC provider's specifications	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC provider's specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider's OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class	Mandatory	eSign Guidelines 2.7			

CCA - AUDIT REPORT

		based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.					
3.8.5.7	ESP should form a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. The CA system should accept only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC provider's specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider's OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.	Mandatory	eSign Guidelines 2.7			
3.8.5.8	CA system shall be	1. Conduct a walkthrough to check on sample	Mandatory	eSign Guidelines 2.7			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	configured to issue only e-KYC class end entity individual digital signature certificate(s).	basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC provider's specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider's OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.					
3.8.5.9	The eSign xml response formed by ESP should be digitally signed prior to sending it to ASP	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC provider's specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to	Mandatory	eSign Guidelines 2.7			

CCA IT AUDIT REPORT

		sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider's OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.					
3.8.5.10	OTP request should conform to e-KYC provider's OTP request API specifications	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC provider's specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider's OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and	Mandatory	eSign Guidelines 2.7			

CCA IT AUDIT REPORT

		management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.					
3.8.5.11	The ESP systems used for e-KYC service request and response should be different from ESP systems used to communicate with CA servers.	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC provider's specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider's OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online	Mandatory	eSign Guidelines 2.7			

CCA AUDIT REPORT

		electronic signature service.					
3.8.5.12	The eSign user key generation and management systems of ESP should be separate from CA systems in use for issuing end user certificate.	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC provider's specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider's OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.	Mandatory	eSign Guidelines 2.7			
3.8.5.13	The CA system used for issuing e-KYC class based DSCs should be independent of CA systems used for other classes of DSCs	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC	Mandatory	eSign Guidelines 2.7			

CCA IS AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		provider’s specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider’s OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.					
3.8.5.14	Key Generation for eSign user should happen on HSM and also should be secured by HSM The private key of the user should be secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider’s specifications f. e-KYC response is as per e- KYC provider’s specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider’s OTP request API specifications l. ESP systems used for e- KYC service	Mandatory	eSign Guidelines 2.7			

CCA IS AUDIT REPORT

		request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3 recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.					
3.8.5.15	ESP should deploy trustworthy systems and employ trusted personal for eSign online electronic signature service.	1. Conduct a walkthrough to check on sample basis the following: a. eSign xml request and response is as per the eSign API specification. b. communication between ASP and ESP is secured (e.g. SSL, VPN, etc). c. eSign xml request is digitally signed prior to sending it to ESP d. ESP verifies ASP's digital signature on each eSign xml request received e. e-KYC request is as per e- KYC provider's specifications f. e-KYC response is as per e- KYC provider's specifications g. ESP forms a digitally signed Certificate Generation Request with ESP's key prior to sending it to CA system. h. CA system accepts only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link i. CA system is configured to issue only e-KYC class end entity individual digital signature certificate(s). j. eSign xml response formed by ESP is digitally signed prior to sending it to ASP k. OTP request conforms to e- KYC provider's OTP request API specifications l. ESP systems used for e- KYC service request and response is different from ESP systems used to communicate with CA servers. m. eSign user key generation and management systems of ESP should is separate from CA systems in use for issuing end user certificate. n. CA system used for issuing e-KYC class based DSCs are be independent of CA systems used for other classes of DSCs o. Key Generation for eSign user happens on HSM and is secured by HSM p. Private key of the user is secured by Hardware security module (HSM) in accordance with FIPS 140-2 level 3	Mandatory	eSign Guidelines 2.7			

CCA - AUDIT REPORT

		recommendations for Cryptographic Modules Validation List q. ESP deploys trustworthy systems and employs trusted personal for eSign online electronic signature service.					

3.8.6. ESign - Digital Signature Certificate and Profiles

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
eSign - Digital Signature Certificate and Profile							
3.8.6.1	The end-user Digital Signature Certificates issued by CA should contain the following fields specific to eSign-Online Electronic Signature service along with other specified fields in IOG • Common Name - "Name of the person as in e-KYC response • Unique Identifier - This attribute shall be used for SHA 256 hash of e-KYC ID for individuals • Pseudonym - Response code/e-KYC unique Number in the case of e-KYC Service (Mandatory) (2.5.4.65 - id-at-pseudonym)	1. Validate that the end-user DSC issued by the CA contain the elements mentioned in the control description	Mandatory	eSign Guidelines 4.1			

3.8.7. ESign API

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
eSign API							
3.8.7.1	The API specifications remain common for all eSign Service provider. However, the parameter values that will vary for each ESP are ‘eSign Service URL’ and ‘ASP ID’ (Unique User ID provided by the ESP).	1. Validate same API specification are present for all ESPs with difference in the eSign service URL and ASP ID	Mandatory	eSign API Specifications			
3.8.7.2	ASP provides eSign facility to public	1. Verify ASP providing eSign facility to public integrated with	Mandatory	eSign API Specifications			

CCA - AUDIT REPORT

	should integrate with all other ESPs within one month after onboarding with first ESP.	all other ESPs within one month after onboarding with first ESP					
3.8.7.3	To support strong end to end security and avoid request tampering and man-in-the-middle attacks, it is essential that the requests and responses are digitally signed. The usage of HTTPS shall ensure transport layer encryption, while digital signing of XML shall ensure integrity & authenticity of data.	1. Validate requests and responses are digitally signed 2. Verify HTTPs is used for transport layer encryption	Mandatory	eSign API Specifications			
3.8.7.4	Once ASP submits the Request XML, ESP provides a 'pending for completion' (status=2) response which will contain the response code (as an acknowledgement). At this stage, ASP is expected to guide the user with proper information as under: 1. Redirect the user to the authentication page of the ESP. 2. Provide information to the user to authenticate over ESP's mobile app. (ESP may also support push notification for mobile app users, and allowing to authenticate on mobile through eKYC provider)	1. Conduct walkthrough of the process of ASP submitting the Request XML 2. Validaye ESP provides a 'pending for completion' (status=2) response which contains the response code (as an acknowledgement)	Mandatory	eSign API Specifications			
3.8.7.5	CA shall implement a comprehensive eKYC service to fulfil the KYC requirements of eSign user. • eKYC system shall be a protected and shall not be exposed to any external services directly. • The access of eKYC	1. Validate the eKYC service for eSign user cover the requirements mentioned in the control description	Mandatory	eSign API Specifications			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	information shall be on need basis for the services prescribed. • The access to such information by other services shall be bound by authentication of eSign user by two factors, namely the PIN and an OTP • The information of PIN shall not be stored in plain text format. The authentication of PIN shall be always verified after compare against the stored value. • The PIN information in plain text shall not be part of any logs or data monitoring systems.						
3.8.7.6	eKYC Service shall operate with the minimum required functions. The functions shall include: • Creation of eSign user account • Fetch eSign user information by ESP / CA systems (with user authentication) • Trigger OTP to the user • Mobile application based Access tokens • eSign user functionalities	1. Validate the minimum required functions mentioned in the control description are performed as part of the eKYC service	Mandatory	eSign API Specifications			
3.8.7.7	eKYC system shall provide provision for online enrolment to eSign users and the same should be able access through ESP page or ASP applications. Such enrolment is bound by procedures and requirements defined under Identity Verification Guidelines. On successful enrolment of an eKYC User, following data eSign user information is recorded in eKYC user account. These	1. Conduct walkthrough and check if the eKYC system provisioned for online enrolment to eSign users can be accessed through ESP page or ASP applications 2. Validate on successful enrolment of eKYC user, all required information mentioned in control description is covered 3. Check Aadhaar Offline XML is verified on its receipt for a valid digital signature by UIDAI 4. Verify the bank sends eKYC to CA directly up on authentication by user as a banking customer Bank and eKYC is verified on its receipt by CA for a valid digital signature by respective bank	Mandatory	eSign API Specifications			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	fields are subject to verification against the prescribed 'Verified Source'. (Aadhaar Offline XML, Bank eKYC, Organizational KYC)						
3.8.7.8	Aadhaar Offline XML shall be verified on its receipt for a valid digital signature by UIDAI	1. Conduct walkthrough and check if the eKYC system provisioned for online enrolment to eSign users can be accessed through ESP page or ASP applications 2. Validate on successful enrolment of eKYC user, all required information mentioned in control description is covered 3. Check Aadhaar Offline XML is verified on its receipt for a valid digital signature by UIDAI 4. Verify the bank sends eKYC to CA directly up on authentication by user as a banking customer Bank and eKYC is verified on its receipt by CA for a valid digital signature by respective bank	Mandatory	eSign API Specifications			
3.8.7.9	Bank sends eKYC to CA directly up on authentication by user as a banking customer Bank eKYC shall be verified on its receipt by CA for a valid digital signature by respective bank.	1. Conduct walkthrough and check if the eKYC system provisioned for online enrolment to eSign users can be accessed through ESP page or ASP applications 2. Validate on successful enrolment of eKYC user, all required information mentioned in control description is covered 3. Check Aadhaar Offline XML is verified on its receipt for a valid digital signature by UIDAI 4. Verify the bank sends eKYC to CA directly up on authentication by user as a banking customer Bank and eKYC is verified on its receipt by CA for a valid digital signature by respective bank	Mandatory	eSign API Specifications			
3.8.7.10	The existence of Organization and verification of authorised signatory as per IVG is a prerequisite. Organization should send KYC List to CA in electronic form or physical paper form signed by authorised signatory CA should verify the source and signature of the signatory of Organization	1. Verify the oranisation sends KYC List to CA in electronic form or physical paper form signed by authorised signatory. Check CA also verifies the source and signature of the signatory of Organization	Mandatory	eSign API Specifications			
3.8.7.11	The eKYC user	2. Verify the eKYC user is allowed to	Mandatory	eSign API Specifications			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	information shall be allowed to access for eSign process and DSC issuance. For access of such data for eSign process, ESP shall implement necessary rest API based eKYC request, as per the formats provided under section 4.3 of eSign API Specifications guidelines.	access eSign process and DSC issuance and for accessing such data ESP implements necessary API based eKYC request as per format provided in the guidelines 3. Validate the audit logs of eKYC user are maintained by eKYC provider with timestamps and user id. 4. Check maximum retries with failed authentication by a user is limited to 5 attempts					
3.8.7.12	The audit logs (both success & Failure) of eKYC user authentications shall be maintained by eKYC Provider with timestamp and user id. The maximum retries with failed authentication by a user (for specific transaction) shall be limited to 5 attempts	2. Verify the eKYC user is allowed to access eSign process and DSC issuance and for accessing such data ESP implements necessary API based eKYC request as per format provided in the guidelines 3. Validate the audit logs of eKYC user are maintained by eKYC provider with timestamps and user id. 4. Check maximum retries with failed authentication by a user is limited to 5 attempts	Mandatory	eSign API Specifications			
3.8.7.13	ESP should implement an internal secure API communication, in order to send OTP to the user. Alternatively, ESP may also implement Time Based OTP (TOTP) functionality using compliant TOTP authenticators and/or ESPs own authenticator app through eKYC provider. ESP can also implement ESP mobile app based authentication, as an alternate to OTP.	1. Validate if ESP has implemented any one of the following a. internal secure API communication to send OTP b. Time based OTP using compliant TOTP authenticators c. ESP mobile app based authentication	Mandatory	eSign API Specifications			
3.8.7.14	ESP shall offer a subscriber portal to meet the following requirements through eKYC provider. • PIN change functionality • Signing History • Other modifications to user data This portal shall implement single factor authentication including either PIN,	1. Check the portal created by ESP to meet the requirements of eKYC provider 2. Verify the portal offers PIN change functionality, signing history and other modifications 3. Validate single factor authentication is implemented to include either PIN, or OTP, or Mobile app to login to the system	Mandatory	eSign API Specifications			

CCA IT AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	or OTP, or Mobile app to login to the system. The portal shall be secured and permit minimum of the requirements stated in this section. Any request for modifications to KYC data shall undergo necessary verification procedures laid down by CCA.						
3.8.7.15	ESP may offer mobile based authentication. The requirements for the same need to be fulfilled as under, in order to qualify for Mobile based authentication. Such qualified mobile app-based authentication shall be equivalent to OTP authentication. Thereby, any such signing process shall have PIN + Mobile app authentication to fulfil KYC data access. Requirements to be fulfilled by such mobile applications: • Mobile app shall be owned and operated by ESP with complete control on its code, architecture, security and publishing requirements. • Mobile app shall support largely used Mobile operating systems. However, it shall not support any operating systems or its versions, which are known to have security issue or deprecation. • Mobile app shall have a secure architecture and undergo vulnerability assessments to avoid any exploitation. • User shall login to the mobile app using a secure procedure involvement PIN + OTP authentication. This first time usage shall have a secure	1. Verify if ESP offers mobile based authentication, the requirements covered in control description are met 2. Check the mobile app-based authentication is equivalent to OTP authentication and any signing process shall have PIN + Mobile app authentication to fulfil KYC data access.	Mandatory	eSign API Specifications			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	layer to create and make a handshake with KYC server with generation of a unique Access Token. • Such access token shall be generated in the mobile device in a secure area / element supported by the platform, and shared with eKYC server for enrolment of the device against that eKYC user. • Access Token shall be marked for expiry in 3 months from its last successful usage. In case of expired access token, mobile app shall clear the local Access Token and force the user for fresh login. • System shall support multiple access Tokens against one eKYC user, towards supporting multiple mobile devices. • Subscriber portal shall provide necessary option for accessToken history and revocation of accessTokens. • Any signing transaction 'waiting for user authentication' shall be queued and shown separately on the mobile app. It is also recommended to show new signing transactions as a push notification. • User shall be able to open the mobile app (with or without a local sign in functionality) and confirm the signature with PIN authentication. • Mobile app may also support additional eSign user functions using same level of security required for eSign user portal. • Mobile app should be secure enough to avoid any kind of access breach, or any kind of hacks to gain direct access to the						

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	token and the eKYC server endpoint consumed by such mobile app.						
3.8.7.16	Request/Response format of eSign API 2.X	The following should be verified 1. Obtain all the request/ response format specified under eSign API 2.X and cross verify with request/ response of a sample transaction	Mandatory	eSign API 2.X Specifications			
3.8.7.17	Request/Response format of eSign API 3.X	The following should be verified 1. Obtain all the request/ response format specified under eSign API 3.X and cross verify with request/ response of a sample transaction	Mandatory	eSign API 3.X Specifications			
3.8.7.18	Request/Response format of eSign API 1.X	The following should be verified 1. Obtain all the request/ response format specified under eSign API 1.X and cross verify with request/ response of a sample transaction	Mandatory	eSign API 1.X Specifications			

3.8.8. On boarding Process and Agreement

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
ASP Eligibility Criteria							
3.8.8.1	The agency which desires to integrate eSign service should either be: • A Central/ State Government Ministry / Department or an undertaking owned and managed by Central • / State Government, or • An Authority constituted under the Central / State Act, or • A Not-for-profit company / Special Purpose organization of national importance, or • A bank / financial institution / telecom company, or • A legal entity registered in India: o Should be an organization incorporated under Companies Act, 1956, Registrar of Firms, LLPRegistered; OR An association of persons or a body of individuals, in India, whether incorporated or not o	1. Obtain list of agencies integrated eSign Services 2. For sample agencies verify if they come under either of the categories mentioned in the control description	Mandatory	ASP On-Boarding Guidelines 1.7			

CCA - AUDIT REPORT

	Should not have been blacklisted by any State Government, Central Government, Statutory,Autonomous, or Regulatory body.						
3.8.8.2	he agency which desires to integrate eSign service should either be: • A Central/ State Government Ministry / Department or an undertaking owned and managed by Central • / State Government, or • An Authority constituted under the Central / State Act, or • A Not-for-profit company / Special Purpose organization of national importance, or • A bank / financial institution / telecom company, or • A legal entity registered in India: o Should be an organization incorporated under Companies Act, 1956, Registrar of Firms, LLPRegistered; OR An association of persons or a body of individuals, in India, whether incorporated or not o Should not have been blacklisted by any State Government, Central Government, Statutory,Autonomous, or Regulatory body.	1. Obtain list of agencies integrated eSign Services 2. For sample agencies verify if they come under either of the categories mentioned in the control description	Mandatory	ASP On-Boarding Guidelines 1.7			
On Boarding Process							
3.8.8.3	Organization intending to avail eSign service shall make a formal request to one or more ESP.	1. Conduct a walkthrough of the on boarding process and check the following: a. Formal request is made to ESP to avail eSign service b. Application form is made specific to particular ESP c. Application form is submitted in original, and bear the signature/ attestation of Authorized signatory of the organization d. For paperless mode, application should be digitally signed e. ESP grants the access to eSign only after receiving completed application form f. All supporting documents, duly attested are submitted	Mandatory	ASP On-Boarding Guidelines 1.9			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		g. ASP agrees to the terms of service with the ESP to enable eSign in their application/ software					
3.8.8.4	Application form should be made specific to particular ESP. For this purpose, each ESP may share a format of application form	1. Conduct a walkthrough of the on boarding process and check the following: a. Formal request is made to ESP to avail eSign service b. Application form is made specific to particular ESP c. Application form is submitted in original, and bear the signature/ attestation of Authorized signatory of the organization d. For paperless mode, application should be digitally signed e. ESP grants the access to eSign only after receiving completed application form f. All supporting documents, duly attested are submitted g. ASP agrees to the terms of service with the ESP to enable eSign in their application/ software	Mandatory	ASP On-Boarding Guidelines 1.9			
3.8.8.5	Application form should be submitted in original, and bear the signature / attestation of Authorized signatory of the organization.	1. Conduct a walkthrough of the on boarding process and check the following: a. Formal request is made to ESP to avail eSign service b. Application form is made specific to particular ESP c. Application form is submitted in original, and bear the signature/ attestation of Authorized signatory of the organization d. For paperless mode, application should be digitally signed e. ESP grants the access to eSign only after receiving completed application form f. All supporting documents, duly attested are submitted g. ASP agrees to the terms of service with the ESP to enable eSign in their application/ software	Mandatory	ASP On-Boarding Guidelines 1.9			
3.8.8.6	In case of application form being submitted through paperless mode (email, etc), it shall be digitally / electronically signed by authorized signatory of the organization.	1. Conduct a walkthrough of the on boarding process and check the following: a. Formal request is made to ESP to avail eSign service b. Application form is made specific to particular ESP c. Application form is submitted in original, and bear the signature/ attestation of Authorized signatory of the organization d. For paperless mode, application should be digitally signed	Mandatory	ASP On-Boarding Guidelines 1.9			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		e. ESP grants the access to eSign only after receiving completed application form f. All supporting documents, duly attested are submitted g. ASP agrees to the terms of service with the ESP to enable eSign in their application/ software					
3.8.8.7	ESP shall grant the access to eSign only after receiving completed application form from ASP.	1. Conduct a walkthrough of the on boarding process and check the following: a. Formal request is made to ESP to avail eSign service b. Application form is made specific to particular ESP c. Application form is submitted in original, and bear the signature/ attestation of Authorized signatory of the organization d. For paperless mode, application should be digitally signed e. ESP grants the access to eSign only after receiving completed application form f. All supporting documents, duly attested are submitted g. ASP agrees to the terms of service with the ESP to enable eSign in their application/ software	Mandatory	ASP On-Boarding Guidelines 1.9			
3.8.8.8	ASP shall submit supporting documents towards KYC verification and other requirements of on-boarding. These documents should be duly attested & forwarded by the authorized signatory of the organization. The list of documents to be submitted shall be as given at Annexure 2.11.2	1. Conduct a walkthrough of the on boarding process and check the following: a. Formal request is made to ESP to avail eSign service b. Application form is made specific to particular ESP c. Application form is submitted in original, and bear the signature/ attestation of Authorized signatory of the organization d. For paperless mode, application should be digitally signed e. ESP grants the access to eSign only after receiving completed application form f. All supporting documents, duly attested are submitted g. ASP agrees to the terms of service with the ESP to enable eSign in their application/ software	Mandatory	ASP On-Boarding Guidelines 1.10			
3.8.8.9	The ASP should enter / agree to the terms of service with the eSign Service Provider (ESPs) to enable eSign in their application / software.	1. Conduct a walkthrough of the on boarding process and check the following: a. Formal request is made to ESP to avail eSign service b. Application form is made specific to particular ESP c. Application form is submitted in original, and bear the signature/	Mandatory	ASP On-Boarding Guidelines 1.11			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		attestation of Authorized signatory of the organization d. For paperless mode, application should be digitally signed e. ESP grants the access to eSign only after receiving completed application form f. All supporting documents, duly attested are submitted g. ASP agrees to the terms of service with the ESP to enable eSign in their application/ software					
3.8.8.10	ASP has to submit the Digital Signature Certificate to ESP, so that ESP can configure it in their system and validate/verify each transaction received from the ASP. Such Digital Signature Certificate should fulfill the criteria given below: • Should be a valid certificate issued by a CA licensed under Information technology (IT) Act. • Should be either an Organizational Person Digital Signature Certificate or an Organizational Document Signer Certificate. • The O value in the certificate should be the legal entity name of the ASP organization. • Should be either Class 2 or Class 3 certificate. • Should be valid for at least six months from date of submission	1. For sample DSC verify the following criteria is fulfilled: a. Should be a valid certificate issued by a CA licensed under Information technology (IT) Act. b. Should be either an Organizational Person Digital Signature Certificate or an Organizational Document c. Signer Certificate. The O value in the certificate should be the legal entity name of the ASP organization. d. Should be either Class 2 or Class 3 certificate. e. Should be valid for at least six months from date of submission	Mandatory	ASP On-Boarding Guidelines 1.12			
3.8.8.11	ASP shall build the required infrastructure for adopting eSign service. ESP provides access to pre-production environment and enables the ASP to establish end-to -end connectivity to carry out eSign services testing and integration	1. Verify ASP has built the required infrastructure for adopting eSign service. 2. Check the ESP provides access to pre-production environment and enables the ASP to establish end- to -end connectivity to carry out eSign services testing and integration	Mandatory	ASP On-Boarding Guidelines 1.13			
3.8.8.12	ASP shall submit the audit report in original to the ESP. Such audit report should not be older than 3 months. In case, ASP is taking service from multiple ESPs,	1. Validate audit report not older than 3 months was submitted to the ESP 2. Check the audit was carried out by Auditor empaneled by Cert in /IS Auditor 3. Validate ASP carried out the audit prior to completion of one year from	Mandatory	ASP On-Boarding Guidelines 1.14			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	common audit report can be submitted. ASP Audit report should be carried out by Auditor empaneled by Cert-in /IS Auditor	the date of completion of last audit. 4. For e-KYC compliance, validate ESP carried out necessary auditing of ASP as applicable					
3.8.8.13	ASP should carry out the audit prior to the completion of one year from the date of completion of last audit. Audit report shall also be examined on a yearly basis by ESP by requesting a fresh audit report. ASP should submit annual compliance report with the same audit requirements and procedures provided here, upon request by ESP, within 30 days, In respect of e-KYC compliance requirements, ESP shall carryout necessary auditing of ASP as applicable separately.	1. Validate audit report not older than 3 months was submitted to the ESP 2. Check the audit was carried out by Auditor empaneled by Cert in /IS Auditor 3. Validate ASP carried out the audit prior to completion of one year from the date of completion of last audit. 4. For e-KYC compliance, validate ESP carried out necessary auditing of ASP as applicable	Mandatory	ASP On-Boarding Guidelines 1.14			
3.8.8.14	ASP shall notify ESP about its readiness for migration to production environment. Subsequently ASP completes the go live checklist and submits the request for Go Live checklist. ESP should take an undertaking from ASP or an agreement should be executed between ESP and ASP.	1. Obtain sample Go Live checklist for some of the ASPs 2. Validate the checklist was completed by ASP 3. Verify ESP obtained an undertaking from ASP or an agreement is executed between ESP and ASP.	Mandatory	ASP On-Boarding Guidelines 1.15			
3.8.8.15	ESP shall ensure successful scrutiny of the following before granting production access: • Application form • Supporting documents • Acceptance of terms of service • Digital Signature Certificate submission • Integration / testing completion in preproduction / testing environment • Audit report • Go Live checklist • Internal approvals and clearance within ESP organization ESP shall ensure that such information is securely	1. ESP to demonstrate that it scrutinized the following before granting production access: a. Application form b. Supporting documents c. Acceptance of terms of service d. Digital Signature Certificate submission e. Integration / testing completion in preproduction / testing environment f. Audit report g. Go Live checklist h. Internal approvals and clearance within ESP organization	Mandatory	ASP On-Boarding Guidelines 1.16			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	shared with the relevant person in ASP organization.						

3.8.9. CA Requirements

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
CA Requirements							
3.8.9.1	The CA system used for issuing e-KYC class based DSCs should be independent of CA systems used for other classes of DSCs.	1. Verify the CA system used for issuing e-KYC class based DSCs is independent of CA systems used for other classes of DSC 2. Check the CA system accepts only digitally signed CSR from designated ESP over a secure link 3. Verify the CA system is configured to issue only e-KYC class end entity individual digital signature certificates 4. Validate ESP is allowed access to CA systems only for submitting CSR for issuance of e-KYC classes of DSCs to be used for eSign.	Mandatory	eSign Guidelines 7			
3.8.9.2	The CA system should accept only digitally signed Certificate Signing Request (CSR) from designated ESP systems over a secure link.	1. Verify the CA system used for issuing e-KYC class based DSCs is independent of CA systems used for other classes of DSC 2. Check the CA system accepts only digitally signed CSR from designated ESP over a secure link 3. Verify the CA system is configured to issue only e-KYC class end entity individual digital signature certificates 4. Validate ESP is allowed access to CA systems only for submitting CSR for issuance of e-KYC classes of DSCs to be used for eSign.	Mandatory	eSign Guidelines 7			
3.8.9.3	CA system shall be configured to issue only e-KYC class end entity individual digital signature certificates. ESP shall be allowed access to CA systems only for submitting CSR for issuance of e-KYC classes of DSCs to be used for eSign.	1. Verify the CA system used for issuing e-KYC class based DSCs is independent of CA systems used for other classes of DSC 2. Check the CA system accepts only digitally signed CSR from designated ESP over a secure link 3. Verify the CA system is configured to issue only e-KYC class end entity individual digital signature certificates 4. Validate ESP is allowed access to CA systems only for submitting CSR for issuance of e-KYC classes of DSCs to be used for eSign.	Mandatory	eSign Guidelines 7			
3.8.9.4	All Digital Signature Certificates issued by the Certifying Authorities shall conform to ITU X.509 version 3	1. Obtain sample DSCs and verify the certificates contains the following: a. Serial Number b. Signature Algorithm ldentifier c. Issuer d. Validity period of the Digital Signature Certificate;	Mandatory	IT CA Rules 7			

COAT AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	standard as per rule 6 and shall inter alia contain the following data, namely:- • Serial Number • Signature Algorithm ldentifier • Issuer • Validity period of the Digital Signature Certificate; • Name of the subscriber • Public Key information of the subscriber	e. Name of the subscriber f. Public Key information of the subscriber					

3.8.10. Audit Logging Procedures

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Audit Logging							
3.8.10.1	Audit log files shall be generated for all events relating to the security of the eSign-Online Electronic Signature Service. Where possible, the security audit logs shall be automatically collected. Where this is not possible, a logbook, paper form, or other physical mechanism shall be used.	1. Conduct a walkthrough of the audit logging process followed by CA and on sample basis check the following: a. Audit log files are generated for all events relating to the security of the eSign-Online Electronic Signature Service. b. Security audit logs are automatically collected or a logbook, paper form, or other physical mechanism is used. c. All security audit logs, both electronic and non-electronic, are retained and made available during compliance audits d. Security audit logs for each auditable event defined in this section 3.9.10 are maintained e. All security auditing capabilities of the operating system and the applications required are enabled	Mandatory	e-authentication guidelines for eSign			
3.8.10.2	All security audit logs, both electronic and non-electronic, shall be retained and made available during compliance audits. The security audit logs for each auditable event defined in this section 3.9.10 shall be maintained in accordance with controls covered below	1. Conduct a walkthrough of the audit logging process followed by CA and on sample basis check the following: a. Audit log files are generated for all events relating to the security of the eSign-Online Electronic Signature Service. b. Security audit logs are automatically collected or a logbook, paper form, or other physical mechanism is used. c. All security audit logs, both electronic and non-electronic, are retained and made available during compliance audits d. Security audit logs for each auditable event defined in this section 3.9.10 are maintained e. All security auditing capabilities of the operating system and the applications	Mandatory	e-authentication guidelines for eSign			

COMPLIANCE AUDIT REPORT

		required are enabled					
3.8.10.3	All security auditing capabilities of the operating system and the applications required shall be enabled	1. Conduct a walkthrough of the audit logging process followed by CA and on sample basis check the following: a. Audit log files are generated for all events relating to the security of the eSign-Online Electronic Signature Service. b. Security audit logs are automatically collected or a logbook, paper form, or other physical mechanism is used. c. All security audit logs, both electronic and non-electronic, are retained and made available during compliance audits d. Security audit logs for each auditable event defined in this section 3.9.10 are maintained e. All security auditing capabilities of the operating system and the applications required are enabled	Mandatory	e-authentication guidelines for eSign			
3.8.10.4	At a minimum, each audit record shall include the following (either recorded automatically or manually for each auditable event): • The type of event, • The date and time the event occurred, • Success or failure where appropriate, and • The identity of the entity and/or operator that caused the event.	1. For sample audit records check the following are recorded: a. The type of event, b. The date and time the event occurred, c. Success or failure where appropriate, and d. The identity of the entity and/or operator that caused the event	Mandatory	e-authentication guidelines for eSign			
3.8.10.5	The following events shallbe covered under security: • Any changes to the Audit parameters, e.g., audit frequency, type of event audited • Any attempt to delete or modify the Audit logs	1. For sample audit records check the following are covered under security: a. Any changes to the Audit parameters, e.g., audit frequency, type of event audited b. Any attempt to delete or modify the Audit logs	Mandatory	e-authentication guidelines for eSign			
3.8.10.6	The following events shall be covered under logical access: • Successful and unsuccessful attempts to assume	1. For sample audit records check the following are covered under logical access: a. Successful and unsuccessful attempts to assume a role b. The value of maximum number of authentication attempts is changed c. The number of unsuccessful	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	a role • The value of maximum number of authentication attempts is changed • The number of unsuccessful authentication attempts exceeds the maximum authentication attempts during user login • An Administrator unlocks an account that has been locked as a result of unsuccessful authentication attempts • An Administrator changes the type of authenticator, e.g., from a password to a biometric	authentication attempts exceeds the maximum authentication attempts during user login d. An Administrator unlocks an account that has been locked as a result of unsuccessful authentication attempts e. An Administrator changes the type of authenticator, e.g., from a password to a biometric					
3.8.10.7	The following events shall be covered under key generation: • Generation of Signing Key Pair for eSign users • Deletion of key pair after signature	1. For sample audit records check the following are covered under key generation: a. Generation of Signing Key Pair for eSign users b. Deletion of key pair after signature	Mandatory	e-authentication guidelines for eSign			
3.8.10.8	The following events shall be covered under securing key: • Securing eSign user Signing private key • Retrieval of eSign user Signing private key for usage	1. For sample audit records check the following are covered under key securing: a. Securing eSign user Signing private key b. Retrieval of eSign user Signing private key for usage	Mandatory	e-authentication guidelines for eSign			
3.8.10.9	The following events shall covered under eSign online electronic signature services: • All eSign Online Electronic Signature Signing requests received from ASP • All e-KYC response received from e-KYC Provider	1. For sample audit records check the following are covered under eSign online electronic signature services: a. All eSign Online Electronic Signature Signing requests received from ASP b. All e-KYC response received from e-KYC Provider c. All electronic DSC Application Form Generated d. Proof of eSign user's consent for i. key pair generation, ii. DSC application form submission to CA,	Mandatory	e-authentication guidelines for eSign			

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	• All electronic DSC Application Form Generated • Proof of eSign user's consent for - key pair generation, - DSC application form submission to CA, - Generate CSR based on the digitally signed information received from e-KYC services - signature generation on the hash submitted • Mechanism Implemented for acceptance of DSC by eSign user • Communication to CA in respect of Certification. • Response sent to ASP	iii. Generate CSR based on the digitally signed information received from e-KYC services iv. signature generation on the hash submitted e. Mechanism Implemented for acceptance of DSC by eSign user f. Communication to CA in respect of Certification. g. Response sent to ASP					
3.8.10.10	The following events shall be covered under essential security requirements: • Identification and Authentication • Domain Separation • Cryptographic Requirements	1. For sample audit records check the following are covered under essential security requirements: a. Identification and Authentication b. Domain Separation c. Cryptographic Requirements	Mandatory	e-authentication guidelines for eSign			
3.8.10.11	The following events shall be covered under account administration: • Roles and users are added or deleted • The access control privileges of a user account or a role are modified • eSign Online Electronic Signature Service API • All changes to the eSign Online Electronic Signature Service API	1. For sample audit records check the following are covered under account administration: a. Roles and users are added or deleted b. The access control privileges of a user account or a role are modified c. eSign Online Electronic Signature Service API d. All changes to the eSign Online Electronic Signature Service API	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.8.10.12	The following events shall be covered under miscellaneous: • Appointment of an individual to a Trusted Role • Designation of personnel for multiparty control • Installation of the Operating System • Installation of the eSign Online Electronic Signature Service Application • Installation of hardware cryptographic modules • Removal of hardware cryptographic modules • Destruction of cryptographic modules • Zeroization of cryptographic modules • System Startup • Logon attempts to eSign Online Electronic Signature Service Application • Receipt of hardware / software • Attempts to set passwords • Attempts to modify passwords • Back up of the internal eSign Services database • Restoration from back up of the internal eSign Services database • File manipulation (e.g., creation, renaming, moving) • Access to the internal eSign Online Electronic Signature Service database • Re-key of the eSign Online Electronic Signature Service signing certificate	1. For sample audit records check the following are covered under miscellaneous: a. Designation of personnel for multiparty control b. Installation of the Operating System c. Installation of the eSign Online Electronic Signature Service Application d. Installation of hardware cryptographic modules e. Removal of hardware cryptographic modules f. Destruction of cryptographic modules g. Zeroization of cryptographic modules h. System Startup i. Logon attempts to eSign Online Electronic Signature Service Application j. Receipt of hardware / software k. Attempts to set passwords l. Attempts to modify passwords m. Back up of the internal eSign Services database n. Restoration from back up of the internal eSign Services database o. File manipulation (e.g., creation, renaming, moving) p. Access to the internal eSign Online Electronic Signature Service database q. Re-key of the eSign Online Electronic Signature Service signing certificate	Mandatory	e-authentication guidelines for eSign			
3.8.10.13	The following events shall be	. For sample audit records check the following are covered under configuration	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	covered under configuration changes: • Hardware • Software • Operating System • Patches • Security Profiles	changes: a. Hardware b. Software c. Operating System d. Patches e. Security Profiles					
3.8.10.14	The following events shall be covered under physical access/site security: • Personnel Access to room housing eSign- Online Electronic Signature Service • Access to the eSign- Online Electronic Signature Service • Known or suspected violations of physical security	1. For sample audit records check the following are covered under physical access/site security:: a. Personnel Access to room housing eSign- Online Electronic Signature Service b. Access to the eSign- Online Electronic Signature Service c. Known or suspected violations of physical security	Mandatory	e-authentication guidelines for eSign			
3.8.10.15	The following events shall be covered under anomalies: • Software error conditions • Software check integrity failures • Receipt of improper messages • Misrouted messages • Network attacks (suspected or confirmed) • Equipment failure • Electrical power outages • Uninterruptible Power Supply (UPS) failure • Obvious and significant network service or access failures • Violations of eSign- Online Electronic Signature Service	1. For sample audit records check the following are covered under anomalies: a. Software error conditions b. Software check integrity failures c. Receipt of improper messages d. Misrouted messages e. Network attacks (suspected or confirmed) f. Equipment failure g. Electrical power outages h. Uninterruptible Power Supply (UPS) failure i. Obvious and significant network service or access failures j. Violations of eSign- Online Electronic Signature Service	Mandatory	e-authentication guidelines for eSign			
3.8.10.16	The following events shall be covered under Auditable Event/ Audit	1. For sample audit records check the following are covered under Auditable Event/ Audit Criteria(ESP) for reports: a. Agreement between ESP e-KYC Provider and its Compliance audit report	Mandatory	e-authentication guidelines for eSign			

COPY - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	Criteria(ESP) for reports: • Agreement between ESP e-KYC Provider and its Compliance audit report • Report of Vulnerability Assessment and Penetration Test • Agreement between ESP-ASP • Compliance audit report of ASP • Any other applicable agreements and its compliance reports	b. Report of Vulnerability Assessment and Penetration Test c. Agreement between ESP-ASP d. Compliance audit report of ASP e. Any other applicable agreements and its compliance reports					
3.8.10.17	The following events shall be audited in respect of eSign service: • The isolation of CA system used for issuing e-KYC class from the CA system used for issuing other classes of DSCs • Digitally signed Certificate Signing Request (CSR) from ESP systems • Ensuring no DSCs other than e-KYC class of certificates are issued from ESP • Secure communication between ESP and CA system	1. For sample audit records check the following events are audited as part of eSign service: a. The isolation of CA system used for issuing e-KYC class from the CA system used for issuing other classes of DSCs b. Digitally signed Certificate Signing Request (CSR) from ESP systems c. Ensuring no DSCs other than e-KYC class of certificates are issued from ESP d. Secure communication between ESP and CA system	Mandatory	e-authentication guidelines for eSign			
Frequency of Processing Audit Logs							
3.8.10.18	Frequency of ESP audit log processing shall be in accordance with the requirements set for the CAs in Section 5.4.2 of the [CCACP].	1. Validate the frequency of ESP audit log processing are in accordance with the requirements set for the CAs in Section 5.4.2 of the [CCACP].	Mandatory	e-authentication guidelines for eSign			
Retention Period for Audit Logs and Archive							
3.8.10.19	The minimum retention periods for archive data are listed below for the various assurance levels.	1. For samples of archived data, verify the minimum retention period is as listed in control 3.9.10.19 2. Check in cases where original media cannot retain the data for the required period, a mechanism to periodically	Mandatory	e-authentication guidelines for eSign			

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	• e-KYC OTP Single Factor - 7 Years • e-KYC Multi Factor - 7 Years	transfer the archived data to new media is defined. 3. Verify applications required to process the archive data are maintained for the minimum retention period specified in control 3.9.10.19					
3.8.10.20	If the original media cannot retain the data for the required period, a mechanism to periodically transfer the archived data to new media shall be defined. Applications required to process the archive data shall also be maintained for the minimum retention period specified above	1. For samples of archived data, verify the minimum retention period is as listed in control 3.9.10.19 2. Check in cases where original media cannot retain the data for the required period, a mechanism to periodically transfer the archived data to new media is defined. 3. Verify applications required to process the archive data are maintained for the minimum retention period specified in control 3.9.10.19	Mandatory	e-authentication guidelines for eSign			
Protection of Audit Logs							
3.8.10.21	Protection of ESP audit log shall be in accordance with the requirements set for the CAs in Section 5.4.4 of the [CCA-CP].	1. Validate ESP audit logs are protected in accordance with the requirements set for the CAs in Section 5.4.4 of the [CCA-CP]	Mandatory	e-authentication guidelines for eSign			
Audit Log Backup Procedures							
3.8.10.22	Audit logs and audit summaries shall be archived per requirements mentioned in control 3.9.10.19	1. For sample records check the audit logs and audit summaries are archived as per control 3.9.10.19	Mandatory	e-authentication guidelines for eSign			
Audit Collection System (internal vs. external)							
3.8.10.23	ESP audit collection requirements shall be in accordance with the requirements set for the CAs in Section 5.4.6 of the [CCA-CP]	1. Validate the ESP audit collection requirements is in accordance with the requirements set for the CAs in Section 5.4.6 of the [CCA-CP]	Mandatory	e-authentication guidelines for eSign			
Records Archival							
3.8.10.24	Types of Records Archived - ESP's archival of records	1. Validate the following on sample basis	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	shall be sufficiently detailed to establish the proper operation of the ESP Service or the validity of any signature generated by ESP.	for the record archival process a. ESP's archival of records is sufficiently detailed to establish the proper operation of the ESP Service or the validity of any signature generated by ESP b. All data covered in control 3.9.10.25 is archived by CA or ESP c. archive retention period for ESP Service is same as those listed for CA in Section 5.5.2 of the [CCACP]. d. Protection of ESP Service archives is same as those listed for CA in Section 5.5.3 of the [CCACP]. e. Archived records are time stamped such that order of events can be determined f. eSign- Online Electronic Signature Service can be reestablish as soon as possible in case of a Disaster. Check the disaster recovery plan g. Form C is archived in machine readable or human readable format (XML or PDF) with a digital signature of ESP. h. Forms is versioned and stored to provide a complete history of compliance. i. CA has established a managed process for creating, maintaining, and verifying archive					
3.8.10.25	Data To Be Archived (CA Or ESP) • Contractual obligations • System and equipment configuration • Modifications and updates to system or configuration • eSign- Digital Signature signing requests • eSign user's Digital Signature and Certificate • Response received from e-KYC Services and DSC application form • Record of eSign-Digital Signature signing Re-key • All Audit Logs • All Audit Log Summaries • Other data or applications to verify archive contents • Compliance audit reports •	1. Validate the following on sample basis for the record archival process a. ESP's archival of records is sufficiently detailed to establish the proper operation of the ESP Service or the validity of any signature generated by ESP b. All data covered in control 3.9.10.25 is archived by CA or ESP c. archive retention period for ESP Service is same as those listed for CA in Section 5.5.2 of the [CCACP]. d. Protection of ESP Service archives is same as those listed for CA in Section 5.5.3 of the [CCACP]. e. Archived records are time stamped such that order of events can be determined f. eSign- Online Electronic Signature Service can be reestablish as soon as possible in case of a Disaster. Check the disaster recovery plan g. Form C is archived in machine readable or human readable format (XML or PDF) with a digital signature of ESP. h. Forms is versioned and stored to provide a complete history of compliance. i. CA has established a managed process for creating, maintaining, and verifying archive	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.8.10.26	Retention Period for Archive - The archive retention period for ESP Service shall be the same as those listed for CA in Section 5.5.2 of the [CCACP].	1. Validate the following on sample basis for the record archival process a. ESP's archival of records is sufficiently detailed to establish the proper operation of the ESP Service or the validity of any signature generated by ESP b. All data covered in control 3.9.10.25 is archived by CA or ESP c. archive retention period for ESP Service is same as those listed for CA in Section 5.5.2 of the [CCACP]. d. Protection of ESP Service archives is same as those listed for CA in Section 5.5.3 of the [CCACP]. e. Archived records are time stamped such that order of events can be determined f. eSign- Online Electronic Signature Service can be reestablish as soon as possible in case of a Disaster. Check the disaster recovery plan g. Form C is archived in machine readable or human readable format (XML or PDF) with a digital signature of ESP. h. Forms is versioned and stored to provide a complete history of compliance. i. CA has established a managed process for creating, maintaining, and verifying archive	Mandatory	e-authentication guidelines for eSign			
3.8.10.27	Protection of Archive - Protection of ESP Service archives shall be the same as those listed for CA in Section 5.5.3 of the [CCACP].	1. Validate the following on sample basis for the record archival process a. ESP's archival of records is sufficiently detailed to establish the proper operation of the ESP Service or the validity of any signature generated by ESP b. All data covered in control 3.9.10.25 is archived by CA or ESP c. archive retention period for ESP Service is same as those listed for CA in Section 5.5.2 of the [CCACP]. d. Protection of ESP Service archives is same as those listed for CA in Section 5.5.3 of the [CCACP]. e. Archived records are time stamped such that order of events can be determined f. eSign- Online Electronic Signature Service can be reestablish as soon as possible in case of a Disaster. Check the disaster recovery plan g. Form C is archived in machine readable or human readable format (XML or PDF) with a digital signature of ESP. h. Forms is versioned and stored to provide a complete history of compliance. i. CA has established a managed process for creating, maintaining, and verifying archive	Mandatory	e-authentication guidelines for eSign			
3.8.10.28	Requirements for eSign- Online		Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	Electronic Signature Service records - Archived records shall be time stamped such that order of events can be determined.	1. Validate the following on sample basis for the record archival process a. ESP's archival of records is sufficiently detailed to establish the proper operation of the ESP Service or the validity of any signature generated by ESP b. All data covered in control 3.9.10.25 is archived by CA or ESP c. archive retention period for ESP Service is same as those listed for CA in Section 5.5.2 of the [CCACP]. d. Protection of ESP Service archives is same as those listed for CA in Section 5.5.3 of the [CCACP]. e. Archived records are time stamped such that order of events can be determined f. eSign- Online Electronic Signature Service can be reestablish as soon as possible in case of a Disaster. Check the disaster recovery plan g. Form C is archived in machine readable or human readable format (XML or PDF) with a digital signature of ESP. h. Forms is versioned and stored to provide a complete history of compliance. i. CA has established a managed process for creating, maintaining, and verifying archive					
3.8.10.29	Business Continuity Capabilities after a Disaster - In the case of a disaster whereby a ESP Service installation is physically damaged and all copies of the eSign-Online Electronic Signature Service Signing Key are destroyed as a result, the eSign-Online Electronic Signature Service shall reestablish services as soon as practical	1. Validate the following on sample basis for the record archival process a. ESP's archival of records is sufficiently detailed to establish the proper operation of the ESP Service or the validity of any signature generated by ESP b. All data covered in control 3.9.10.25 is archived by CA or ESP c. archive retention period for ESP Service is same as those listed for CA in Section 5.5.2 of the [CCACP]. d. Protection of ESP Service archives is same as those listed for CA in Section 5.5.3 of the [CCACP]. e. Archived records are time stamped such that order of events can be determined f. eSign- Online Electronic Signature Service can be reestablish as soon as possible in case of a Disaster. Check the disaster recovery plan g. Form C is archived in machine readable or human readable format (XML or PDF) with a digital signature of ESP. h. Forms is versioned and stored to provide a complete history of compliance. i. CA has established a managed process for creating, maintaining, and verifying archive	Mandatory	e-authentication guidelines for eSign			
3.8.10.30	Archival Format. - The Form C should be archived in machine readable	1. Validate the following on sample basis for the record archival process	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	or human readable format (XML or PDF) with a digital signature of ESP. The forms should be versioned and stored to provide a complete history of compliance.CA must have managed process for creating, maintaining, and verifying archive.	a. ESP's archival of records is sufficiently detailed to establish the proper operation of the ESP Service or the validity of any signature generated by ESP b. All data covered in control 3.9.10.25 is archived by CA or ESP c. archive retention period for ESP Service is same as those listed for CA in Section 5.5.2 of the [CCACP]. d. Protection of ESP Service archives is same as those listed for CA in Section 5.5.3 of the [CCACP]. e. Archived records are time stamped such that order of events can be determined f. eSign- Online Electronic Signature Service can be reestablish as soon as possible in case of a Disaster. Check the disaster recovery plan g. Form C is archived in machine readable or human readable format (XML or PDF) with a digital signature of ESP. h. Forms is versioned and stored to provide a complete history of compliance. i. CA has established a managed process for creating, maintaining, and verifying archive					

3.8.11. eKYC Service Modes

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
eKYC Service Modes							
3.8.11.1	The eSign service will have two modes of verification of eSign user. Online Aadhaar eKYC authentication (API 2.x version) of eSign user is facilitated by CA	1. For eKYC Service Modes, verify the following: a. eSign service has only two modes of verification of eSign user. b. Online Aadhaar eKYC authentication (API 2.x version) of eSign user is facilitated by CA c. Offline Aadhaar eKYC authentication(API 3.x version) is carried out by eSign user and authentication response is submitted to CA. d. CA further confirms the submission and accepts the same. e. Offline Aadhaar eKYC authentication of eSign user requires one time registration. f. procedure for registration given in the IVG section 5 is followed. g. eKYC accounts of registered and verified users are used for eSign	Mandatory	e-authentication guidelines for eSign			
3.8.11.2	Offline Aadhaar eKYC authentication(API 3.x version) will be carried out by eSign user and authentication response will be	1. For eKYC Service Modes, verify the following: a. eSign service has only two modes of verification of eSign user. b. Online Aadhaar eKYC authentication (API 2.x version) of eSign user is facilitated by CA c. Offline Aadhaar eKYC	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

	submitted to CA. CA further confirm the submission and accept the same. Offline Aadhaar eKYC authentication of eSign user requires one time registration.	authentication(API 3.x version) is carried out by eSign user and authentication response is submitted to CA. d. CA further confirms the submission and accepts the same. e. Offline Aadhaar eKYC authentication of eSign user requires one time registration. f. procedure for registration given in the IVG section 5 is followed. g. eKYC accounts of registered and verified users are used for eSign					
3.8.11.3	The procedure to be followed for registration is given in the IVG section 5. The API specification for interface with ESP is specified under eSign API version 3.x. The eKYC accounts of registered and verified users are used for eSign	1. For eKYC Service Modes, verify the following: a. eSign service has only two modes of verification of eSign user. b. Online Aadhaar eKYC authentication (API 2.x version) of eSign user is facilitated by CA c. Offline Aadhaar eKYC authentication(API 3.x version) is carried out by eSign user and authentication response is submitted to CA. d. CA further confirms the submission and accepts the same. e. Offline Aadhaar eKYC authentication of eSign user requires one time registration. f. procedure for registration given in the IVG section 5 is followed. g. eKYC accounts of registered and verified users are used for eSign	Mandatory	e-authentication guidelines for eSign			
3.8.11.4	This section is applicable to CA that maintains eKYC accounts of registered users. ESP use registered & verified information of eSign user retained on eKYC system for eSign service. CA may also use the same verified user information for DSC issuance. In both cases, two factor authentications is required for CA or ESP to use the eKYC account holder's information retained in the eKYC account held by CA.	1. Verify the ESP uses registered & verified information of eSign user retained on eKYC system for eSign service 2. Validate two factor authentication is implemented to use the eKYC account holder's information retained in the eKYC account held by CA.	Mandatory	e-authentication guidelines for eSign			

3.8.12. CA eKYC Implementation Requirements

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

eKYC Service Modes							
Data Protection and Privacy							
3.8.12.1	eKYC Data Protection - eKYC data protection should be part of the design and implementation of eKYC systems, services, products and practices	1. Verify eKYC data protection is part of the design and implementation of eKYC systems, services, products and practices 2. Validate the eKYC user's account information is used only for DSC issuance and authentication purpose only 3. Check by reviewing reports, the risk assessment of eKYC system is carried out and security measures are in place 4. Verify eKYC system is made operational only after Risk assessment, VA/PT and Audit	Mandatory	e-authentication guidelines for eSign			
3.8.12.2	Privacy of eKYC Data - Ensure to process the data that is necessary to achieve specific eKYC user's account management & authentication. The eKYC user's account information should be used only for DSC issuance and authentication purpose only.	1. Verify eKYC data protection is part of the design and implementation of eKYC systems, services, products and practices 2. Validate the eKYC user's account information is used only for DSC issuance and authentication purpose only 3. Check by reviewing reports, the risk assessment of eKYC system is carried out and security measures are in place 4. Verify eKYC system is made operational only after Risk assessment, VA/PT and Audit	Mandatory	e-authentication guidelines for eSign			
3.8.12.3	Risk Assessment - Risk assessment of eKYC system should have carried out and security measures should be in place	1. Verify eKYC data protection is part of the design and implementation of eKYC systems, services, products and practices 2. Validate the eKYC user's account information is used only for DSC issuance and authentication purpose only 3. Check by reviewing reports, the risk assessment of eKYC system is carried out and security measures are in place 4. Verify eKYC system is made operational only after Risk assessment, VA/PT and Audit	Mandatory	e-authentication guidelines for eSign			
3.8.12.4	Operational Requirements - The eKYC system should have made operational only after Risk assessment, VA/PT and Audit.	1. Verify eKYC data protection is part of the design and implementation of eKYC systems, services, products and practices 2. Validate the eKYC user's account information is used only for DSC issuance and authentication purpose only 3. Check by reviewing reports, the risk assessment of eKYC system is carried out and security measures are in place 4. Verify eKYC system is made operational only after Risk assessment, VA/PT and Audit	Mandatory	e-authentication guidelines for eSign			
Identification							

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.8.12.5	Transaction ID - Generated by ASP calling the API, this is logged and returned in the output for correlation. Should be unique for the given ASP-ESP combination	1. Verify the transaction ID is unique for the ASP-ESP combination 2. Validate the response code is a part of DSC and is of length 32 3. Check the CA permits eSign signer to have one or more eKYC user account	Mandatory	e-authentication guidelines for eSign			
3.8.12.6	Response Code - Generated by ESP on eKYC user authentication request and should be a part of DSC . The Response Code should be of length 32.	1. Verify the transaction ID is unique for the ASP-ESP combination 2. Validate the response code is a part of DSC and is of length 32 3. Check the CA permits eSign signer to have one or more eKYC user account	Mandatory	e-authentication guidelines for eSign			
3.8.12.7	eKYC user ID - eSign signer can have one or more eKYC user account	1. Verify the transaction ID is unique for the ASP-ESP combination 2. Validate the response code is a part of DSC and is of length 32 3. Check the CA permits eSign signer to have one or more eKYC user account	Mandatory	e-authentication guidelines for eSign			
eKYC System security							
3.8.12.8	Network Security - The e-KYC services systems (database) must be configured as secure systems as per the definitions of IT Act and should not have direct interface with system other than eKYC Server. The communication between eKYC server and e-KYC service systems (database) should be in request response mode	1. For sample eKYC services systems (database), check the systems are configured as secure systems as per the definitions of IT Act and do not have direct interface with system other than eKYC Server. 2. Verify the communication between eKYC server and e-KYC service systems (database) is in request response mode 3. Check the CA e-KYC service systems are dedicated only for e-KYC service purpose	Mandatory	e-authentication guidelines for eSign			
3.8.12.9	Dedicated for the Purpose - The CA e-KYC service systems should be dedicated only for e-KYC service purpose	1. For sample eKYC services systems (database), check the systems are configured as secure systems as per the definitions of IT Act and do not have direct interface with system other than eKYC Server. 2. Verify the communication between eKYC server and e-KYC service systems (database) is in request response mode 3. Check the CA e-KYC service systems are dedicated only for e-	Mandatory	e-authentication guidelines for eSign			

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		KYC service purpose					
eKYC Account Management							
3.8.12.10	eKYC User authentication - The authentication should be carried out using OTP sent to registered mobile eSign user and PIN. Access Token registered for the mobile Application based on OTP and PIN	1. Validate the eKYC user authentication is carried out using OTP sent to registered mobile eSign user and PIN and access Token is registered for the mobile Application based on OTP and PIN 2. Validate the e-KYC request is as per the format specified in eSign API specifications and ESP sends digitally signed eKYC Request with ESP's key. 3. Verify the e-KYC response is as per the format specified in eSign API specifications and the response is digitally signed using a CA eKYC System key 4. Check on sample basis OTP or Mobile Token Response is sent with purpose and Request and Response are preserved 5. Verify clear text transmission, storage or capture of passwords, maintain audit trails, and lock the account after repeated unsuccessful attempts are not allowed for PIN Management 6. Check CA has implemented mechanism for eKYC user to set eKYC user id and PIN and the PIN is of 6 characters in length 7. Validate the OTP and Mobile Access token verified along with PURPOSE text is deemed as consent	Mandatory	e-authentication guidelines for eSign			
3.8.12.11	ESP e-KYC Request to CA e-KYC System - The e-KYC request should be as per the format specified in eSign API specifications ESP should send digitally signed eKYC Request with ESP's key.	1. Validate the eKYC user authentication is carried out using OTP sent to registered mobile eSign user and PIN and access Token is registered for the mobile Application based on OTP and PIN 2. Validate the e-KYC request is as per the format specified in eSign API specifications and ESP sends digitally signed eKYC Request with ESP's key. 3. Verify the e-KYC response is as per the format specified in eSign API specifications and the response is digitally signed using a CA eKYC System key 4. Check on sample basis OTP or Mobile Token Response is sent with purpose and Request and Response are preserved 5. Verify clear text transmission, storage or capture of passwords, maintain audit trails, and lock the account after repeated unsuccessful attempts are not allowed for PIN Management 6. Check CA has implemented mechanism for eKYC user to set eKYC user id and PIN and the PIN is of 6 characters in length 7. Validate the OTP and Mobile Access token verified along with PURPOSE text is deemed as consent	Mandatory	e-authentication guidelines for eSign			
3.8.12.12	e-KYC response to ESP - The e-KYC response should be as per	1. Validate the eKYC user authentication is carried out using OTP sent to registered mobile eSign user and PIN and access Token is registered for the mobile Application	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	the format specified in eSign API specifications. The response should be digitally signed using a CA eKYC System key	based on OTP and PIN 2. Validate the e-KYC request is as per the format specified in eSign API specifications and ESP sends digitally signed eKYC Request with ESP's key. 3. Verify the e-KYC response is as per the format specified in eSign API specifications and the response is digitally signed using a CA eKYC System key 4. Check on sample basis OTP or Mobile Token Response is sent with purpose and Request and Response are preserved 5. Verify clear text transmission, storage or capture of passwords, maintain audit trails, and lock the account after repeated unsuccessful attempts are not allowed for PIN Management 6. Check CA has implemented mechanism for eKYC user to set eKYC user id and PIN and the PIN is of 6 characters in length 7. Validate the OTP and Mobile Access token verified along with PURPOSE text is deemed as consent					
3.8.12.13	OTP or Mobile Token Authentication - Each OTP or Mobile Token Response should be sent with purpose and Request and Response should be preserved	1. Validate the eKYC user authentication is carried out using OTP sent to registered mobile eSign user and PIN and access Token is registered for the mobile Application based on OTP and PIN 2. Validate the e-KYC request is as per the format specified in eSign API specifications and ESP sends digitally signed eKYC Request with ESP's key. 3. Verify the e-KYC response is as per the format specified in eSign API specifications and the response is digitally signed using a CA eKYC System key 4. Check on sample basis OTP or Mobile Token Response is sent with purpose and Request and Response are preserved 5. Verify clear text transmission, storage or capture of passwords, maintain audit trails, and lock the account after repeated unsuccessful attempts are not allowed for PIN Management 6. Check CA has implemented mechanism for eKYC user to set eKYC user id and PIN and the PIN is of 6 characters in length 7. Validate the OTP and Mobile Access token verified along with PURPOSE text is deemed as consent	Mandatory	e-authentication guidelines for eSign			
3.8.12.14	PIN Management - For PIN management, do not allow clear text transmission, storage or capture of passwords, maintain audit trails, and lock the account after repeated unsuccessful attempts. CA	1. Validate the eKYC user authentication is carried out using OTP sent to registered mobile eSign user and PIN and access Token is registered for the mobile Application based on OTP and PIN 2. Validate the e-KYC request is as per the format specified in eSign API specifications and ESP sends digitally signed eKYC Request with ESP's key. 3. Verify the e-KYC response is as per the format specified in eSign API specifications and the response is digitally signed using a CA eKYC System key 4. Check on sample basis OTP or Mobile	Mandatory	e-authentication guidelines for eSign			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	should implement mechanism for eKYC user to set eKYC user id and PIN. PIN shall be 6 characters in length	Token Response is sent with purpose and Request and Response are preserved 5. Verify clear text transmission, storage or capture of passwords, maintain audit trails, and lock the account after repeated unsuccessful attempts are not allowed for PIN Management 6. Check CA has implemented mechanism for eKYC user to set eKYC user id and PIN and the PIN is of 6 characters in length 7. Validate the OTP and Mobile Access token verified along with PURPOSE text is deemed as consent					
3.8.12.15	Consent - The OTP and Mobile Access token verified along with PURPOSE text is deemed as consent	1. Validate the eKYC user authentication is carried out using OTP sent to registered mobile eSign user and PIN and access Token is registered for the mobile Application based on OTP and PIN 2. Validate the e-KYC request is as per the format specified in eSign API specifications and ESP sends digitally signed eKYC Request with ESP's key. 3. Verify the e-KYC response is as per the format specified in eSign API specifications and the response is digitally signed using a CA eKYC System key 4. Check on sample basis OTP or Mobile Token Response is sent with purpose and Request and Response are preserved 5. Verify clear text transmission, storage or capture of passwords, maintain audit trails, and lock the account after repeated unsuccessful attempts are not allowed for PIN Management 6. Check CA has implemented mechanism for eKYC user to set eKYC user id and PIN and the PIN is of 6 characters in length 7. Validate the OTP and Mobile Access token verified along with PURPOSE text is deemed as consent	Mandatory	e-authentication guidelines for eSign			
Audit Requirements							
3.8.12.16	Audit Trail of Account Creation and Maintenance - The audit trail of eKYC account creation, modification, suspension, deletion etc should be maintained by CA with the details of authorised individual who carried out the operation. The date/time stamp, requested source details etc. also should be accessible for audit	1. Verify the CA maintains audit trail of eKYC account creation, modification, suspension, deletion etc. with the details of authorised individual who carried out the operation. 2. Validate the date/time stamp, requested source details etc. also are accessible for audit 3. On sample basis, check a monthly audit of ten percent (subjected to maximum of 5000) of the eKYC account creation & modification has been carried out by an IS Auditor in the following month and the report is made available during Annual CA compliance Audit	Mandatory	e-authentication guidelines for eSign			

CCA AUDIT REPORT

3.8.12.17	A monthly audit of ten percent (subjected to maximum of 5000) of the eKYC account creation & modification should be carried out by an IS Auditor in the following month and the report should be made available during Annual CA compliance Audit	1. Verify the CA maintains audit trail of eKYC account creation, modification, suspension, deletion etc. with the details of authorised individual who carried out the operation. 2. Validate the date/time stamp, requested source details etc. also are accessible for audit 3. On sample basis, check a monthly audit of ten percent (subjected to maximum of 5000) of the eKYC account creation & modification has been carried out by an IS Auditor in the following month and the report is made available during Annual CA compliance Audit	Mandatory	e-authentication guidelines for eSign			
Account Monitoring facility to eKYC user							
3.8.12.18	The history of eKYC account changes should be made available to eKYC users	1. Verify history of eKYC account changes is made available to eKYC users 2. Validate ESP provides access to the signed transaction details to eSign users 3. Check the ASP provides mechanism to eSign users for viewing the signed documents.	Mandatory	e-authentication guidelines for eSign			
3.8.12.19	ESP should provide access to the signed transaction details to eSign users	1. Verify history of eKYC account changes is made available to eKYC users 2. Validate ESP provides access to the signed transaction details to eSign users 3. Check the ASP provides mechanism to eSign users for viewing the signed documents.	Mandatory	e-authentication guidelines for eSign			
3.8.12.20	ASP should provide mechanism for viewing the signed documents to eSign users.	1. Verify history of eKYC account changes is made available to eKYC users 2. Validate ESP provides access to the signed transaction details to eSign users 3. Check the ASP provides mechanism to eSign users for viewing the signed documents.	Mandatory	e-authentication guidelines for eSign			
3.8.12.21	The history of certificate issuance, setting PIN, & signature of documents shall be made available to subscribers.	Verify the history of certificate issuance, setting PIN, & signature of documents are available to subscribers.	Mandatory	e-authentication guidelines for eSign			
3.8.12.22	CA shall provide access to the signed transaction details to subscribers	Check the access to the signed transaction details to subscribers is provided by CA	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.8.12.23	ASP should provide mechanism for viewing the signed documents to eSign users.	Verify audit report of ASP and check whether ASP provided mechanism for viewing the signed documents to eSign users	Mandatory	e-authentication guidelines for eSign			

3.8.13. e-Authentication & Electronic Signature Guidelines for Remote Key-Storage

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
General Requirements							
3.8.13.1	In order to provide the assurance of sole control over the private key of subscriber in a remote secure device, the authentication for activating the private key for signature function shall be secure and reliable. The authentication data shall be communicated to the HSM managing the private key in a secure manner. The authentication software/firmware shall be executed in the area protected by HSM securing the subscriber private key.	Verify the following 1. Authentication data is communicated to the HSM managing the private key in a secure manner. 2. the authentication software/firmware is executed in the area protected by HSM securing the subscriber private key.	Mandatory	e-authentication guidelines for eSign			
3.8.13.2	The requirements for creation, management and authentication to eKYC account of subscribers and signature creation based on the one time key pair generation and short validity certificates are specified in the earlier sections. The objective of this section is to specify the requirements for ESPs to act as a trusted third party for keeping the subscriber private keys and associated public key certificate. The	Verify the following 1. authentication to eKYC account of subscribers and signature creation based on the one time key pair generation and short validity certificates are in accordance with e- authentication guidelines 2. the aspects relating to empanelment, signature generation, certificate & signature standards are the same as eSign service for short validity certificate based electronic signature	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

	deviation and additional requirements of subscriber private key life cycle management are described in this section. All other aspects relating to empanelment, signature generation, certificate & signature standards are the same as eSign service for short validity certificate based electronic signature.						
3.8.13.3	The overall functionality of the remote key-storage based solution is similar to EU standards (eIDAS, QSCD), however the actual implementation is specific to India PKI based on the architecture & protocol level implementation detailed in the eSign Remote API 1.0.	Check the CA implementation is based on the architecture & protocol level implementation detailed in the eSign Remote API 1.0.	Mandatory	e-authentication guidelines for eSign			
3.8.13.4	As in the case of crypto token, HSM based remote key-storage also shall use PIN as primary authentication. The additional modes of authentication shall be used at eKYC account level by CAs. The ESP/TTP shall use additional modes of authentication at application level before redirecting user to HSM secure key access environment.	Verify that at least two modes of authentication is used , the PIN as primary authentication for HSM key access and one at eKYC account level.	Mandatory	e-authentication guidelines for eSign			
Security Procedure For Protection of Subscriber's Key							
3.8.13.5	For securing private keys of subscriber whether CA implemented any	Check the additional functionalities apart from the requirements as mentioned in this document, if so provide details	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	additional functionalities apart from the requirements as mentioned in this document.						
HSM functionality							
3.8.13.6	A Hardware Security Module (HSM) to ensure the security and subscriber control of private key. The HSM used for securing private keys of subscribers shall be at least FIPS 140-2 Level 3 validated/certified. In addition to generation, authentication, and usage of subscriber private keys, the HSM shall support SAM for secure execution of code.	Check the following 1. HSMs used for securing private keys of subscribers are at least FIPS 140-2 Level 3 validated/certified 2. HSM support SAM for secure execution of code in addition to generation, authentication, and usage of subscriber private keys	Mandatory	e-authentication guidelines for eSign			
3.8.13.7	HSM shall be capable of implementing a secure channel establishment protocol stack for secure subscriber authentication data using secure communication protocol stacks like: TLS 1.2, TLS 1.3 or others offering similar or higher security.	Verify HSM is capable of implementing a secure channel establishment protocol stack for secure subscriber authentication data using secure communication protocol stacks like: TLS 1.2, TLS 1.3 or others offering similar or higher security.	Mandatory	e-authentication guidelines for eSign			
3.8.13.8	The HSM shall not permit export or output of subscriber private keys in any form except for the backup of the entire HSM.	Validate HSM not permit export or output of subscriber private keys in any form except for the backup of the entire HSM.	Mandatory	e-authentication guidelines for eSign			
3.8.13.9	For synchronization of keys in HSM between Main and DR site, FIPS certified synchronization features of HSM	Validate the synchronization of keys in HSM between Main and DR site, use FIPS certified synchronization features of HSM only	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	shall be used.						
Subscriber Authentication Module (SAM)							
3.8.13.10	Subscriber Authentication Module (SAM) is software which shall reside in the tamper proof environment protected by HSM. SAM shall utilize the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication.	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination, architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM) reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM, 4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions 7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session 8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.	Mandatory	e-authentication guidelines for eSign			

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.8.13.11	In the SAM, the software functions such as creation, destruction, signing, authentication shall be implemented as independent modules under an integrated module.	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination, architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM) reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM, 4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions 7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session 8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.	Mandatory	e-authentication guidelines for eSign			
3.8.13.12	The verification of authentication code must not be executed by any application other	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination,	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	than that reside in SAM	architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM) reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM, 4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions 7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session 8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.					
3.8.13.13	CA shall provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination, architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM)	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM, 4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions 7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session 8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.					
3.8.13.14	SAM shall verify the authentication of subscriber before facilitating any subscriber bound functions	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination, architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM) reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including	Mandatory	e-authentication guidelines for eSign			

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM, 4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions 7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session 8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.					
3.8.13.15	Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin shall be implemented in a single secure session thus providing binding among the subscriber, subscriber’s key pair, and Authpin.	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination, architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM) reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM,	Mandatory	e-authentication guidelines for eSign			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions 7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session 8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.					
3.8.13.16	HSM shall receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM.	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination, architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM) reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM, 4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the	Mandatory	e-authentication guidelines for eSign			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions 7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session 8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.					
3.8.13.17	CA/ESP shall not deploy any software code components in the SAM which are not assessed by the empaneled experts.	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination, architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM) reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM, 4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions	Mandatory	e-authentication guidelines for eSign			

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session 8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.					
3.8.13.18	SAM shall perform authentication of end user using SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104. Alternative authentication protocols shall offer at least as much security	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination, architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM) reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM, 4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions 7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session	Mandatory	e-authentication guidelines for eSign			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.					
3.8.13.19	The code to be deployed in the SAM shall be digitally signed by CA after security and software code level auditing to ensure security and reliability. The software testing shall be carried out by authorized cert-in empanelled experts. If the SAM functions are natively build in the HSM and certified , the same need not to be examined and tested by the empanelled experts.	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination, architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM) reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM, 4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions 7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session 8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components	Mandatory	e-authentication guidelines for eSign			

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.					
3.8.13.20	The logs of software changes / installations made in the SAM shall be archived.	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination, architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM) reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM, 4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions 7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session 8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance	Mandatory	e-authentication guidelines for eSign			

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.					
3.8.13.21	CA/ESP shall have dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM should host in KMS. All the communication to KMS server shall be in a request/response format.	The requirements mentioned in this section may be examined and verified by the means of one of more of the following : logs generated, code examination, product specification, input/output examination, architecture design , software audit report by cert-in empanelled auditor and testing Verify the following are implemented by CA and examine the proof if applicable:- 1. Subscriber Authentication Module (SAM) reside in the tamper proof environment protected by HSM 2. SAM is utilizing the secure channel interface through KMS to securely communicate with the subscribers, including the subscriber authentication. 3. the software functions such as creation, destruction, signing, authentication is implemented as independent modules under an integrated module in the SAM, 4. the authentication code is not executed by any application other than that reside in SAM 5. CA provide access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 6. SAM verify the authentication of subscriber before facilitating any subscriber bound functions 7. Subscriber actions such as communicating with the HSM for PKCS-10 request generation, obtaining the PKCS-10 from the HSM, and setting the Authpin is implemented in a single secure session 8. HSM receive the authentication code submitted by subscribers in an encrypted form by the public key corresponding to the private key generated in the HSM 9. No software code components aredeployed in SAM which is not assessed by the empanelled experts. 10. For authentication of end user , SAM use SHA-256 hash of Authpin and a random number of 128 bits or longer in accordance with RFC 2104 or alternative authentication protocols that offer at least as much security 11. The code to be deployed in the SAM is digitally signed by CA 12. The compliance report of authorized	Mandatory	e-authentication guidelines for eSign			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		cert-in empanelled experts and no non-compliance are present. 13. The logs of software changes / installations made in the SAM are archived. 14. CA/ESP have deployed dedicated Key Management Server (KMS) to interface with HSM/ SAM and the software module interfacing directly with HSM/SAM sis hosted in KMS. 15. All the communication to KMS server are in a request/response format.					
Key generation & management							
3.8.13.22	The CA shall facilitate key pair generation by the subscriber under subscriber's direct control after successful authentication to eKYC account. The Authpin for subsequent successful authorization should be set by the subscriber.	Check the following are implemented by CA and examine the input/out , sample testing if applicable 1. The CA generates key pair for subscriber only after successful authentication to subscriber's eKYC account. 2. The Authpin for subsequent successful authorization is set by the subscriber 3. The HSM securing the private key of subscriber is physically hosted at CA premises or application owner' s premises. 4. HSM securing the private keys of subscribers is under the sole administrative control of CA. 5. The key generation is in the FIPS 140- 2 Level 3 validated/certified HSM. 6. Private keys are always be secured by HSM 7. The HSM administrator of the hosting environment cannot perform the subscriber's key authentication function 8. For any key management functions eKYC account id, eKYC account PIN and Authpin authentications is required 9. A single session is used for all subscriber actions such as communicating with the HSM for PKCS-10 generation, obtaining PKCS- 10 from the HSM, and setting the Authpin . 10. CA provides secure session access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 11. The key management function by CA is limited only to deletion backup and restore 12. The private key can be deleted by the subscriber directly or by CA as per the scenarios mentioned under CPS. i.e the private key shall be deleted after revocation. 13. The private key is retained by the HSM beyond the certificate validity period. 14. The certificate renewal, re-key suspension etc., are not allowed under this scheme	Mandatory	e-authentication guidelines for eSign			
3.8.13.23	The HSM securing the private keys of subscribers shall be physically hosted in	Check the following are implemented by CA and examine the input/out , sample testing if applicable 1. The CA generates key pair for subscriber	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

	the CA premises or application owners premises however it should be under the sole administrative control of CA.	only after successful authentication to subscriber's eKYC account. 2. The Authpin for subsequent successful authorization is set by the subscriber 3. The HSM securing the private key of subscriber is physically hosted at CA premises or application owner' s premises. 4. HSM securing the private keys of subscribers is under the sole administrative control of CA. 5. The key generation is in the FIPS 140- 2 Level 3 validated/certified HSM. 6. Private keys are always be secured by HSM 7. The HSM administrator of the hosting environment cannot perform the subscriber's key authentication function 8. For any key management functions eKYC account id, eKYC account PIN and Authpin authentications is required 9. A single session is used for all subscriber actions such as communicating with the HSM for PKCS-10 generation, obtaining PKCS- 10 from the HSM, and setting the Authpin . 10. CA provides secure session access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 11. The key management function by CA is limited only to deletion backup and restore 12. The private key can be deleted by the subscriber directly or by CA as per the scenarios mentioned under CPS. i.e the private key shall be deleted after revocation. 13. The private key is retained by the HSM beyond the certificate validity period. 14. The certificate renewal, re-key suspension etc., are not allowed under this scheme					
3.8.13.24	The key generation shall be in the FIPS 140-2 Level 3 validated/certified HSM. Private keys shall always be secured by HSM	Check the following are implemented by CA and examine the input/out , sample testing if applicable 1. The CA generates key pair for subscriber only after successful authentication to subscriber's eKYC account. 2. The Authpin for subsequent successful authorization is set by the subscriber 3. The HSM securing the private key of subscriber is physically hosted at CA premises or application owner' s premises. 4. HSM securing the private keys of subscribers is under the sole administrative control of CA. 5. The key generation is in the FIPS 140- 2 Level 3 validated/certified HSM. 6. Private keys are always be secured by HSM 7. The HSM administrator of the hosting environment cannot perform the subscriber's key authentication function	Mandatory	e-authentication guidelines for eSign			

CCA AUDIT REPORT

		8. For any key management functions eKYC account id, eKYC account PIN and Authpin authentications is required 9. A single session is used for all subscriber actions such as communicating with the HSM for PKCS-10 generation, obtaining PKCS- 10 from the HSM, and setting the Authpin . 10. CA provides secure session access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 11. The key management function by CA is limited only to deletion backup and restore 12. The private key can be deleted by the subscriber directly or by CA as per the scenarios mentioned under CPS. i.e the private key shall be deleted after revocation. 13. The private key is retained by the HSM beyond the certificate validity period. 14. The certificate renewal, re-key suspension etc., are not allowed under this scheme					
3.8.13.25	The HSM administrator of the hosting environment shall not be able to perform the subscriber's key authentication function.	Check the following are implemented by CA and examine the input/out , sample testing if applicable 1. The CA generates key pair for subscriber only after successful authentication to subscriber's eKYC account. 2. The Authpin for subsequent successful authorization is set by the subscriber 3. The HSM securing the private key of subscriber is physically hosted at CA premises or application owner' s premises. 4. HSM securing the private keys of subscribers is under the sole administrative control of CA. 5. The key generation is in the FIPS 140- 2 Level 3 validated/certified HSM. 6. Private keys are always be secured by HSM 7. The HSM administrator of the hosting environment cannot perform the subscriber's key authentication function 8. For any key management functions eKYC account id, eKYC account PIN and Authpin authentications is required 9. A single session is used for all subscriber actions such as communicating with the HSM for PKCS-10 generation, obtaining PKCS- 10 from the HSM, and setting the Authpin . 10. CA provides secure session access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 11. The key management function by CA is limited only to deletion backup and restore 12. The private key can be deleted by the subscriber directly or by CA as per the scenarios mentioned under CPS. i.e the private key shall be deleted after revocation.	Mandatory	e-authentication guidelines for eSign			

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		13. The private key is retained by the HSM beyond the certificate validity period. 14. The certificate renewal, re-key suspension etc., are not allowed under this scheme					
3.8.13.26	For any key management functions eKYC account id, eKYC account PIN and Authpin authentications shall be required.	Check the following are implemented by CA and examine the input/out , sample testing if applicable 1. The CA generates key pair for subscriber only after successful authentication to subscriber's eKYC account. 2. The Authpin for subsequent successful authorization is set by the subscriber 3. The HSM securing the private key of subscriber is physically hosted at CA premises or application owner' s premises. 4. HSM securing the private keys of subscribers is under the sole administrative control of CA. 5. The key generation is in the FIPS 140- 2 Level 3 validated/certified HSM. 6. Private keys are always be secured by HSM 7. The HSM administrator of the hosting environment cannot perform the subscriber's key authentication function 8. For any key management functions eKYC account id, eKYC account PIN and Authpin authentications is required 9. A single session is used for all subscriber actions such as communicating with the HSM for PKCS-10 generation, obtaining PKCS- 10 from the HSM, and setting the Authpin . 10. CA provides secure session access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 11. The key management function by CA is limited only to deletion backup and restore 12. The private key can be deleted by the subscriber directly or by CA as per the scenarios mentioned under CPS. i.e the private key shall be deleted after revocation. 13. The private key is retained by the HSM beyond the certificate validity period. 14. The certificate renewal, re-key suspension etc., are not allowed under this scheme	Mandatory	e-authentication guidelines for eSign			
3.8.13.27	To ensure the centrally stored private key is bound to the subscriber, implement all subscriber actions such as communicating with the HSM for PKCS-10 generation, obtaining	Check the following are implemented by CA and examine the input/out , sample testing if applicable 1. The CA generates key pair for subscriber only after successful authentication to subscriber's eKYC account. 2. The Authpin for subsequent successful authorization is set by the subscriber 3. The HSM securing the private key of subscriber is physically hosted at CA premises or application owner' s premises.	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

	PKCS-10 from the HSM, and setting the Authpin in a single secure session. This secure session shall be available to the subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG	4. HSM securing the private keys of subscribers is under the sole administrative control of CA. 5. The key generation is in the FIPS 140- 2 Level 3 validated/certified HSM. 6. Private keys are always be secured by HSM 7. The HSM administrator of the hosting environment cannot perform the subscriber's key authentication function 8. For any key management functions eKYC account id, eKYC account PIN and Authpin authentications is required 9. A single session is used for all subscriber actions such as communicating with the HSM for PKCS-10 generation, obtaining PKCS- 10 from the HSM, and setting the Authpin . 10. CA provides secure session access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 11. The key management function by CA is limited only to deletion backup and restore 12. The private key can be deleted by the subscriber directly or by CA as per the scenarios mentioned under CPS. i.e the private key shall be deleted after revocation. 13. The private key is retained by the HSM beyond the certificate validity period. 14. The certificate renewal, re-key suspension etc., are not allowed under this scheme					
3.8.13.28	The key management function by CA is limited only to deletion backup and restore	Check the following are implemented by CA and examine the input/out , sample testing if applicable 1. The CA generates key pair for subscriber only after successful authentication to subscriber's eKYC account. 2. The Authpin for subsequent successful authorization is set by the subscriber 3. The HSM securing the private key of subscriber is physically hosted at CA premises or application owner' s premises. 4. HSM securing the private keys of subscribers is under the sole administrative control of CA. 5. The key generation is in the FIPS 140- 2 Level 3 validated/certified HSM. 6. Private keys are always be secured by HSM 7. The HSM administrator of the hosting environment cannot perform the subscriber's key authentication function 8. For any key management functions eKYC account id, eKYC account PIN and Authpin authentications is required 9. A single session is used for all subscriber actions such as communicating with the HSM for PKCS-10 generation, obtaining PKCS- 10 from the HSM, and setting the Authpin .	Mandatory	e-authentication guidelines for eSign			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		10. CA provides secure session access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 11. The key management function by CA is limited only to deletion backup and restore 12. The private key can be deleted by the subscriber directly or by CA as per the scenarios mentioned under CPS. i.e the private key shall be deleted after revocation. 13. The private key is retained by the HSM beyond the certificate validity period. 14. The certificate renewal, re-key suspension etc., are not allowed under this scheme					
3.8.13.29	The private key can be deleted by the subscriber directly or by CA as per the scenarios mentioned under CPS. i.e the private key shall be deleted after revocation.	Check the following are implemented by CA and examine the input/out , sample testing if applicable 1. The CA generates key pair for subscriber only after successful authentication to subscriber's eKYC account. 2. The Authpin for subsequent successful authorization is set by the subscriber 3. The HSM securing the private key of subscriber is physically hosted at CA premises or application owner' s premises. 4. HSM securing the private keys of subscribers is under the sole administrative control of CA. 5. The key generation is in the FIPS 140- 2 Level 3 validated/certified HSM. 6. Private keys are always be secured by HSM 7. The HSM administrator of the hosting environment cannot perform the subscriber's key authentication function 8. For any key management functions eKYC account id, eKYC account PIN and Authpin authentications is required 9. A single session is used for all subscriber actions such as communicating with the HSM for PKCS-10 generation, obtaining PKCS- 10 from the HSM, and setting the Authpin . 10. CA provides secure session access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 11. The key management function by CA is limited only to deletion backup and restore 12. The private key can be deleted by the subscriber directly or by CA as per the scenarios mentioned under CPS. i.e the private key shall be deleted after revocation. 13. The private key is retained by the HSM beyond the certificate validity period. 14. The certificate renewal, re-key suspension etc., are not allowed under this scheme	Mandatory	e-authentication guidelines for eSign			
3.8.13.30	The private key	Check the following are implemented by	Mandatory	e-authentication			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	shall not be retained by the HSM beyond the certificate validity period.	CA and examine the input/out , sample testing if applicable 1. The CA generates key pair for subscriber only after successful authentication to subscriber's eKYC account. 2. The Authpin for subsequent successful authorization is set by the subscriber 3. The HSM securing the private key of subscriber is physically hosted at CA premises or application owner' s premises. 4. HSM securing the private keys of subscribers is under the sole administrative control of CA. 5. The key generation is in the FIPS 140- 2 Level 3 validated/certified HSM. 6. Private keys are always be secured by HSM 7. The HSM administrator of the hosting environment cannot perform the subscriber's key authentication function 8. For any key management functions eKYC account id, eKYC account PIN and Authpin authentications is required 9. A single session is used for all subscriber actions such as communicating with the HSM for PKCS-10 generation, obtaining PKCS- 10 from the HSM, and setting the Authpin . 10. CA provides secure session access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 11. The key management function by CA is limited only to deletion backup and restore 12. The private key can be deleted by the subscriber directly or by CA as per the scenarios mentioned under CPS. i.e the private key shall be deleted after revocation. 13. The private key is retained by the HSM beyond the certificate validity period. 14. The certificate renewal, re-key suspension etc., are not allowed under this scheme		guidelines for eSign			
3.8.13.31	The certificate renewal, re-key suspension etc., are not allowed under this scheme	Check the following are implemented by CA and examine the input/out , sample testing if applicable 1. The CA generates key pair for subscriber only after successful authentication to subscriber's eKYC account. 2. The Authpin for subsequent successful authorization is set by the subscriber 3. The HSM securing the private key of subscriber is physically hosted at CA premises or application owner' s premises. 4. HSM securing the private keys of subscribers is under the sole administrative control of CA. 5. The key generation is in the FIPS 140- 2 Level 3 validated/certified HSM. 6. Private keys are always be secured by HSM 7. The HSM administrator of the hosting	Mandatory	e-authentication guidelines for eSign			

COPY AUDIT REPORT

		environment cannot perform the subscriber's key authentication function 8. For any key management functions eKYC account id, eKYC account PIN and Authpin authentications is required 9. A single session is used for all subscriber actions such as communicating with the HSM for PKCS-10 generation, obtaining PKCS- 10 from the HSM, and setting the Authpin . 10. CA provides secure session access to subscriber for key generation & setting Authpin only after the satisfactory completion of identity verification as per IVG 11. The key management function by CA is limited only to deletion backup and restore 12. The private key can be deleted by the subscriber directly or by CA as per the scenarios mentioned under CPS. i.e the private key shall be deleted after revocation. 13. The private key is retained by the HSM beyond the certificate validity period. 14. The certificate renewal, re-key suspension etc., are not allowed under this scheme					
Authpin Authentication							
3.8.13.32	Authpin for activation of the private key shall be stored along with eKYC id	Verify the following :- 1. The subscriber authentication related functions are carried out by SAM 2. Authpin for activation of the private key is stored along with eKYC id 3. Authpin I of 6 characters in length 4. A secure session is used for both auth pin authentication & data submission 5. The maximum number of consecutive Authpin retries does not exceed 10 after which the account will be temporarily locked out for a period of no less than one hour or until HSM Trusted Administrator takes action. 6. Upon three consecutive lockouts, the account will be permanently locked out. 7. CA provided mechanism for resetting Authpin by the subscriber 8. The authe PIN reset is only after a successful video verification of the subscriber	Mandatory	e-authentication guidelines for eSign			
3.8.13.33	SAM shall perform subscriber authentication related functions	Verify the following :- 1. The subscriber authentication related functions are carried out by SAM 2. Authpin for activation of the private key is stored along with eKYC id 3. Authpin I of 6 characters in length 4. A secure session is used for both auth pin authentication & data submission 5. The maximum number of consecutive Authpin retries does not exceed 10 after which the account will be temporarily locked out for a period of no less than one hour or until HSM Trusted Administrator takes action.	Mandatory	e-authentication guidelines for eSign			

COPY AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		6. Upon three consecutive lockouts, the account will be permanently locked out. 7. CA provided mechanism for resetting Authpin by the subscriber 8. The authe PIN reset is only after a successful video verification of the subscriber					
3.8.13.34	Authpin shall be 6 characters in length	Verify the following :- 1. The subscriber authentication related functions are carried out by SAM 2. Authpin for activation of the private key is stored along with eKYC id 3. Authpin I of 6 characters in length 4. A secure session is used for both auth pin authentication & data submission 5. The maximum number of consecutive Authpin retries does not exceed 10 after which the account will be temporarily locked out for a period of no less than one hour or until HSM Trusted Administrator takes action. 6. Upon three consecutive lockouts, the account will be permanently locked out. 7. CA provided mechanism for resetting Authpin by the subscriber 8. The authe PIN reset is only after a successful video verification of the subscriber	Mandatory	e-authentication guidelines for eSign			
3.8.13.35	To protect the Authpin from exposure & binding to data to be signed, HSM shall use a secure session for submission of the data to be signed, once the Authpin authentication succeeds.	Verify the following :- 1. The subscriber authentication related functions are carried out by SAM 2. Authpin for activation of the private key is stored along with eKYC id 3. Authpin I of 6 characters in length 4. A secure session is used for both auth pin authentication & data submission 5. The maximum number of consecutive Authpin retries does not exceed 10 after which the account will be temporarily locked out for a period of no less than one hour or until HSM Trusted Administrator takes action. 6. Upon three consecutive lockouts, the account will be permanently locked out. 7. CA provided mechanism for resetting Authpin by the subscriber 8. The authe PIN reset is only after a successful video verification of the subscriber	Mandatory	e-authentication guidelines for eSign			
3.8.13.36	The maximum number of consecutive Authpin retries shall be 10 after which the account shall be temporarily locked out for a period of no less than one hour or until HSM Trusted Administrator takes	Verify the following :- 1. The subscriber authentication related functions are carried out by SAM 2. Authpin for activation of the private key is stored along with eKYC id 3. Authpin I of 6 characters in length 4. A secure session is used for both auth pin authentication & data submission 5. The maximum number of consecutive Authpin retries does not exceed 10 after which the account will be temporarily locked out for a period of no less than one	Mandatory	e-authentication guidelines for eSign			

CCA IN AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	action. Upon three consecutive lockouts, the account shall be permanently locked out.	hour or until HSM Trusted Administrator takes action. 6. Upon three consecutive lockouts, the account will be permanently locked out. 7. CA provided mechanism for resetting Authpin by the subscriber 8. The authe PIN reset is only after a successful video verification of the subscriber					
3.8.13.37	Upon permanent locked out of account, CA should provide mechanism for resetting Authpin by the subscriber after a successful video verification of the subscriber	Verify the following :- 1. The subscriber authentication related functions are carried out by SAM 2. Authpin for activation of the private key is stored along with eKYC id 3. Authpin I of 6 characters in length 4. A secure session is used for both auth pin authentication & data submission 5. The maximum number of consecutive Authpin retries does not exceed 10 after which the account will be temporarily locked out for a period of no less than one hour or until HSM Trusted Administrator takes action. 6. Upon three consecutive lockouts, the account will be permanently locked out. 7. CA provided mechanism for resetting Authpin by the subscriber 8. The authe PIN reset is only after a successful video verification of the subscriber	Mandatory	e-authentication guidelines for eSign			
Roles, privileges and access control							
3.8.13.38	The following human users or IT entity with designated roles & privileges interact with SAM	Verify the following:- CA implemented the following human users or IT entity with designated roles & privileges to interact with SAM 1. Users - the authorised and registered subscribers 2. HSM Administrator: Handling software code, initialization of subscriber 3. Administrator -security, user management and other administrative functions 4. Verification agent - establishing the identity of the signatory, providing this data to the SAM ensuring it’s integrity and initiating the lifecycle of the signatory account. Signatory account creation and initialization are not allowed without verification agent’s authentication. 5. Auditor -The auditor is in charge of performing the audit functions	Mandatory	e-authentication guidelines for eSign			
3.8.13.39	Users - the authorised and registered subscribers	Verify the following:- CA implemented the following human users or IT entity with designated roles & privileges to interact with SAM 1. Users - the authorised and registered subscribers 2. HSM Administrator: Handling software code, initialization of subscriber 3. Administrator -security, user management	Mandatory	e-authentication guidelines for eSign			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		and other administrative functions 4. Verification agent - establishing the identity of the signatory, providing this data to the SAM ensuring it's integrity and initiating the lifecycle of the signatory account. Signatory account creation and initialization are not allowed without verification agent's authentication. 5. Auditor -The auditor is in charge of performing the audit functions					
3.8.13.40	HSM Administrator: Handling software code, initialization of subscriber	Verify the following:- CA implemented the following human users or IT entity with designated roles & privileges to interact with SAM 1. Users - the authorised and registered subscribers 2. HSM Administrator: Handling software code, initialization of subscriber 3. Administrator -security, user management and other administrative functions 4. Verification agent - establishing the identity of the signatory, providing this data to the SAM ensuring it's integrity and initiating the lifecycle of the signatory account. Signatory account creation and initialization are not allowed without verification agent's authentication. 5. Auditor -The auditor is in charge of performing the audit functions	Mandatory	e-authentication guidelines for eSign			
3.8.13.41	Administrator - security, user management and other administrative functions	Verify the following:- CA implemented the following human users or IT entity with designated roles & privileges to interact with SAM 1. Users - the authorised and registered subscribers 2. HSM Administrator: Handling software code, initialization of subscriber 3. Administrator -security, user management and other administrative functions 4. Verification agent - establishing the identity of the signatory, providing this data to the SAM ensuring it's integrity and initiating the lifecycle of the signatory account. Signatory account creation and initialization are not allowed without verification agent's authentication. 5. Auditor -The auditor is in charge of performing the audit functions	Mandatory	e-authentication guidelines for eSign			
3.8.13.42	Verification agent - establishing the identity of the signatory, providing this data to the SAM ensuring it's integrity and initiating the lifecycle of the signatory account.	Verify the following:- CA implemented the following human users or IT entity with designated roles & privileges to interact with SAM 1. Users - the authorised and registered subscribers 2. HSM Administrator: Handling software code, initialization of subscriber 3. Administrator -security, user management and other administrative functions	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	Signatory account creation and initialization shall not allow without verification agent's authentication.	4. Verification agent - establishing the identity of the signatory, providing this data to the SAM ensuring it's integrity and initiating the lifecycle of the signatory account. Signatory account creation and initialization are not allowed without verification agent's authentication. 5. Auditor -The auditor is in charge of performing the audit functions					
3.8.13.43	Auditor -The auditor is in charge of performing the audit functions	Verify the following:- CA implemented the following human users or IT entity with designated roles & privileges to interact with SAM 1. Users - the authorised and registered subscribers 2. HSM Administrator: Handling software code, initialization of subscriber 3. Administrator -security, user management and other administrative functions 4. Verification agent - establishing the identity of the signatory, providing this data to the SAM ensuring it's integrity and initiating the lifecycle of the signatory account. Signatory account creation and initialization are not allowed without verification agent's authentication. 5. Auditor -The auditor is in charge of performing the audit functions	Mandatory	e-authentication guidelines for eSign			
Software Modules							
3.8.13.44	CA shall implement the following software components in the CA systems for interfacing with HSM for management of eKYC account synchronization, key management, certificate management, Authpin management , and signature as per eSign Remote API 1.X	Verify the following 1. CA has implemented the following software components in the CA systems for interfacing with HSM for management of eKYC account synchronization, key management, certificate management, Authpin management , and signature as per eSign Remote API 1.X a) CHI- eKYC account synchronization, key management, certificate management, Authpin management shall be managed by CA-HSM Interface (CHI) software module b) SHI- The Signing-HSM interface (SHI) module shall interface with HSM for signature functionalities. The SHI module may be hosted in the CA or at trusted third party site. c) AI- CA shall implement Authentication Interface(AI) software component as per eSign API 1.x for interfacing with subscriber and HSM for authentication. 2. All communication between CHI, SHI and AI is signed & encrypted through secure channel 3. CHI, SHI and AI modules are digitally signed by CA.	Mandatory	e-authentication guidelines for eSign			
3.8.13.45	CHI- eKYC account synchronization,	Verify the following 1. CA has implemented the following software components in the CA systems for	Mandatory	e-authentication guidelines for eSign			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	key management, certificate management, Authpin management shall be managed by CA-HSM Interface (CHI) software module	interfacing with HSM for management of eKYC account synchronization, key management, certificate management, Authpin management , and signature as per eSign Remote API 1.X a) CHI- eKYC account synchronization, key management, certificate management, Authpin management shall be managed by CA-HSM Interface (CHI) software module b) SHI- The Signing-HSM interface (SHI) module shall interface with HSM for signature functionalities. The SHI module may be hosted in the CA or at trusted third party site. c) AI- CA shall implement Authentication Interface(AI) software component as per eSign API 1.x for interfacing with subscriber and HSM for authentication. 2. All communication between CHI, SHI and AI is signed & encrypted through secure channel 3. CHI, SHI and AI modules are digitally signed by CA.					
3.8.13.46	SHI- The Signing-HSM interface (SHI) module shall interface with HSM for signature functionalities. The SHI module may be hosted in the CA or at trusted third party site.	Verify the following 1. CA has implemented the following software components in the CA systems for interfacing with HSM for management of eKYC account synchronization, key management, certificate management, Authpin management , and signature as per eSign Remote API 1.X a) CHI- eKYC account synchronization, key management, certificate management, Authpin management shall be managed by CA-HSM Interface (CHI) software module b) SHI- The Signing-HSM interface (SHI) module shall interface with HSM for signature functionalities. The SHI module may be hosted in the CA or at trusted third party site. c) AI- CA shall implement Authentication Interface(AI) software component as per eSign API 1.x for interfacing with subscriber and HSM for authentication. 2. All communication between CHI, SHI and AI is signed & encrypted through secure channel 3. CHI, SHI and AI modules are digitally signed by CA.	Mandatory	e-authentication guidelines for eSign			
3.8.13.47	AI- CA shall implement Authentication Interface(AI) software component as per eSign API 1.x for interfacing with subscriber and HSM for authentication.	Verify the following 1. CA has implemented the following software components in the CA systems for interfacing with HSM for management of eKYC account synchronization, key management, certificate management, Authpin management , and signature as per eSign Remote API 1.X a) CHI- eKYC account synchronization, key management, certificate management, Authpin management shall be managed by CA-HSM Interface (CHI) software module b) SHI- The Signing-HSM interface (SHI) module shall interface with HSM for signature functionalities. The SHI module	Mandatory	e-authentication guidelines for eSign			

COMPLIANCE AUDIT REPORT

		may be hosted in the CA or at trusted third party site. c) AI- CA shall implement Authentication Interface(AI) software component as per eSign API 1.x for interfacing with subscriber and HSM for authentication. 2. All communication between CHI, SHI and AI is signed & encrypted through secure channel 3. CHI, SHI and AI modules are digitally signed by CA.					
3.8.13.48	All communication between CHI, SHI and AI shall be signed & encrypted through secure channel	Verify the following 1. CA has implemented the following software components in the CA systems for interfacing with HSM for management of eKYC account synchronization, key management, certificate management, Authpin management , and signature as per eSign Remote API 1.X a) CHI- eKYC account synchronization, key management, certificate management, Authpin management shall be managed by CA-HSM Interface (CHI) software module b) SHI- The Signing-HSM interface (SHI) module shall interface with HSM for signature functionalities. The SHI module may be hosted in the CA or at trusted third party site. c) AI- CA shall implement Authentication Interface(AI) software component as per eSign API 1.x for interfacing with subscriber and HSM for authentication. 2. All communication between CHI, SHI and AI is signed & encrypted through secure channel 3. CHI, SHI and AI modules are digitally signed by CA.	Mandatory	e-authentication guidelines for eSign			
3.8.13.49	CHI, SHI and AI modules shall be digitally signed by CA.	Verify the following 1. CA has implemented the following software components in the CA systems for interfacing with HSM for management of eKYC account synchronization, key management, certificate management, Authpin management , and signature as per eSign Remote API 1.X a) CHI- eKYC account synchronization, key management, certificate management, Authpin management shall be managed by CA-HSM Interface (CHI) software module b) SHI- The Signing-HSM interface (SHI) module shall interface with HSM for signature functionalities. The SHI module may be hosted in the CA or at trusted third party site. c) AI- CA shall implement Authentication Interface(AI) software component as per eSign API 1.x for interfacing with subscriber and HSM for authentication. 2. All communication between CHI, SHI and AI is signed & encrypted through secure channel 3. CHI, SHI and AI modules are digitally signed by CA.	Mandatory				

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

CA Requirements							
3.8.13.50	The procedure to be followed for issuance of crypto token based certificates and eSign services are described/referred in the CPS. The following section will be used as a reference point in the CPS for certificate life cycle & signature service based on remote-key storage	Check the reference points in CPS in respect of certificate life cycle & signature service based on remote-key storage.	Mandatory	e-authentication guidelines for eSign			
CA INFRASTRUCTURE							
3.8.13.51	The CA system used for issuance of crypto token based DSC can be integrated with remote key storage based DSC issuance.	Verify the CA system used for issuance of crypto token based DSC is integrated with remote key storage based DSC issuance.	Mandatory	e-authentication guidelines for eSign			
DSC Application Form							
3.8.13.52	The DSC application form for long term validity DSC issuance on remote key-storage of a subscriber shall be as per the CPS and Schedule IV of IT Act.	Validate the DSC application form for long term validity DSC issuance on remote key-storage of a subscriber is as per the CPS and Schedule IV of IT Act.	Mandatory	e-authentication guidelines for eSign			
3.8.13.53	Response code shall be generated by ESP on eKYC user authentication request for certificate generation and should be a part of DSC & DSC application form. The Response Code should be of length 32.	Validate the response code is generated by ESP on eKYC user authentication request for certificate generation and the same is a part of DSC & DSC application form. The Response Code should be of length 32	Mandatory	e-authentication guidelines for eSign			
3.8.13.54	eSign signer can have one or more eKYC user account	Verify the CA has implemented the option for one or more eKYC user account for the same user.	Mandatory	e-authentication guidelines for eSign			
Key Life cycle & Signature requirements							

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.8.13.55	The key life cycle should be able to handle the following functions : 1. Creation of account in the protected storage area of HSM 2. Enrolment for authentication and signature service 3. Key pair and certificate generation 4. Activation of signature service 5. Use of signature service 6. Deactivation of signature service 7. Deletion of the account created in the SAM	Verify the key life cycle is able to handle the following functions : 1. Creation of account in the protected storage area of HSM 2. Enrolment for authentication and signature service 3. Key pair and certificate generation 4. Activation of signature service 5. Use of signature service 6. Deactivation of signature service 7. Deletion of the account created in the SAM	Mandatory	e-authentication guidelines for eSign			
3.8.13.56	For the certificate life cycle functions which involve HSM interaction, upon successful authentication to eKYC account by subscriber, CA redirect subscriber to HSM environment through CHI.	Verify the following In the case of remote key storage based option implementation by CA, upon successful authentication to eKYC account by subscriber, CA redirect subscriber to HSM environment through CHI.	Mandatory	e-authentication guidelines for eSign			
3.8.13.57	The request/response between CA system and HSM environment shall be as per the eSign Remote API 1.X	Validate that the request/response between CA system and HSM environment is as per the eSign Remote API 1.X	Mandatory	e-authentication guidelines for eSign			
3.8.13.58	eKYC account is pre-requisite for remote key storage. After success authentication to eKYC account by subscriber, CA redirect user to HSM environment for key generation, setting of Authpin, CSR generation, and verification of certificate details and download of certificate through	Verify the following 1. eKYC account is created for each remote key storage based option to subscriber. 2.After success authentication to eKYC account by subscriber, CA redirect user to HSM environment for key generation, setting of Authpin, CSR generation, and verification of certificate details and download of certificate through CHI 3.The functions mentioned in 2 are happening in a single secure session	Mandatory	e-authentication guidelines for eSign			

CCA - IT AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	CHI. CA shall ensure that all these actions are happening in a single secure session.						
3.8.13.59	Subscriber requesting for revocation shall be redirected to HSM environment through CHI for revocation of certificate. For self-revocation, the authentication to eKYC account is mandatory.	Check the following 1. Subscriber requesting for certificate revocation is redirected to HSM environment through CHI. 2. CA system allows self-revocation, only after the successful authentication to eKYC account.	Mandatory	e-authentication guidelines for eSign			
3.8.13.60	The CA trusted persons are also be allowed to revoke after due verification as per the conditions and procedure specified under CPS	Verify CAtrusted persons revoke certificate after due verification per the conditions and procedure specified under CPS	Mandatory	e-authentication guidelines for eSign			
3.8.13.61	The Signing HSM Interface (SHI) module for subscriber signature function can reside at CA premises or trusted third party premises.	Verify the Signing HSM Interface (SHI) module for subscriber signature function is hosted at CA premises or trusted third party premises only	Mandatory	e-authentication guidelines for eSign			
3.8.13.62	The user shall authenticate to eKYC account in the case of SHI is hosted at CA and trusted third party application access account if it is hosted at trusted third party premises	Validate the Signing HSM Interface (SHI) module for subscriber signature function is hosted at CA premises or trusted third party premises only	Mandatory	e-authentication guidelines for eSign			
3.8.13.63	The SHI software component shall redirect subscriber to HSM environment as per the eSign API .1.X	Check the SHI software component redirect subscriber to HSM environment as per the eSign API .1.X	Mandatory	e-authentication guidelines for eSign			
Audit Trail of Account Creation and Maintenance							
3.8.13.64	The audit trail of certificate issuance,	Check the following 1. The audit trail of certificate issuance, key	Mandatory	e-authentication guidelines for			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	key generation, Authpin setting/reset , signature request/response etc should be maintained by CA. The date/time stamp, requested source details etc. also should be accessible for audit.	generation, Authpin setting/reset , signature request/response etc are maintained by CA. 2. The date/time stamp, requested source details etc. are also accessible for audit.		eSign			
3.8.13.65	A monthly audit of ten percent (subjected to maximum of 5000) of the certificate issuance, signature functions shall be carried out by an IS Auditor in the following month and the report shall be made available during Annual CA compliance Audit.	Check the following 1. A monthly audit of ten percent (subjected to maximum of 5000) of the certificate issuance, signature functions is carried out by an IS Auditor in the following month 2. The report is to auditors of Annual CA compliance Audit.	Mandatory	e-authentication guidelines for eSign			

3.9. Other Business and Legal Matters

3.10. CA website, Application software , CA software requirements

3.10.1. Compliance Requirements for the CA Website

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.10.2. Compliance Requirements for the Application system.

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
The applicant software provides external access to users. The compliance requirements for the software are below.							
3.10.2.1	The verification requirements shall be as per CCA-IVG. The applicant software should have strictly implemented the functions as mentioned in the Guidelines issued by CCA	Verify the following w.r.t controls 1. RA software specifications	Mandatory	CCA-CALIC 2.1 Annexure VI			
Application Interface Software							

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

3.10.2.2	The verification requirements shall be as per CCA-IVG. The applicant software should have strictly implemented the functions as mentioned in the Guidelines issued by CCA.	Verify the following 1. VA-PT by Cert-in empanelled auditor and Its closure 2. Internal VA-PT report and its closure	Mandatory	CCA-CALIC 2.1 Annexure VI			
Audit Logs and Evidence Requirements							
3.10.2.3	The applicant software must generate audit logs for user actions, user failures, and modifications to the configuration	Verify the following 1. Roles defined in the RA software and its privilege given. As this is critical , the the corresponding software, schema and interaces may be checked to verify the practices followed by CA against the procedure mentioned in IVG 2. Whether role based access implemented 3. subscriber and RA roles maintained 4. RA's access to applicants' information is limited only up to the approval by CA 5. RA's page view shall be restricted to RA who facilitated the DSC application form submission only	Mandatory	CCA-CALIC 2.1 Annexure VI			
3.10.2.4	The audit logs shall be secured in the CA facility with physical and system access controls as required for CA operations.	Verify the following 1. Roles defined in the RA software and its privilege given. As this is critical , the the corresponding software, schema and interaces may be checked to verify the practices followed by CA against the procedure mentioned in IVG 2. Whether role based access implemented 3. subscriber and RA roles maintained 4. RA's access to applicants' information is limited only up to the approval by CA 5. RA's page view shall be restricted to RA who facilitated the DSC application form submission only	Mandatory	CCA-CALIC 2.1 Annexure VI			
3.10.2.5	The audit logs should be stored in the CA facility.	Verify the following 1. Roles defined in the RA software and its privilege given. As this is critical , the the corresponding software, schema and interaces may be checked to verify the practices followed by CA against the procedure mentioned in IVG 2. Whether role based access implemented 3. subscriber and RA roles maintained 4. RA's access to applicants' information is limited only up to the approval by CA 5. RA's page view shall be restricted to RA who facilitated the DSC application form submission only	Mandatory	CCA-CALIC 2.1 Annexure VI			
3.10.2.6	The audit logs are to be protected for data integrity	Verify the following 1. Roles defined in the RA software and its privilege given. As this is critical , the the	Mandatory	CCA-CALIC 2.1 Annexure VI			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

	preferably using Syslog servers	corresponding software, schema and interaces may be checked to verify the practices followed by CA against the procedure mentioned in IVG 2. Whether role based access implemented 3. subscriber and RA roles maintained 4. RA's access to applicants' information is limited only up to the approval by CA 5. RA's page view shall be restricted to RA who facilitated the DSC application form submission only					
3.10.2.7	The applicant interface access shall be periodically reviewed.	Verify the following 1. Roles defined in the RA software and its privilege given. As this is critical , the the corresponding software, schema and interaces may be checked to verify the practices followed by CA against the procedure mentioned in IVG 2. Whether role based access implemented 3. subscriber and RA roles maintained 4. RA's access to applicants' information is limited only up to the approval by CA 5. RA's page view shall be restricted to RA who facilitated the DSC application form submission only	Mandatory	CCA-CALIC 2.1 Annexure V			
Session Time-out							
3.10.2.8	In the eKYC account creation process, inactivity time limits shall be enforced. The activity time limits shall be as per the following 1. eSign-based Signature - Immediate 2. eKYC account Information submission - 20 minutes 3. OTP authentication - 5 minutes 4. DSC applicant Login - 20 Minutes 5. Exit upon inactivity - 5 minutes	1. Check whether inactivity time limits are enforced.	Mandatory	CCA-CALIC 2.1 Annexure VI			

3.10.3. Compliance Requirements for the CA system.

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
No Any Parameter Available							

CCA AUDIT REPORT

3.10.3.1	1. The CA management software is expected to be certified as CC EAL4 or higher in consistent with the Certificate Issuing and Management Components Protection Profile, Version 1.5. (NIST) or Protection Profile for Certification Authorities or both. 2. The CAs are encouraged to obtain Common Criteria EAL4+ certification ASAP. In case the CA software does not have certification at present, as an interim measure, a security audit of the CA software shall be carried out as per “4. Security Evaluation Requirements for CA”. The compliance report in this regard should be made available to the empanelled auditors. The broad areas to be covered but not limited to the security audit of CA software are below:	Verify w.r.t controls 1. Verify the certificate scope, validity etc.& consistency with the profiles 2. If not certified verify “Security Evaluation Requirements for CA” report till the specified period.	Optional	CCA-CALIC 2.1 Annexure VI			
3.10.3.2	Security Policy	1. The compliance report in this regard should be made available to the empanelled auditors. The broad areas to be covered but not limited to the Software Application Testing & Evaluation scope are below : • Security Policy • Roles (Administration Officers, Registration Officers, Authentication Officers) • Access Control and Authorization • Identification and Authentication • Remote Data Entry and Export • Key Management: Key Generation, Key Storage, Key Destruction, and Key Export • Cryptographic module requirements • Profile Management(Certificate, CRL, OCSP) • Certificate applicant data registration • Certificate Registration • Certificate Preparation • Certificate approval	Mandatory	CCA-CALIC 2.1 Annexure VI			

COMPLIANCE REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		• Certificate Signing • Certificate Activation • Certificate storage & delivery • Certificate Publication • Certificate Revocation • Certificate Status Information Provision – OCSP, CRL • CA Policy Administration • Key Archiving and Recovery • PIN Management • Audit and Log Review • Batch Processing • Communication with RA Software • Initial Boot Process Threats(Authorised user threats, System related threats, Cryptography related threats, External attacks)					
3.10.3.3	Roles (Administration Officers, Registration Officers, Authentication Officers)	1. The compliance report in this regard should be made available to the empanelled auditors. The broad areas to be covered but not limited to the Software Application Testing & Evaluation scope are below : • Security Policy • Roles (Administration Officers, Registration Officers, Authentication Officers) • Access Control and Authorization • Identification and Authentication • Remote Data Entry and Export • Key Management: Key Generation, Key Storage, Key Destruction, and Key Export • Cryptographic module requirements • Profile Management(Certificate, CRL, OCSP) • Certificate applicant data registration • Certificate Registration • Certificate Preparation • Certificate approval • Certificate Signing • Certificate Activation • Certificate storage & delivery • Certificate Publication • Certificate Revocation • Certificate Status Information Provision – OCSP, CRL • CA Policy Administration • Key Archiving and Recovery • PIN Management • Audit and Log Review • Batch Processing • Communication with RA Software • Initial Boot Process Threats(Authorised user threats, System related threats, Cryptography related threats, External attacks)	Mandatory	CCA-CALIC 2.1 Annexure VI			
3.10.3.4	Access Control and Authorization	1. The compliance report in this regard should be made available to the empanelled auditors. The broad areas to be covered but not limited to the Software Application Testing & Evaluation scope are below : • Security Policy • Roles (Administration Officers, Registration Officers, Authentication Officers) • Access Control and Authorization • Identification and Authentication • Remote Data Entry and Export	Mandatory	CCA-CALIC 2.1 Annexure VI			

COMPLIANCE AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		• Key Management: Key Generation, Key Storage, Key Destruction, and Key Export • Cryptographic module requirements • Profile Management(Certificate, CRL, OCSP) • Certificate applicant data registration • Certificate Registration • Certificate Preparation • Certificate approval • Certificate Signing • Certificate Activation • Certificate storage & delivery • Certificate Publication • Certificate Revocation • Certificate Status Information Provision – OCSP, CRL • CA Policy Administration • Key Archiving and Recovery • PIN Management • Audit and Log Review • Batch Processing • Communication with RA Software • Initial Boot Process Threats(Authorised user threats, System related threats, Cryptography related threats, External attacks)					
3.10.3.5	Identification and Authentication	1. The compliance report in this regard should be made available to the empanelled auditors. The broad areas to be covered but not limited to the Software Application Testing & Evaluation scope are below : • Security Policy • Roles (Administration Officers, Registration Officers, Authentication Officers) • Access Control and Authorization • Identification and Authentication • Remote Data Entry and Export • Key Management: Key Generation, Key Storage, Key Destruction, and Key Export • Cryptographic module requirements • Profile Management(Certificate, CRL, OCSP) • Certificate applicant data registration • Certificate Registration • Certificate Preparation • Certificate approval • Certificate Signing • Certificate Activation • Certificate storage & delivery • Certificate Publication • Certificate Revocation • Certificate Status Information Provision – OCSP, CRL • CA Policy Administration • Key Archiving and Recovery • PIN Management • Audit and Log Review • Batch Processing • Communication with RA Software • Initial Boot Process Threats(Authorised user threats, System related threats, Cryptography related threats, External attacks)	Mandatory	CCA-CALIC 2.1 Annexure V			
3.10.3.6	Remote Data Entry and Export	1. The compliance report in this regard should be made available to the empanelled auditors. The broad areas to be covered but not limited to	Mandatory	CCA-CALIC 2.1 Annexure VI			

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		the Software Application Testing & Evaluation scope are below : • Security Policy • Roles (Administration Officers, Registration Officers, Authentication Officers) • Access Control and Authorization • Identification and Authentication • Remote Data Entry and Export • Key Management: Key Generation, Key Storage, Key Destruction, and Key Export • Cryptographic module requirements • Profile Management(Certificate, CRL, OCSP) • Certificate applicant data registration • Certificate Registration • Certificate Preparation • Certificate approval • Certificate Signing • Certificate Activation • Certificate storage & delivery • Certificate Publication • Certificate Revocation • Certificate Status Information Provision – OCSP, CRL • CA Policy Administration • Key Archiving and Recovery • PIN Management • Audit and Log Review • Batch Processing • Communication with RA Software • Initial Boot Process Threats(Authorised user threats, System related threats, Cryptography related threats, External attacks)					
3.10.3.7	Key Management: Key Generation, Key Storage, Key Destruction, and Key Export	1. The compliance report in this regard should be made available to the empanelled auditors. The broad areas to be covered but not limited to the Software Application Testing & Evaluation scope are below : • Security Policy • Roles (Administration Officers, Registration Officers, Authentication Officers) • Access Control and Authorization • Identification and Authentication • Remote Data Entry and Export • Key Management: Key Generation, Key Storage, Key Destruction, and Key Export • Cryptographic module requirements • Profile Management(Certificate, CRL, OCSP) • Certificate applicant data registration • Certificate Registration • Certificate Preparation • Certificate approval • Certificate Signing • Certificate Activation • Certificate storage & delivery • Certificate Publication • Certificate Revocation • Certificate Status Information Provision – OCSP, CRL • CA Policy Administration • Key Archiving and Recovery • PIN Management • Audit and Log Review • Batch Processing • Communication with RA Software	Mandatory	CCA-CALIC 2.1 Annexure VI			

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

		• Initial Boot Process Threats(Authorised user threats, System related threats, Cryptography related threats, External attacks)					
3.10.3.8	Cryptographic module requirements	1. The compliance report in this regard should be made available to the empanelled auditors. The broad areas to be covered but not limited to the Software Application Testing & Evaluation scope are below : • Security Policy • Roles (Administration Officers, Registration Officers, Authentication Officers) • Access Control and Authorization • Identification and Authentication • Remote Data Entry and Export • Key Management: Key Generation, Key Storage, Key Destruction, and Key Export • Cryptographic module requirements • Profile Management(Certificate, CRL, OCSP) • Certificate applicant data registration • Certificate Registration • Certificate Preparation • Certificate approval • Certificate Signing • Certificate Activation • Certificate storage & delivery • Certificate Publication • Certificate Revocation • Certificate Status Information Provision – OCSP, CRL • CA Policy Administration • Key Archiving and Recovery • PIN Management • Audit and Log Review • Batch Processing • Communication with RA Software • Initial Boot Process Threats(Authorised user threats, System related threats, Cryptography related threats, External attacks)	Mandatory	CCA-CALIC 2.1 Annexure VI			

3.10.4. Security Evaluation Requirements for CA

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.10.5. Conditions for Appointment of Auditor

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

3.10.6. Financial Status Verification

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks

1. Annual Audit Period Details

S. No.	Description	From	To	Brief details of open observation (max 50 words)
Auditor Remarks:				

CCA AUDIT REPORT

2. Internal Audit Details

S. No.	Description	From	To	Brief details of open observation (max 50 words)	Details of Auditors
Auditor Remarks:					

3. eKYC Account Audit Details of last one year - Month-wise

S. No.	Month	From	To	Summary of Observations	Details of Auditors
Auditor Remarks:					

4. eKYC Account-based Verification Enabled by CA - Details of the Audit Period

S. No.	Option	Date of Approval by CCA	No DSCs Issued	Associated External Service	Details of External Service
Auditor Remarks:					

5. RA Audit Details – During the Annual Audit Period

S. No.	Description	Details
1	Number of RAs	Total RAs - Active RAs -
2	Dates of RA Audit	
3	Details of Non-Compliance reported by RAs	)
4	Action Taken by CAs	
Auditor Remarks:		

6. No of Court Cases / Police Complaints

S. No.	Description	Details
1	Number of active court cases related to verification prior to issuance of DSC (Exists before the audit period)	
2	Number of court cases related to verification prior to issuance of DSC (Registered during the audit period)	
3	Number of police complaints against CA on DSC issuance/verification related activities	
Auditor Remarks:		

7. No of Revocation of DSC during the Audit Period

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

S. No.	Description	Details
1	Number of DSCs revoked	
2	Number of revocation requests received from subscriber/organizations & reasons	
3	Number of DSCs revoked by CAs & reasons	)
Auditor Remarks:		

8. Empanelment of Crypto Token

S. No.	Brand Name of Token	Details of OEM	Make in India Percentage	FIPs Certification up to	Details of Security Audit Details of Crypto token
Auditor Remarks:					

9. Details of CA Software/Website

S. No.	Description	Developed By	Database Used	Certification	Last Security Audit
Auditor Remarks:					

10. Details of DC & DR Site

S. No.	Description	Location	No of System Administrators	No of CA Operators	No of Verification Officers	Total CA Manpower
Auditor Remarks:						

11. Details of CA Services

S. No.	Description	Internal Only	External Service	No of ASPs/ Organizations
Auditor Remarks:				

12. Details of ASP

S. No.	Description	Details
1	No of ASPs	
2	No of ASPs whose audit exceed more than One year	
Auditor Remarks:		

13. Public Information maintained at the website of CA

S. No.	Description	Website Link

COPY - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

Auditor Remarks:

14. Cost of Certificates issued during audit period

S. No.	Description	Details
1	Average expenditure for issuance of one DSC and maintenance of the details for a period of 7 years after expiry of DSC	
2	Average fee charged for one DSC by CA	
3	Detailed explanation, sustainability plan if the average fee charged is less than average cost of certificates	
Auditor Remarks:		

15. CA Self-assessment for audit period

S. No.	Name	Details
1	No of DSC issued without any DSC application Forms, if any & reason for non-compliance.	
2	No of DSC issued without charging fee, if any & details.	
3	No DSC issued without having physical verification(video/Biometric Aadhaar) if any	
4	No of DSC issued(except for foreign nationals) whose name is not matching with as that of in Aadhaar or PAN, if any & reason for noncompliance	
5	Whether CA system allows sending common OTP to many customers? If Yes, reason for such non-compliance	
6	Whether access to CA system is based on single URL-point or allows Link based access. If link-based access allowed, provide details in respect of coverage of such access in the security audit, annual audit & internal audit. The details of vulnerabilities and non-compliance noted for each type of links.	
7	The effort taken by CA to find out the own-noncompliance and action Taken during the audit period.	
Auditor Remarks:		

16. CA Software and external connectivity

S. No.	Name	Details
Auditor Remarks:		

15. CA Self-assessment for audit period

S. No.	Name	Details
1	Total service down time during the audit period, if any.	
2	Reason for non-availability of service and remedial measures taken.	
Auditor Remarks:		

18. List of CA Trusted Persons

S. No.	Name	Designation	Location of Posting DC/DR	Role in CA	ID Card No & Mobile	Identification Details in the CA Payroll	Employed Since	Training details	Date of last background verification

CA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

Auditor Remarks:

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

DNS TXT Record Addition Request

SSL Certificate Renewal - ceg.meity.gov.in

To	DNS Administration (meity.gov.in zone)
From	CEG / MeitY Team
Date	19-May-2026
Subject	Let's Encrypt DNS-01 validation - add 2 TXT records for ceg.meity.gov.in

1. Background

The TLS certificate for ceg.meity.gov.in (previously issued by ZeroSSL) expired on 28-Aug-2025. A replacement is being issued via Let's Encrypt using DNS-01 ACME validation. The application server (10.249.166.4) has no outbound internet access, so validation cannot be performed from the server directly. NIC is requested to publish two DNS TXT records in the meity.gov.in zone. No other changes are required.

2. System Details

Item	Value
Primary hostname	`ceg.meity.gov.in`
Additional hostname	`www.ceg.meity.gov.in`
Public IP (A record)	`164.100.94.128`
Application server	itc1CEGP-CEGWEB - 10.249.166.4 (internal)
Web stack	Apache / Tomcat 8.5.61
Certificate authority	Let's Encrypt (ACME v2)
Validation method	DNS-01 (TXT records under _acme-challenge)
ACME account email	apabishekraj@gmail.com

3. Action Required

Add the two TXT records below to the meity.gov.in zone. Remove any existing _acme-challenge TXT entries for the same names before adding these.

Record 1

Field	Value
Name / Host	`_acme-challenge.ceg`
FQDN	`_acme-challenge.ceg.meity.gov.in`
Type	TXT
TTL	300 (or minimum allowed)

CCA AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30

Value	JxV0TmBs4SzHLdg9FKZ6pbNwUaU-X0CGKNid2WBCZWI

Record 2

Field	Value
Name / Host	_acme-challenge.www.ceg
FQDN	_acme-challenge.www.ceg.meity.gov.in
Type	TXT
TTL	300 (or minimum allowed)
Value	3K7r2boTUgF2aEHn955Y1FNtVQ9bWm6omk3z00giYkg

Notes:

1. Do not wrap token values in additional quotes unless the DNS management panel requires it.
2. Do not modify or split the token strings.

4. Verification

Once records are published, verify using the following commands from any host with external DNS access:

```
dig +short TXT _acme-challenge.ceg.meity.gov.in @8.8.8.8
dig +short TXT _acme-challenge.www.ceg.meity.gov.in @8.8.8.8
```

CCA - AUDIT REPORT

Digitally signed by Gaurav Singh
Date: 2026.05.21 17:10:11 +05:30